Київський столичний університет імені Бориса Грінченка

Володимир Соколов

ТЕХНОЛОГІЇ БЕЗПЕКИ ВЕБРЕСУРСІВ

Навчальний посібник

для здобувачів другого (освітнього) рівня вищої освіти
спеціальності 125/F5 «Кібербезпека та захист інформації»
галузі знань 12/F «Інформаційні технології»

Київ — 2027

УДК УДК 004.056:004.738.5(075.8)
ББК 32.973.202
С594

Препринт

Соколов В. Ю. Технології безпеки вебресурсів : навчальний посібник для здобувачів другого (освітнього) рівня вищої освіти. Київ, КСУБГ, 2027, 91 с. — 17 розділів.

Навчальний посібник охоплює теоретичні основи та практичні аспекти технологій безпеки вебресурсів. Розглянуто вебресурси як об'єкт захисту, архітектури вебплатформи, модель порушника та простір загроз; нормативно-правове й стандартизаційне забезпечення в Україні та Європейському Союзі; математичні та кількісні основи оцінювання захищеності; моделювання загроз і управління ризиками; захист транспортного рівня та інфраструктури доставки; безпеку браузера й клієнтської частини; протидію ін'єкційним атакам; автентифікацію й керування сеансами; авторизацію та федеративну ідентифікацію; безпеку API й мікросервісних архітектур; захист від відмови в обслуговуванні та автоматизованих загроз; безпеку серверної, хмарної й контейнерної інфраструктури; безпеку ланцюга постачання програмного забезпечення; безпеку вебзастосунків зі штучним інтелектом; тестування захищеності; моніторинг, виявлення вторгнень і реагування на інциденти; безпечний життєвий цикл розроблення, управління безпекою та напрями наукових досліджень.

Кожен розділ завершується висновками та питаннями для самоперевірки, серед яких — дослідницькі завдання, придатні як відправна точка для наукової статті чи фрагмента дисертаційного дослідження. Посібник призначено для магістрантів галузі знань 12/F «Інформаційні технології» спеціальності 125/F5 «Кібербезпека та захист інформації», а також буде корисним науковим і науково-педагогічним працівникам, фахівцям із захисту інформації та кібербезпеки.

© Володимир Соколов, 2027
© Київський столичний університет імені Бориса Грінченка, 2027

Зміст

Основні терміни та скорочення **1**

Вступ **3**

1 Вебресурси як об'єкт захисту: архітектури, модель порушника й простір загроз **7**
1.1 Поняття та класифікація вебресурсів 7
1.2 Еволюція архітектур вебресурсів 9
1.3 Протокол HTTP і вебплатформа як середовище виконання . 10
1.4 Властивості безпеки вебресурсів 12
1.5 Модель порушника 13
1.6 Простір загроз і багаторівнева поверхня атаки 16
1.7 Український контекст: атаки на державні вебресурси 19
1.8 Термінологічний апарат і структура курсу 21
Висновки до розділу 22
Питання для самоперевірки 22

2 Нормативно-правове та стандартизаційне забезпечення безпеки вебресурсів **25**
2.1 Структура нормативного поля 25
2.2 Законодавство України 27
2.3 Право Європейського Союзу 29
2.4 Міжнародні стандарти 32
2.5 Галузеві рамки OWASP 34
2.6 Оцінювання відповідності та сертифікація 35
2.7 Порівняльний аналіз вимог України та ЄС 37
2.8 Кейс: визначення застосовних вимог 37
Висновки до розділу 38
Питання для самоперевірки 39

3 Математичні та кількісні основи оцінювання захищеності вебресурсів **41**
3.1 Постановка задачі кількісного оцінювання захищеності . . . 41
3.2 Ентропія та стійкість секретів 42
3.3 Моделі підбору облікових даних 44
3.4 Теорія статистичного виявлення 46

3.5 Моделі масового обслуговування для оцінювання стійкості до відмови в обслуговуванні 48
3.6 Атакові графи та марковські моделі 50
3.7 Оцінки вразливостей і ймовірнісна пріоритизація 52
3.8 Розгорнутий приклад комплексного розрахунку 54
Висновки до розділу 55
Питання для самоперевірки 56

4 Моделювання загроз і управління ризиками вебзастосунків 59
4.1 Процес управління ризиками 59
4.2 Моделювання загроз вебзастосунку 61
4.3 Бази знань про атаки та слабкості 64
4.4 Дерева атак 65
4.5 Кількісне оцінювання ризику 66
4.6 Безпека за проєктом 68
4.7 Невизначеність оцінок 69
4.8 Кейс: модель загроз і реєстр ризиків порталу державних послуг 71
Висновки до розділу 72
Питання для самоперевірки 73

Список використаних джерел 75

Додаток. Завдання для самостійної роботи 85

Основні терміни та скорочення

Вступ

Вебресурси стали основною формою надання інформаційних і транзакційних послуг. Через вебінтерфейси та програмні інтерфейси (API) громадяни отримують державні послуги, здійснюють платежі, навчаються й лікуються, а організації керують бізнес-процесами, ланцюгами постачання й навіть промисловими об'єктами. Відповідно вебзастосунки є найпоширенішою точкою входу для зловмисників: помилки контролю доступу, ін'єкції, вади автентифікації й неправильні конфігурації десятиліттями очолюють рейтинги вразливостей, а атаки на ланцюг постачання програмного забезпечення, відмова в обслуговуванні терабітного масштабу та зловживання вебзастосунками зі штучним інтелектом формують нові класи загроз. Специфіка захисту вебресурсів полягає в тому, що вони за визначенням відкриті для анонімних користувачів з усього світу, виконують код у середовищі, яке не контролює власник (браузер клієнта), і складаються з великої кількості сторонніх компонентів, кожен з яких може стати джерелом компрометації.

Досвід України останніх років зробив ці питання предметом не лише академічного інтересу. Масові дефейси й руйнівні атаки на державні вебресурси напередодні повномасштабного вторгнення, постійні розподілені атаки на відмову в обслуговуванні на портали органів влади, банків і медіа, компрометації облікових записів і витоки персональних даних перетворили безпеку вебресурсів на складову національної стійкості. Одночасно цифровізація державних послуг (портал і застосунок «Дія», електронні реєстри) підвищила цінність вебінфраструктури як об'єкта атаки. Змінилося й нормативне поле: оновлено законодавство про кібербезпеку та захист державних інформаційних ресурсів, триває гармонізація з вимогами Європейського Союзу, зокрема Директивою NIS 2 і Регламентом про кіберстійкість.

Мета і завдання навчальної дисципліни

Мета курсу — формування в магістрантів знань, умінь і навичок із застосування теоретичних основ та технологій забезпечення безпеки вебресурсів для захисту інформаційних ресурсів і послуг.

Завдання курсу — отримання теоретичних знань та практичних умінь з дослідження й застосування технологій безпеки вебресурсів та набуття таких компетентностей:

- здатність застосовувати сучасні технології безпеки під час проєктування, розроблення та експлуатації захищених вебресурсів;
- здатність оцінювати захищеність і знаходити раціональні рішення щодо захисту вебзастосунків, програмних інтерфейсів та інфраструктури їх доставки;
- здатність до вдосконалення й наукового дослідження засобів і технологій забезпечення безпеки вебресурсів.

Структура посібника

Матеріал згруповано у чотири логічні блоки.

Блок I. Засади (розділи 1–4) формує понятійний апарат: вебресурси як об'єкт захисту, архітектури вебплатформи та простір загроз; нормативно-правове й стандартизаційне поле; математичні та кількісні основи оцінювання захищеності; моделювання загроз і управління ризиками.

Блок II. Механізми та технології захисту вебзастосунків (розділи **??**–**??**) присвячено власне засобам: захисту транспортного рівня та інфраструктури доставки, безпеці браузера й клієнтської частини, протидії ін'єкційним атакам, автентифікації та керуванню сеансами, авторизації й федеративній ідентифікації, безпеці API та мікросервісних архітектур, захисту від відмови в обслуговуванні та автоматизованих загроз.

Блок III. Платформи, інфраструктура та нові класи загроз (розділи **??**–**??**) охоплює безпеку серверної, хмарної й контейнерної інфраструктури, безпеку ланцюга постачання програмного забезпечення та систем керування вмістом, безпеку вебзастосунків зі штучним інтелектом.

Блок IV. Операційна безпека та управління (розділи **??**–**??**) охоплює тестування захищеності, моніторинг і реагування на інциденти, а також безпечний життєвий цикл розроблення, управління програмою безпеки й методологію наукових досліджень.

Як працювати з посібником

Посібник розраховано на здобувачів другого (освітнього) рівня вищої освіти, які вже володіють базовими знаннями з інформаційної безпеки, комп'ютерних мереж, вебтехнологій і криптографії. Виклад побудовано як систематизація на рівні моделей, доказових аргументів і критичного аналізу чинних рішень, а не як первинне ознайомлення з предметом чи інструкція з експлуатації конкретних інструментів. Формули супроводжуються поясненням позначень і числовими прикладами, які варто відтворити самостійно. Фрагменти коду й конфігурацій наведено лише там, де вони пояснюють механізм атаки чи захисту.

Питання для самоперевірки наприкінці кожного розділу неоднорідні: частина перевіряє відтворення матеріалу, частина потребує аналізу й порівняння, а завершальні питання сформульовано як дослідницькі завдання — вони можуть слугувати відправною точкою для наукової статті або фрагмента дисертаційного дослідження. Магістрантові рекомендується опрацьовувати їх у зв'язці з власною темою.

Посилання на джерела наведено в квадратних дужках; повний список подано наприкінці видання. Перевагу віддано чинним нормативним документам, національним та міжнародним стандартам, специфікаціям IETF, W3C і WHATWG, галузевим рамкам OWASP і рецензованим науковим працям. Усі нормативні акти, стандарти й рейтинги загроз слід перевіряти на чинність редакції на момент використання: вебтехнології та ландшафт загроз змінюються особливо швидко. Практичні вправи з атакувальними техніками допустимо виконувати лише на власних стендах або в межах письмово погодженого тестування на проникнення.

Термінологічне зауваження

У виданні вживаються терміни **вебресурс**, **вебзастосунок**, **вебсервер** відповідно до чинного правопису (разом). Під *вебресурсом* розуміємо сукупність вебсайтів, вебзастосунків і програмних інтерфейсів, доступних через протокол HTTP, разом з інфраструктурою, що забезпечує їх функціонування. Англомовні терміни, що не мають усталеного українського відповідника, наводяться в дужках мовою оригіналу при першому вживанні.

РОЗДІЛ 1

Вебресурси як об'єкт захисту: архітектури, модель порушника й простір загроз

Вебресурси стали основною формою надання інформаційних, фінансових і державних послуг. Водночас вебресурс за визначенням відкритий для будь-кого в Інтернеті: його вхідні точки доступні анонімному порушникові, клієнтська частина виконується на пристрої, який власник не контролює, а значна частина коду надходить від сторонніх постачальників. Розділ формує системне бачення вебресурсу як об'єкта захисту — від класифікації й архітектур до моделі порушника і простору загроз, на які спиратимуться наступні розділи. Окремо проаналізовано досвід атак на українські державні вебресурси 2022–2025 рр.

1.1 Поняття та класифікація вебресурсів

1.1.1 Базові означення

Вебресурс — сукупність інформаційних і програмних засобів, доступ до яких надається за протоколом HTTP (HTTPS) за уніфікованим ідентифікатором ресурсу (URI), разом з інфраструктурою, що забезпечує їхнє функціонування. З правового погляду вебресурс є різновидом інформаційно-комунікаційної системи, тож на нього поширюються вимоги законодавства про захист інформації [24] і кібербезпеку [27] (розділ 2).

Усередині цього поняття розрізняють кілька видів, що відрізняються саме з погляду безпеки. **Вебсайт** призначений переважно для подання інформації, а логіка зосереджена в системі керування вмістом (CMS). **Вебзастосунок** (web application) має стан, облікові записи, права доступу й обробляє персональні чи фінансові дані. **Вебпрограмний інтерфейс** (web API) повертає структуровані дані іншим програмам, тому браузерні механізми захисту тут не діють. **Односторінковий застосунок** (Single-Page Application, SPA) обмінюється із сервером лише даними через API; **прогресивний вебзастосунок** (PWA) додає сервіс-воркери і локальні сховища. Окремий клас становлять **державні вебресурси** — портали електронних послуг, вебінтерфейси реєстрів, офіційні сайти органів влади. Їх вирізняє поєднання масового доступу, обробки персональних даних усього населення [25], юридичної значущості операцій [21] і символічної цінності для політично мотивованого порушника.

1.1.2 Рівні об'єкта захисту

Запит користувача проходить через кілька середовищ із різними власниками й моделями довіри. Доцільно виділити п'ять рівнів об'єкта захисту: *клієнт і браузер* (пристрій, розширення, код застосунку в браузері, локальні сховища; розділ ??); *канал* (DNS, TLS, вузли мережі доставки вмісту CDN, зворотні проксі; розділи ??, ??); *вебзастосунок* (серверна логіка, сеанси, автентифікація, авторизація, обробка вхідних даних, де локалізується більшість вразливостей з OWASP Top 10 [108] і CWE Top 25 [36]; розділи ??–??); *платформа та інфраструктура* (вебсервер, ОС, контейнери, хмарні сервіси, секрети; розділ ??); *сторонні компоненти* (бібліотеки, плагіни CMS, сторонні скрипти, зовнішні API, конвеєри збирання), що пронизують усі інші рівні (розділ ??). Засоби захисту одного рівня не компенсують слабкостей іншого: TLS не захищає від ін'єкції SQL, а перевірка вхідних даних на сервері безсила проти скомпрометованого стороннього скрипту в браузері.

1.1.3 Класифікація вебресурсів за моделлю довіри

З погляду безпеки вебресурси доцільно класифікувати за моделлю довіри: хто є користувачем і клієнтом, які дані обробляються і наскільки значущі наслідки порушення (табл. 1.1).

Таблиця 1.1 — Класи вебресурсів та їхні безпекові характеристики

Клас	Модель довіри	Характерні ризики
Інформаційний сайт (CMS)	анонімні читачі, кілька редакторів	дефейс, вразливі плагіни, захоплення адмінпанелі, розміщення шкідливого вмісту
Вебзастосунок з обліковими записами	автентифіковані користувачі з різними ролями	порушення контролю доступу, викрадення сеансів, XSS, ін'єкції, витік ПД
Вебпрограмний інтерфейс (API)	програмні клієнти з токенами	BOLA/IDOR, надмірне розкриття даних, зловживання частотою, тіньові API
SPA/PWA	логіка частково в браузері, токени в клієнті	DOM-XSS, зберігання токенів, сторонні скрипти, кешування в сервіс-воркері
Електронна комерція	клієнти, платіжні провайдери	скимери на сторінках оплати, боти, шахрайство, вимоги PCI DSS [110]
Державний портал і реєстр	усе населення, юридично значущі операції	масові витоки ПД, DDoS, дефейс, атаки на ідентифікацію, ланцюг постачання підрядників

Зі зростанням значущості операцій зростає не лише цінність ресурсу для порушника, а й кількість незалежних доменів довіри: для державного порталу вона охоплює громадян, розпорядників реєстрів, банки-постачальники ідентифікації, підрядників, хмарних і CDN-провайдерів. Тому вимоги до державних вебресурсів встановлюються не лише галузевими

рамками на кшталт OWASP ASVS [102], а й нормативними актами щодо захисту державних інформаційних ресурсів [19].

1.2 Еволюція архітектур вебресурсів

1.2.1 Від статичних сторінок до мікросервісів

Історію вебархітектур зручно розглядати як послідовність етапів, на кожному з яких змінювалися розподіл логіки між клієнтом і сервером і модель безпеки (табл. 1.2). Спільний шлюзовий інтерфейс (CGI) уперше дозволив запускати на сервері програму з параметрами від користувача, і з ним з'явилася ін'єкція команд ОС. Стек LAMP і CMS зробили типовою трирівневу архітектуру, а з нею прийшли SQLi, XSS, CSRF і масові атаки на CMS [126, 134]. Односторінкові застосунки перенесли логіку в браузер, а сервер став постачальником даних через API в стилі REST [70]: клієнтський код повністю видимий і модифікований порушником, тож будь-яка перевірка в браузері має дублюватися на сервері. Мікросервіси перетворили внутрішні виклики функцій на мережеві запити, що потребують міжсервісної автентифікації (розділ ??), а serverless і edge-обчислення переносять код у середовище провайдера, де основними об'єктами захисту стають ідентичності, ролі й конфігурація.

Таблиця 1.2 — Етапи еволюції вебархітектур і зміна моделі безпеки

Етап	Розподіл логіки	Нові класи загроз і зміна моделі безпеки
Статичні сторінки	лише сервер файлів	обхід каталогів, розкриття вмісту; периметр = сервер
CGI	програми на сервері	ін'єкція команд, переповнення буфера, неперевірені параметри
LAMP, CMS	трирівнева, логіка на сервері	SQLi, XSS, CSRF, вразливі плагіни, масові атаки на CMS
AJAX, SPA	логіка в браузері, сервер = API	DOM-XSS, зберігання токенів, CORS, надмірні дані в API
Мікросервіси	десятки сервісів, шлюз API	міжсервісна довіра, SSRF, тіньові API, секрети в конфігурації
Serverless, edge	код у середовищі провайдера	надмірні права ролей, помилки конфігурації, спільна відповідальність
CDN, WAF/WAAP	проміжні вузли з розкриттям TLS	довіра до провайдера, обхід до джерела, концентрація ризику
LLM-агенти	рішення ухвалює модель	ін'єкція підказок, надмірна автономія (розділ ??)

Кожен етап не скасовує загроз попереднього: ін'єкції команд ОС і SQL досі є в CWE Top 25:2025 [36]. Сучасний вебресурс поєднує CMS, SPA, мікросервіси, хмарні функції й CDN, тому його поверхня атаки є *об'єднанням* поверхонь атаки всіх використаних стилів.

1.2.2 Узагальнена архітектура та домени довіри

На рис. 1.1 наведено узагальнену архітектуру сучасного вебресурсу з доменами довіри. Браузер користувача належить до домену, який власник не контролює. Периферійний рівень (CDN, WAF, захист від DDoS) зазвичай належить провайдерові, якому делеговано розкриття TLS і фільтрацію трафіку. Шлюз API, сервіси й дані належать власникові, але часто розміщуються в хмарі під спільною відповідальністю з провайдером. Сторонні постачальники — платіжні системи, постачальники ідентичності (OpenID Connect [118]), аналітика, сервіси штучного інтелекту — обмінюються даними із сервісами через API, а браузер безпосередньо завантажує їхні скрипти.

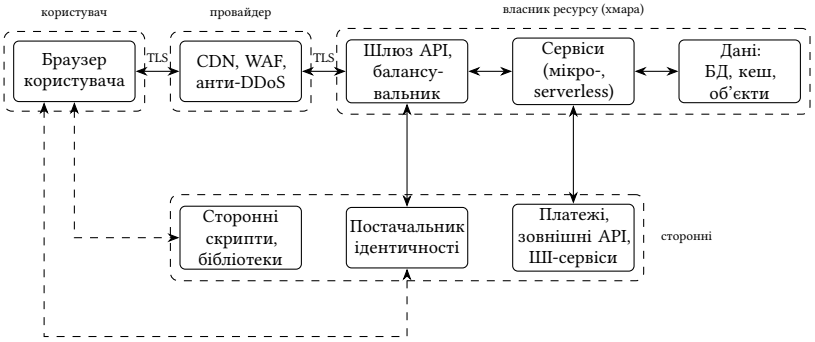


Рис. 1.1 — Узагальнена архітектура сучасного вебресурсу та домени довіри

З рис. 1.1 випливає: межа між доменами довіри — це місце, де дані мають бути перевірені (вхідні дані від браузера, відповіді зовнішніх API, токени); провайдер CDN/WAF бачить увесь трафік відкритим і концентрує ризик; сервер-джерело, доступний в обхід CDN, нейтралізує весь периферійний захист (розділ **??**); у браузері код власника і сторонніх постачальників виконується з однаковими правами. Це узгоджується з принципом нульової довіри [117]: жоден сегмент не вважається довіреним лише через своє розташування.

1.3 Протокол HTTP і вебплатформа як середовище виконання

1.3.1 Версії HTTP і безстановість

HTTP визначає семантику, незалежну від версії: методи, коди стану, заголовки, подання [71]. У текстовому HTTP/1.1 розбіжність тлумачення заголовків `Content-Length` і `Transfer-Encoding` між проксі та сервером спричиняє контрабанду запитів (request smuggling); двійкове мультиплексува-

ння HTTP/2 відкрило нові вектори відмови в обслуговуванні (розділ ??); у HTTP/3 [45] поверх QUIC шифрування TLS 1.3 [116] вбудоване в транспорт, тож мережевий моніторинг втрачає видимість і контроль зміщується до кінцевих точок.

Принциповою властивістю HTTP є **безстановість**: кожен запит обробляється незалежно. Стан сеансу відтворюється поверх протоколу за допомогою cookie [42] або токенів у заголовку `Authorization`. Звідси фундаментальна вразливість вебу: *володіння ідентифікатором сеансу еквівалентне автентифікації.* Хто отримав cookie сеансу — через XSS, перехоплення, фіксацію чи витік журналів, — той діє від імені користувача без пароля і без багатофакторної автентифікації (розділ ??).

1.3.2 Походження та політика того самого походження

Центральним поняттям моделі безпеки вебплатформи є **походження** (origin), означене в RFC 6454 [43] як трійка $o = \langle \text{схема}, \text{хост}, \text{порт} \rangle$. Два URL мають однакове походження лише тоді, коли збігаються всі три компоненти. **Політика того самого походження** (Same-Origin Policy, SOP) забороняє сценаріям одного походження *читати* дані іншого, але браузер дозволяє *надсилати* запити до іншого походження (зображення, форми, скрипти) і автоматично додає до них cookie. Ця асиметрія є коренем атак CSRF і міжсайтових витоків, а механізми контрольованого послаблення SOP (CORS, `postMessage`) стають джерелом помилок конфігурації [77, 69] (розділ ??). Важливо, що SOP захищає походження *одне від одного*, але не *від коду, який сторінка сама завантажила*: скрипт, підключений з іншого домену, виконується з правами походження сторінки і може читати DOM, вміст форм і cookie без атрибута `HttpOnly`.

Отже, браузер фактично є операційною системою для недовіреного коду: він ізолює процеси сайтів, керує доступом до пристроїв і сховищ, а одночасно виконує сценарії кількох суб'єктів з різними намірами [39]. Відповіддю на цю модель є ізоляція сайтів, CSP [57], заголовки ізоляції походжень і Trusted Types.

1.3.3 Кількісна оцінка залежності сторінки від стороннього коду

Нікіфоракіс і співавтори встановили, що 88,45 % із 10 000 найпопулярніших сайтів включають хоча б один віддалений JavaScript-сценарій [97]; Лауінгер і співавтори на вибірці понад 133 тис. сайтів показали, що 37 % з них використовують бібліотеку JavaScript з відомою вразливістю [90]. За даними Web Almanac 2024, 92 % сторінок мають хоча б одного стороннього постачальника, медіана становить 27 постачальників для мільйона найпопулярніших сайтів і 66 — для тисячі найпопулярніших, а сценарії становлять 30,5 % сторонніх запитів [130].

Введемо **частку стороннього коду** сторінки

$$\theta = \frac{\sum_{j \in T} s_j}{\sum_{j \in S} s_j}, \tag{1.1}$$

де S — множина виконуваних ресурсів сторінки (сценаріїв і модулів WebAssembly), $T \subseteq S$ — ресурси з походжень, які не контролює власник, s_j — розмір j-го ресурсу. Якщо сторінка включає код n незалежних постачальників, кожен з яких може бути скомпрометований протягом року з імовірністю q_i, то за відсутності механізмів, що обмежують дію скомпрометованого коду (SRI, CSP, ізоляція в iframe), імовірність хоча б одного шкідливого включення за рік

$$P_{\text{комп}} = 1 - \prod_{i=1}^{n} (1 - q_i) \approx 1 - e^{-n\bar{q}}. \tag{1.2}$$

Приклад: за медіанних $n = 27$ і $\bar{q} = 0{,}002$ маємо $P_{\text{комп}} \approx 1 - e^{-0{,}054} \approx 5{,}3\,\%$ на рік; для сайту з верхньої тисячі ($n = 66$) — $1 - e^{-0{,}132} \approx 12{,}4\,\%$. Компрометація одного популярного постачальника (як у випадку Polyfill.io 2024 р.) одночасно зачіпає всі сайти, що його включають (розділ **??**). Формула (1.2) вказує три напрями зниження ризику: зменшення n (самостійне розміщення бібліотек), зменшення q_i (вибір постачальників, фіксація версій) і розрив зв'язку між компрометацією постачальника та виконанням коду в контексті сторінки.

1.4 Властивості безпеки вебресурсів

Класична тріада «конфіденційність–цілісність–доступність» [7, 121] для вебресурсів доповнюється автентичністю, підзвітністю й приватністю. Специфіка вебу полягає не в переліку властивостей, а в тому, *де* і *ким* вони забезпечуються: частину механізмів реалізує браузер, яким власник не керує, частину — сторонні провайдери (табл. 1.3).

Таблиця 1.3 — Властивості безпеки вебресурсів

Властивість	Вебспецифіка й типові механізми	Розділи
Конфіденційність	TLS, HSTS, захист cookie, мінімізація даних у відповідях API, ізоляція походжень	??, ??, ??
Цілісність	цілісність вмісту сторінки (SRI, CSP), захист від ін'єкцій і CSRF, цілісність ланцюга постачання	??, ??, ??
Доступність	стійкість до DDoS прикладного рівня, CDN, обмеження частоти, обробка винятків	??, ??
Автентичність	сертифікати сервера, автентифікація користувачів і сервісів, ключі доступу (passkeys)	??, ??, ??
Підзвітність	журналювання дій, прив'язка до ідентичності, підпис транзакцій, аудит	??, ??
Приватність	мінімізація відстеження, керування згодою, обмеження сторонніх скриптів	2, ??

Конфіденційність у вебі порушується не лише перехопленням, а й надмірним розкриттям даних самим застосунком: API, що повертає повний об'єкт користувача, розкриває всі його поля кожному, хто відкриє інструменти розробника. *Цілісність* охоплює і дані на сервері, і код, що виконується в браузері; другий вимір порушують дефейси, скимери і компрометація сторонніх бібліотек. *Доступність* визначається найслабшою ланкою ланцюга DNS–CDN–джерело–база даних. *Автентичність* двобічна: користувач має бути впевнений у легітимності ресурсу, а ресурс — що запит надійшов від користувача і з його волі (протидія CSRF і clickjacking); NIST SP 800-63-4 [127] вимагає для вищих рівнів гарантії фішингостійкої автентифікації з прив'язкою автентифікатора до походження (WebAuthn [132]). *Приватність* має власні загрози — відстеження між сайтами, відбиток браузера, витоки через сторонні скрипти — і регулюється окремим законодавством [112, 25].

Властивості можуть суперечити одна одній: журналювання створює сховище персональних даних, CDN підвищує доступність, але розширює коло суб'єктів, що бачать трафік, протидія ботам погіршує приватність. Такі компроміси мають бути явно обґрунтовані в моделі загроз (розділ 4).

1.5 Модель порушника

1.5.1 Класичні моделі та їхня адаптація до вебу

Модель Долева–Яо, у якій порушник повністю контролює мережу, для вебу одночасно надто сильна (більшість атак не потребує контролю над мережею) і надто слабка (не охоплює ключової можливості — *змусити браузер жертви виконати дії* з її cookie). Тому Ахаве і співавтори [39] запропонували ієрархію: **вебпорушник** (web attacker) контролює власні сайти з дійсними сертифікатами і може заманити на них жертву, але не контролює

мережу; **мережевий порушник** (пасивний чи активний) додатково перехоплює і змінює трафік; **порушник-гаджет** (gadget attacker) може вбудувати обмежений вміст (зображення, рекламний блок, сценарій) у легітимний сайт. До ієрархії природно додати порушника з доступом до серверної інфраструктури (інсайдер) і порушника, що контролює ланцюг постачання.

Для практичного проєктування модель порушника доцільно задавати кортежем

$$\mathcal{A} = \langle \Pi,\ \Lambda,\ K,\ R,\ M \rangle, \tag{1.3}$$

де Π — позиція щодо системи (зовнішній анонімний, зареєстрований чи привілейований користувач, інсайдер, постачальник, державний актор); Λ — рівні, на яких діє порушник (підрозділ 1.1); K — апріорні знання (вихідний код, архітектура, облікові дані, вразливості нульового дня); R — ресурси (час, ботнет, кошти, персонал); M — мотивація (фінансова, ідеологічна, розвідувальна, руйнівна). Фінансово мотивований порушник обирає найлегші цілі, а державний актор — конкретну ціль, витрачаючи ресурси, непропорційні її вартості. Типові профілі наведено в табл. 1.4; їхні техніки доцільно описувати в термінах CAPEC [55] і MITRE ATT&CK [96]. Відповідно до нормативних документів ТЗІ [12] і вимог до кіберзахисту об'єктів критичної інфраструктури [9] модель порушника є обов'язковим елементом проєктної документації системи захисту (розділ 4).

Таблиця 1.4 — Типові профілі порушника вебресурсів

Профіль	Позиція, ресурси, мотивація	Характерні можливості й атаки
Автоматизований масовий сканер	зовнішній; ботнет; фінансова	сканування адресного простору, експлуатація відомих CVE, підбір облікових даних
Анонімний зовнішній порушник	зовнішній; помірні; різна	ручний пошук вразливостей, ін'єкції, XSS, фішингові двійники
Автентифікований користувач	зареєстрований; знає API; фінансова	IDOR/BOLA, підвищення привілеїв, зловживання бізнес-логікою
Інсайдер	розробник, адміністратор; повні знання	зловживання доступом, закладки в коді, витік секретів і даних
Постачальник	підрядник, бібліотека, CDN, SaaS	компрометація оновлень, сторонніх скриптів, CI/CD
Хактивіст	зовнішній; ботнет-волонтери; ідеологічна	DDoS, дефейси, витоки для розголосу
Державний актор (APT)	будь-яка; значні; розвідувальна, руйнівна	поєднання всіх можливостей, атаки на підрядників, тривала прихована присутність, знищення даних

1.5.2 Кількісна модель автоматизованого масового сканування

Найчисленнішим порушником є автоматизований сканер. За звітом Imperva 2025 р., автоматизований трафік уперше за десятиліття перевищив людський і становить 51 % вебтрафіку, з них 37 % припадає на шкідливих ботів [37]. Дурумерік, Вустров і Халдерман показали, що інструмент ZMap з одного комп'ютера обстежує весь адресний простір IPv4 менш ніж за 45 хв [66], а сканування всього Інтернету стали буденною практикою [65]. Час повного обстеження адресного простору $|\mathcal{N}|$ зі швидкістю r проб за секунду

$$T_{\text{скан}} = \frac{|\mathcal{N}|}{r}. \tag{1.4}$$

Для IPv4 ($|\mathcal{N}| = 2^{32} \approx 4{,}29 \cdot 10^{9}$) і максимальної швидкості гігабітного Ethernet для мінімальних кадрів ($r \approx 1{,}49 \cdot 10^{6}$ пакетів/с) маємо $T_{\text{скан}} \approx 2\,900$ с ≈ 48 хв, що близько до [66]. Для IPv6 (лише підмережа /64 містить 2^{64} адрес) повний перебір неможливий, і цілі знаходять через журнали прозорості сертифікатів (Certificate Transparency) і DNS. Тому *новий вебресурс слід вважати виявленим з моменту випуску для нього TLS-сертифіката* (розділ **??**).

Якщо кожна з N незалежних спроб експлуатації (проб вхідних точок, варіантів корисного навантаження, пар «логін–пароль») успішна з імовірністю p, то ймовірність успіху хоча б однієї спроби і кількість спроб, потрібна

для досягнення ймовірності P^*,

$$P_N = 1 - (1-p)^N, \qquad N_{\min}(P^*) = \left\lceil \frac{\ln(1-P^*)}{\ln(1-p)} \right\rceil. \tag{1.5}$$

Приклад: для обходу фільтра з $p = 0{,}01$ на спробу досягнення $P^* = 0{,}95$ потребує $N_{\min} = \lceil \ln 0{,}05 / \ln 0{,}99 \rceil = 299$ спроб — тривіальна кількість для автоматизованого засобу. Обмеження частоти до 10 запитів на хвилину розтягує атаку до 30 хв, але не зупиняє ботнет із тисячами адрес (розділи 3, ??).

1.5.3 Гонка між експлуатацією та виправленням

Нехай після оприлюднення вразливості ($t = 0$) масова експлуатація починається в момент t_0, а далі спроби проти кожного вразливого ресурсу надходять пуассонівським потоком з інтенсивністю λ, кожна успішна з імовірністю p. Якщо ресурс виправлено в момент W, імовірність його компрометації до виправлення

$$P_{\text{злам}}(W) = 1 - \exp\bigl(-\lambda p\,(W - t_0)^+\bigr), \qquad (x)^+ = \max(x, 0). \tag{1.6}$$

Нехай для прикладу $t_0 = 72$ год, $\lambda = 0{,}1$ год$^{-1}$, $p = 0{,}5$. Оновлення за 48 год дає $P_{\text{злам}} = 0$; за 96 год — $1 - e^{-1{,}2} \approx 0{,}70$; за два тижні ($W = 336$ год) — $1 - e^{-13{,}2} \approx 1$. Отже, щомісячний цикл оновлень неприйнятний для критичних вразливостей вебресурсів, а основою пріоритизації стають каталог KEV та оцінки EPSS [86] (розділ 3). Дефейс державних сайтів у січні 2022 р. (підрозділ 1.7.3) є ілюстрацією саме цієї гонки.

1.6 Простір загроз і багаторівнева поверхня атаки

1.6.1 Багаторівнева поверхня атаки

Поверхня атаки — сукупність точок, через які порушник може ввести дані в систему, отримати з неї дані або вплинути на її поведінку. Манадхата і Вінг запропонували вимірювати її як суму внесків методів, каналів і елементів даних системи, кожен із яких зважено відношенням потенціалу шкоди до зусиль порушника [91]:

$$AS = \sum_{m \in M} \frac{d(m)}{e(m)} + \sum_{c \in C} \frac{d(c)}{e(c)} + \sum_{i \in I} \frac{d(i)}{e(i)}, \tag{1.7}$$

де M, C, I — доступні порушникові методи (кінцеві точки HTTP і API), канали (HTTPS, WebSocket, gRPC) і елементи даних (файли, записи БД, cookie); $d(\cdot)$ — потенціал шкоди (наприклад, привілеї, з якими виконується метод); $e(\cdot)$ — зусилля (рівень прав, потрібний для доступу). Метрика (1.7) відносна; вона вказує два шляхи зменшення поверхні атаки — вилучення

непотрібних кінцевих точок і підвищення вимог до автентифікації, а «тіньові» API збільшують AS непомітно для захисника (розділ **??**).

Якісно поверхню атаки вебресурсу подають рівнями (рис. 1.2), уздовж яких проходять дві вертикалі: *ланцюг постачання*, що зачіпає всі рівні, і *журналювання та реагування*, без яких атака будь-якого рівня залишається непоміченою.

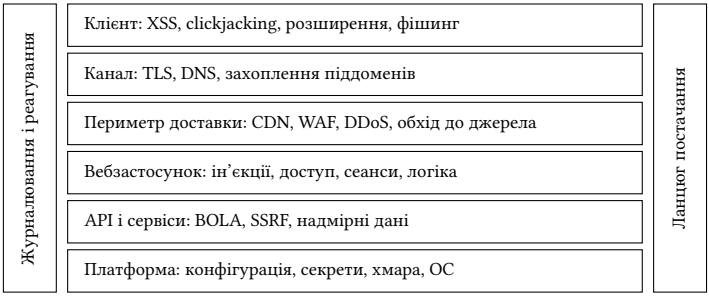


Рис. 1.2 — Багаторівнева поверхня атаки вебресурсу

1.6.2 OWASP Top 10:2025 і CWE Top 25:2025

Редакцію OWASP Top 10:2025 оприлюднено в листопаді 2025 р.; вона ґрунтується на даних тестування понад 2,8 млн застосунків і близько 175 тис. записів CVE, з 589 проаналізованих класів CWE до десяти категорій віднесено 248, вісім категорій визначено за даними, дві — за опитуванням спільноти [108]. Порівняно з редакцією 2021 р. з'явилися дві нові категорії — A03 і A10, SSRF включено до A01, неправильна конфігурація піднялася з п'ятого на друге місце, ін'єкції опустилися з третього на п'яте (табл. 1.5).

Таблиця 1.5 — Категорії OWASP Top 10:2025 і розділи посібника

Код	Категорія	Зміст	Розділи
A01	Broken Access Control	порушення контролю доступу, IDOR, SSRF	??, ??
A02	Security Misconfiguration	помилки конфігурації серверів, хмари, заголовків	??
A03	Software Supply Chain Failures	вразливі й скомпрометовані залежності, CI/CD	??
A04	Cryptographic Failures	слабка або відсутня криптографія	??
A05	Injection	SQLi, XSS, ін'єкція команд	??, ??
A06	Insecure Design	вади проєктування і бізнес-логіки	4, ??
A07	Authentication Failures	вади автентифікації і сеансів	??
A08	Software or Data Integrity Failures	цілісність коду, оновлень, десеріалізація	??, ??
A09	Security Logging & Alerting Failures	недостатнє журналювання й сповіщення	??
A10	Mishandling of Exceptional Conditions	неналежна обробка помилок і винятків	??

Рейтинг CWE Top 25:2025 (MITRE і CISA) підтверджує домінування вебспецифічних слабкостей: перше місце посідає міжсайтовий скриптинг CWE-79 (оцінка 60,38), друге — ін'єкція SQL CWE-89 (28,72), третє — підробка міжсайтових запитів CWE-352 (13,64), четверте — відсутність авторизації CWE-862 (13,28), що піднялася на п'ять позицій; до рейтингу входять також обхід шляху CWE-22, ін'єкція команд ОС CWE-78, необмежене завантаження файлів CWE-434, десеріалізація CWE-502 і SSRF CWE-918 [36]. OWASP Top 10 є переліком *ризиків* для навчання й постановки вимог, CWE Top 25 — рейтингом *слабкостей*; через різний рівень абстракції і методику класифікації їх доцільно використовувати спільно [17]. Для API, LLM-застосунків і верифікації існують окремі переліки OWASP [101, 107, 102].

1.6.3 Композиція загроз і ланцюги атак

Реальні атаки поєднують кілька вразливостей: захоплення облікового запису може складатися зі збереженого XSS, викрадення токена зі сховища браузера і його використання до API. Тому захищеність оцінюють за *ланцюгами атак*. Імовірність успіху ланцюга ℓ з m_ℓ послідовних етапів і хоча б одного з L альтернативних ланцюгів

$$P_\ell = \prod_{j=1}^{m_\ell} p_{\ell j}\big(\mathcal{A}, X\big), \qquad P_\Sigma = 1 - \prod_{\ell=1}^{L}\big(1 - P_\ell\big), \tag{1.8}$$

де $p_{\ell j}$ — імовірність успіху j-го етапу для порушника $\mathcal{A}$ за заходів захисту X. Формула припускає незалежність етапів і ланцюгів; її уточнення на атакових графах розглянуто в розділах 3 і 4. Захід, що обриває обов'язковий

етап, обнуляє P_ℓ незалежно від інших етапів; проте за кількох ланцюгів ризик визначається сукупністю: якщо $P_1 = 0{,}4$, $P_2 = 0{,}3$, $P_3 = 0{,}2$, то $P_\Sigma = 1 - 0{,}6 \cdot 0{,}7 \cdot 0{,}8 = 0{,}664$, а повне закриття найімовірнішого ланцюга знижує ризик лише до $0{,}44$. Звідси принцип глибокого захисту.

1.6.4 Основні класи загроз

Узагальнюючи галузеві рамки [108, 36], огляд загроз ENISA [67] і CyBOK [68], основні класи загроз вебресурсам розподілено між розділами посібника за рівнями рис. 1.2: транспорт, DNS і доставка (розділ ??), клієнтська частина (??), ін'єкції та обробка даних (??), автентифікація й сеанси (??), авторизація і федерація (??), API (??), відмова в обслуговуванні та боти (??), платформа й хмара (??), ланцюг постачання і CMS (??), застосунки зі ШІ (??).

1.7 Український контекст: атаки на державні вебресурси

1.7.1 Хронологія атак 2022–2025 рр.

Атаки на державні вебресурси України передували вторгненню і тривають досі, що робить український досвід унікальним джерелом даних про державного порушника.

Дефейси та WhisperGate (січень 2022 р.). У ніч на 14 січня 2022 р. було атаковано близько 70 державних вебсайтів, зокрема МЗС і МОН; на сторінках з'явилося повідомлення українською, російською і польською мовами; СБУ і Мінцифри заявили, що витоку даних не відбулося, а за оцінками фахівців використана вразливість була відома заздалегідь [15]. Аналітики Unit 42 встановили, що для дефейсу використано вразливість CVE-2021-32648 механізму скидання пароля October CMS [75]. 15 січня Microsoft повідомила про руйнівну програму WhisperGate, що маскувалася під програму-вимагача, але знищувала головний завантажувальний запис і файли без можливості відновлення [49].

DDoS-атаки (лютий–березень 2022 р.). 15 лютого 2022 р. DDoS-атака порушила роботу вебресурсів ПриватБанку, Ощадбанку, сайтів Міноборони і ЗСУ, а також порталу «Дія»; роботу відновили того ж вечора [35]. Атаку назвали наймасштабнішою в історії України: середня потужність сягала десятків гігабіт за секунду, витоку даних не виявлено, натомість зафіксовано ознаки участі іноземних спецслужб [61]. 23 лютого DDoS-атака на урядові сайти збіглася з поширенням вайпера HermeticWiper [49]. За даними Держспецзв'язку, з 15 лютого до середини березня 2022 р. Україна зазнала понад 3 000 DDoS-атак, з рекордом 275 атак за добу і піковою потужністю понад 100 Гбіт/с [5].

Динаміка 2023–2025 рр. За даними CERT-UA, у 2025 р. оброблено 5 927 кіберінцидентів проти 4 315 у 2024 р. (зростання на 37,4 %); найчастіше атакували органи місцевого самоврядування (35,7 %) і державні органи (19,7 %),

а кількість фішингових інцидентів зросла вдвічі [31]. Огляд національної системи кібербезпеки за 2025 р. (НКЦК при РНБО) фіксує зниження кількості інцидентів критичного і високого рівнів із 59 до 12, доповнення псевдохактивістами DDoS-атак і дефейсів атаками на промислові системи, збій IT-систем Укрзалізниці 23 березня 2025 р., що вивів з ладу онлайн-продаж квитків, вебсайт і застосунок, і масові фішингові двійники порталів уряду та «Дії» [16].

1.7.2 Цифрові державні послуги як об'єкт захисту

Портал і застосунок «Дія» (понад 150 послуг і 22,7 млн користувачів [16]) поєднують усі класи табл. 1.1: портал, вебзастосунок з обліковими записами, API для мобільного застосунку й реєстрів, юридично значущі операції з підписом. У термінах моделі (1.3) такий ресурс одночасно є ціллю масового сканера, шахраїв, хактивістів і державного актора. Звідси пріоритети: доступність критична соціально, автентичність ресурсу для громадянина (протидія фішинговим двійникам) важить не менше за автентифікацію громадянина, а цілісність журналів потрібна для юридичної значущості операцій. Нормативну основу захисту становлять закони про кібербезпеку [27] і критичну інфраструктуру [26], координацію реагування здійснюють Держспецзв'язку [4] і CERT-UA [47] (розділи 2, **??**).

1.7.3 Кейс: дефейс державних вебсайтів як ланцюг атаки

Вразливість CVE-2021-32648 стосувалася версій October CMS до 1.0.472 і 1.1.5: механізм скидання пароля порівнював код скидання нестрогим оператором `==`, тож передавання логічного значення `true` замість коду обходило перевірку і дозволяло встановити новий пароль адміністратора [75]. Це вада автентифікації (A07:2025), посилена використанням застарілого компонента (A03:2025). Реконструйований ланцюг має етапи: (1) виявлення сайтів на October CMS; (2) наявність невиправленої версії; (3) скидання пароля адміністратора; (4) зміна вмісту сторінки. Паралельно діяв другий ланцюг — розгортання вайпера WhisperGate в мережах українських організацій [49].

Оцінимо ймовірності за (1.8) для типового сайту на цій CMS. Для порушника, що веде масове сканування (1.4), $p_1 \approx 0{,}95$; частку невиправлених інсталяцій через кілька місяців після виправлення приймемо $p_2 = 0{,}5$; логічна вада не потребує підбору, $p_3 \approx 0{,}95$; доступ адміністратора гарантує зміну вмісту, $p_4 \approx 1$. Отже, $P_1 \approx 0{,}95 \cdot 0{,}5 \cdot 0{,}95 \approx 0{,}45$. Своєчасне оновлення (виграш гонки (1.6)) зводить p_2 до $0{,}05$, а P_1 — до $0{,}045$. Обмеження доступу до адміністративного інтерфейсу CMS довіреними адресами або VPN знижує p_3 для зовнішнього порушника, скажімо, до $0{,}05$; разом два заходи дають $P_1 \approx 0{,}95 \cdot 0{,}05 \cdot 0{,}05 \approx 0{,}0024$, тобто ризик знижується майже у 200 разів. Моніторинг цілісності сторінок атаці не запобігає, але скорочує

час дефейсу. Для 70 сайтів із $P_1 = 0{,}45$ очікувана кількість успішних дефейсів становить ≈ 32, а за двох заходів імовірність хоча б одного дефейсу $1 - (1 - 0{,}0024)^{70} \approx 0{,}15$.

Кейс ілюструє три висновки: державний порушник використовує масові техніки і відомі вразливості, тому базова гігієна дає найбільший ефект; концентрація ресурсів на одній платформі робить окрему ваду системною, і події компрометації сайтів групи не є незалежними; видимий дефейс може супроводжувати приховану руйнівну операцію, тож реагування має включати розслідування в інфраструктурі розробника й хостингу (розділ **??**).

1.8 Термінологічний апарат і структура курсу

Базові поняття вебресурсу, вебсайту, вебзастосунку і вебпрограмного інтерфейсу означено в підрозділі 1.1, походження — у підрозділі 1.3; **сайт** (site) — схема разом із зареєстрованим доменом. **Сервер-джерело** (origin server) — сервер з оригінальним вмістом на противагу вузлам CDN. **Сеанс** — послідовність запитів, пов'язаних спільним станом автентифікації. **Слабкість** (weakness) — тип вади, що за певних умов може призвести до **вразливості**, тобто конкретної вади, яку можна використати для порушення властивостей безпеки (термінологія CWE [56]); **експлойт** — засіб такого використання; **вектор атаки** — шлях, яким порушник досягає вразливості. **Дефейс** (defacement) — несанкціонована зміна вигляду вебсторінки. **Брандмауер вебзастосунків** (WAF) фільтрує запити HTTP на прикладному рівні, а **WAAP** (Web Application and API Protection) додатково охоплює API, ботів і DDoS. Загальні терміни вживаються відповідно до глосарію [121], національних стандартів [7] і ISO/IEC 27034 [84].

Структура курсу відображає рух від загального до конкретного і від механізмів до управління (рис. 1.3). Блок II іде за рівнями поверхні атаки рис. 1.2 від транспорту до доступності, блок III охоплює інфраструктуру, ланцюг постачання і ШІ, блок IV — операційну безпеку й управління. Для кожної категорії OWASP Top 10:2025 відповідні розділи вказано в табл. 1.5. Методологічною основою курсу є CyBOK [68] і фундаментальні праці з безпеки систем [40] і вебзастосунків [134, 76].

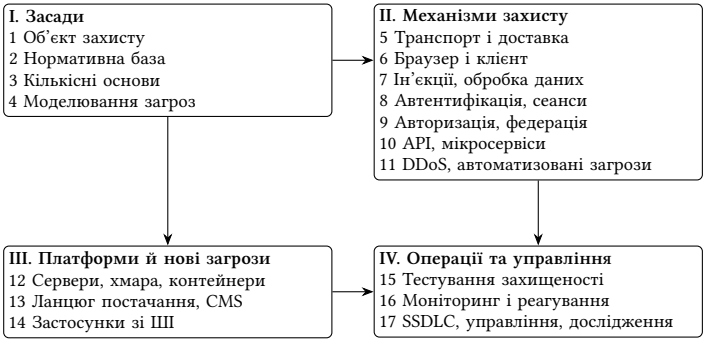


Рис. 1.3 — Структура курсу та зв'язки між блоками розділів

Висновки до розділу

Вебресурс відрізняється від інших інформаційних систем відкритістю вхідних точок для анонімного порушника, виконанням частини коду в неконтрольованому браузері і глибокою залежністю від сторонніх постачальників. Еволюція архітектур не скасовувала загроз попередніх етапів, тож поверхня атаки сучасного ресурсу є об'єднанням поверхонь усіх використаних стилів. Безстановість HTTP робить ідентифікатор сеансу еквівалентом автентифікації, а політика того самого походження не захищає сторінку від коду, який вона сама завантажила; за медіани 27 сторонніх постачальників навіть малі ймовірності їх компрометації дають відчутний річний ризик (1.2). Модель порушника для вебу має враховувати ієрархію «вебпорушник — мережевий порушник — порушник-гаджет» і параметри (1.3); найчисленнішим порушником є автоматизований сканер, для якого обстеження всього IPv4 займає менше години, тому час виправлення критичних вразливостей має вимірюватися годинами й днями (1.6). OWASP Top 10:2025 і CWE Top 25:2025 підтверджують домінування порушень контролю доступу, помилок конфігурації, збоїв ланцюга постачання, XSS та ін'єкцій, а захищеність слід оцінювати за ланцюгами атак (1.8). Український досвід 2022–2025 рр. — дефейси через застарілу CMS, вайпери, масовані DDoS, фішингові двійники порталів — показує, що державний порушник здебільшого використовує відомі вразливості, а базова гігієна, захист адміністративних інтерфейсів і готовність до реагування дають найбільший ефект.

Питання для самоперевірки

1. Дайте означення вебресурсу, вебсайту, вебзастосунку і вебпрограмного інтерфейсу. Чим вони відрізняються з погляду безпеки?

2. Назвіть п’ять рівнів об’єкта захисту вебресурсу й наведіть приклад їх взаємної некомпенсованості.
3. Порівняйте класи вебресурсів (табл. 1.1) за моделлю довіри. Чому для державних порталів кількість доменів довіри максимальна?
4. Користуючись табл. 1.2, поясніть, як перехід до SPA і мікросервісів змінив модель безпеки вебзастосунку.
5. Опишіть домени довіри на рис. 1.1. Які наслідки має доступність сервера-джерела в обхід CDN?
6. Чому безстановість HTTP робить ідентифікатор сеансу еквівалентом автентифікації? Які атрибути cookie зменшують цей ризик?
7. Чи мають однакове походження адреси `https://shop.example`, `https://shop.example:8443` і `http://shop.example`? Від чого не захищає політика того самого походження?
8. За формулою (1.2) обчисліть річну ймовірність компрометації сторінки з кодом 40 сторонніх постачальників при $\bar{q} = 0{,}003$. Як зміниться результат, якщо 30 бібліотек розмістити самостійно?
9. Які властивості доповнюють тріаду «конфіденційність–цілісність–доступність» для вебресурсів (табл. 1.3)? Наведіть приклад конфлікту двох властивостей.
10. Порівняйте вебпорушника, мережевого порушника і порушника-гаджета. Задайте параметри моделі (1.3) для автентифікованого користувача інтернет-банкінгу.
11. За формулою (1.4) оцініть час сканування всього IPv4 зі швидкістю 10^5 проб/с. Чому для IPv6 така оцінка втрачає сенс?
12. Користуючись (1.6), визначте максимальний час виправлення, за якого ймовірність компрометації не перевищує 0,1, якщо $t_0 = 48$ год, $\lambda = 0{,}2$ год$^{-1}$, $p = 0{,}5$.
13. Назвіть нові категорії OWASP Top 10:2025 і чотири перші позиції CWE Top 25:2025. Чим відрізняється призначення цих рамок?
14. Які уроки для захисту державних вебресурсів випливають з атак січня–лютого 2022 р.? Оцініть за (1.8) ефект лише багатофакторної автентифікації адміністраторів у кейсі підрозділу 1.7.3.
15. Дослідницьке: запропонуйте методику вимірювання частки стороннього коду θ (1.1) за кількістю викликів чутливих API браузера, а не за розміром, і обґрунтуйте її використання для оцінки ризику ланцюга постачання клієнтського коду.
16. Дослідницьке: побудуйте модель порушника для порталу цифрових державних послуг в умовах воєнного стану, що враховує хактивістів, шахраїв і державного актора, і визначте, як змінюється пріори-

тетність властивостей табл. 1.3 порівняно з комерційним вебзастосунком.

РОЗДІЛ 2

Нормативно-правове та стандартизаційне забезпечення безпеки вебресурсів

Вебресурс одночасно перебуває в полі дії кількох нормативних режимів: законодавства про кібербезпеку, захист інформації і персональних даних, права ЄС, міжнародних стандартів, галузевих стандартів платіжних карток і відкритих рамок OWASP. Фахівцю потрібно вміти визначати, які з них застосовні до конкретного ресурсу, хто є суб'єктом зобов'язань і як юридичні вимоги перетворюються на перевірювані технічні заходи. Розділ спирається на модель об'єкта захисту з розділу 1, систематизує нормативне поле України та ЄС, стандарти і рамки OWASP, механізми оцінювання відповідності й завершується кейсом для державного вебпорталу та інтернет-магазину.

2.1 Структура нормативного поля

2.1.1 Рівні регулювання

Нормативне забезпечення безпеки вебресурсів доцільно подавати як ієрархію з шести рівнів, що різняться юридичною силою і деталізацією (рис. 2.1). *Закони* України, регламенти і директиви ЄС визначають об'єкти захисту, суб'єктів, обов'язки й відповідальність, але за принципом технологічної нейтральності майже не називають механізмів. *Підзаконні акти* (постанови КМУ, акти Держспецзв'язку, імплементаційні акти Єврокомісії) деталізують процедури. *Технічні нормативи* (НД ТЗІ, профілі безпеки, гармонізовані стандарти) конкретизують вимоги. *Міжнародні стандарти* (ISO/IEC, NIST) формують спільну мову управління безпекою. *Галузеві рамки*, насамперед OWASP, найдетальніше описують вебспецифічні вимоги. *Договірні вимоги* (угода з еквайрером, умови хмарного провайдера, технічне завдання) часто є каналом, яким добровільний стандарт стає обов'язковим.

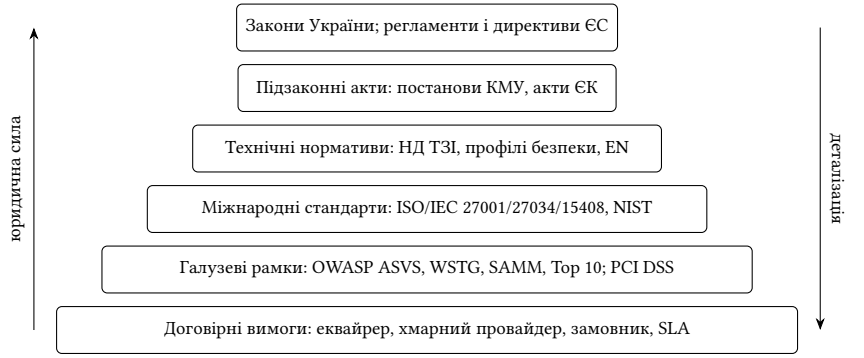


Рис. 2.1 — Рівні нормативного забезпечення безпеки вебресурсів

Норма закону про заходи, що відповідають «сучасному рівню техніки» (state of the art), тлумачиться через стандарти нижніх рівнів. Тому OWASP ASVS [102] і PCI DSS [110] фактично визначають, що вважати належними заходами в розумінні ст. 32 GDPR [112] чи ст. 21 NIS 2 [64], хоча ці акти на них не посилаються.

2.1.2 Суб'єкти зобов'язань

Виділяють п'ять категорій суб'єктів. **Власник вебресурсу** відповідає за захист інформації і персональних даних, повідомлення про інциденти й вибір постачальників. **Розробник або виробник програмного забезпечення** з Актом про кіберстійкість ЄС [115] отримує власні обов'язки щодо безпеки продукту протягом життєвого циклу. **Хостинг-, хмарний і CDN-провайдер** відповідає за свою частину моделі спільної відповідальності (розділ **??**). **Еквайрери й платіжні оператори** транслюють вимоги платіжних систем на торговців через договори. **Державні органи** встановлюють вимоги, наглядають і допомагають у реагуванні. Множину вимог, застосовних до об'єкта o, можна записати як

$$\mathcal{R}(o) = \bigcup_{k=1}^{K} \big\{\, r \in \mathcal{R}_k \;:\; \varphi_k(o) = 1 \;\wedge\; \psi_r(o) = 1 \,\big\}, \tag{2.1}$$

де $\mathcal{R}_k$ — вимоги k-го режиму (закону, стандарту, договору); $\varphi_k(o) \in \{0,1\}$ — предикат застосовності режиму («обробляє державні інформаційні ресурси», «пропонує товари особам у ЄС», «приймає картки»); $\psi_r(o)$ — предикат застосовності окремої вимоги (вимога 6.4.3 PCI DSS діє, лише коли платіжна сторінка формується в браузері клієнта). Режими перекриваються (багатофакторна автентифікація адміністраторів задовольняє кілька $\mathcal{R}_k$), тому доцільний єдиний реєстр вимог (підрозділ 2.6).

2.2 Законодавство України

2.2.1 Кібербезпека та реформа 2025 року

Закон «Про основні засади забезпечення кібербезпеки України» [27] відносить до об'єктів кіберзахисту системи органів влади, державні інформаційні ресурси та об'єкти критичної інформаційної інфраструктури, отже, і портали послуг, вебінтерфейси реєстрів та офіційні сайти. Атаки на державні ресурси 2022–2024 рр. (розділ 1) і курс на інтеграцію з ЄС зумовили реформу: Законом від 27.03.2025 № 4336-IX [20] змінено закони про кібербезпеку і про захист інформації в ІКС. Запроваджено національну систему реагування на кіберінциденти й обміну інформацією про загрози, посади фахівців з кібербезпеки в органах влади й на об'єктах критичної інфраструктури, оцінювання стану кіберзахисту з механізмом аудиту; розширено контрольні повноваження Держспецзв'язку. Концептуально головне — відмова від обов'язкової комплексної системи захисту інформації (КСЗІ) на користь ризик-орієнтованого підходу: власник впроваджує заходи базових і галузевих **профілів безпеки** і підтримує їх протягом життєвого циклу системи, що гармонізує підхід із NIS 2 [64] і практиками NIST [99].

2.2.2 Захист інформації: від КСЗІ до авторизації з безпеки

Закон «Про захист інформації в інформаційно-комунікаційних системах» [24] установлює вимоги до захисту державної інформації та інформації з обмеженим доступом. До 2025 р. її обробляли в системах із КСЗІ, підтвердженою атестатом за результатами державної експертизи; порядок створення КСЗІ визначав НД ТЗІ 3.7-003-05 [14], критерії оцінювання — НД ТЗІ 2.5-004-99 [13], загальні правила — постанова КМУ № 373 [19]. Для вебресурсів із безперервним розгортанням ця модель погано пасувала: атестат фіксував стан на дату експертизи.

Постановою КМУ від 18.06.2025 № 712 [6] затверджено Порядок авторизації з безпеки інформаційних, електронних комунікаційних, інформаційно-комунікаційних і технологічних систем та Порядок розроблення і затвердження профілів безпеки. **Авторизація з безпеки** — рішення про допуск системи до експлуатації на підставі документально підтвердженого впровадження заходів профілю. За рік нової процедури авторизовано 682 системи, з них 485 — у першому півріччі 2026 р. [38]. Ризиком переходу [2] є залежність якості від зрілості управління ризиками у власника. Для вебресурсу профіль задає мінімальний набір заходів, а конкретні механізми (WAF, політика безпеки вмісту, сканування залежностей) власник обирає й обґрунтовує; рамки OWASP (підрозділ 2.5) заповнюють проміжок між профілем і реалізацією.

2.2.3 Персональні дані, довірчі послуги, е-комерція, хмарні послуги

Закон «Про захист персональних даних» [25] поширюється на облікові записи, адреси, ідентифікатори пристроїв і cookie. Порівняно з GDPR [112] у ньому немає розгорнутих принципів захисту даних за задумом, загального обов'язку повідомлення про порушення у фіксований строк і співмірних санкцій. Закон «Про електронні довірчі послуги» [21] визначає режим кваліфікованого електронного підпису, важливий для автентифікації на державних порталах і юридичної значущості поданих документів (розділ ??). Закон «Про електронну комерцію» [22] регулює укладання електронних правочинів, що вимагає цілісності й доказовості процесу. Закон «Про хмарні послуги» [29] розмежовує відповідальність постачальника і споживача, установлює вимоги до постачальників, що обробляють державні ресурси, і їхній реєстр, відкривши можливість розміщувати державні вебресурси в хмарі.

2.2.4 Державні вебресурси, критична інфраструктура та інституції

Для вебсайтів органів виконавчої влади технічні вимоги, зокрема захист від несанкціонованого доступу й модифікації, встановлює Порядок функціонування вебсайтів [23]. Закон «Про критичну інфраструктуру» [26] встановлює категоризацію об'єктів, постанова КМУ № 518 [9] — загальні вимоги до кіберзахисту (ризики, доступ, моніторинг, реагування, неперервність). Вебресурс стає частиною об'єкта критичної інформаційної інфраструктури, якщо через нього надаються життєво важливі послуги. Інституційну систему [27, 28] формують Держспецзв'язку [4] (регулятор: профілі, авторизація, контроль), CERT-UA [47] (повідомлення про інциденти, координація реагування), Національний координаційний центр кібербезпеки при РНБО, кіберполіція і СБУ.

2.2.5 Юридична відповідальність

Розділ XVI Кримінального кодексу [10] встановлює відповідальність за несанкціоноване втручання в роботу систем (ст. 361 — дефейс, компрометація сервера), створення і збут шкідливих засобів (ст. 361-1 — вебшели), збут інформації з обмеженим доступом (ст. 361-2 — продаж викрадених баз), несанкціоновані дії особи, що має доступ (ст. 362 — інсайдер), порушення правил експлуатації чи захисту відповідальною особою, що спричинило шкоду (ст. 363), і перешкоджання роботі систем масовим розповсюдженням повідомлень (ст. 363-1, зокрема DDoS). Перевірка чужого ресурсу без дозволу може кваліфікуватися за ст. 361, тож тестування потребує договору або програми координованого розкриття (розділ ??). Зведення актів — у табл. 2.1.

Таблиця 2.1 — Основні акти законодавства України та їхнє значення для вебресурсів

Акт	Значення для вебресурсу
ЗУ № 2163-VIII зі змінами ЗУ № 4336-IX	об'єкти кіберзахисту; система реагування; фахівці; аудит
ЗУ № 80/94-ВР; КМУ № 373, № 712	захист державних ресурсів; профілі; авторизація замість атестата КСЗІ
ЗУ «Про критичну інфраструктуру»; КМУ № 518	ресурси, що надають життєво важливі послуги
ЗУ «Про захист персональних даних»	облікові записи, cookie, журнали
ЗУ «Про електронні довірчі послуги»	КЕП і електронна ідентифікація
ЗУ «Про електронну комерцію»	доказовість електронних договорів
ЗУ «Про хмарні послуги»	державні ресурси в хмарі; реєстр
Наказ № 327/225	вебсайти органів виконавчої влади
ККУ, ст. 361–363-1	кримінальна відповідальність

2.3 Право Європейського Союзу

2.3.1 Директива NIS 2

Директива (ЄС) 2022/2555 [64] (транспонування до 17.10.2024) поширюється на суттєві й важливі суб'єкти. Для вебсфери ключові сектор цифрової інфраструктури (DNS, реєстри TLD, хмарні обчислення, центри обробки даних, CDN, довірчі послуги) і цифрові постачальники (онлайнові майданчики, пошукові системи, соціальні мережі). Правило розміру (середні й великі підприємства) не діє для DNS, реєстрів TLD і кваліфікованих надавачів довірчих послуг. Регламент 2024/2690 [52] деталізує для них технічні вимоги. Ст. 21 вимагає «відповідних і пропорційних» заходів, зокрема безпеки ланцюга постачання, розроблення, оброблення вразливостей, криптографії і багатофакторної автентифікації; ст. 20 встановлює відповідальність органів управління, ст. 23 — багатоетапне повідомлення про інциденти. Інтернет-магазин власних товарів не належить до секторів Директиви, а майданчик для сторонніх продавців — належить: предикат φ_k у (2.1) визначає бізнес-модель, а не технологія.

2.3.2 Акт про кіберстійкість

Регламент (ЄС) 2024/2847 (CRA) [115] запровадив горизонтальні вимоги до **продуктів із цифровими елементами**, включно з *рішеннями віддаленої обробки даних*, без яких продукт не виконує функцій. Він охоплює тиражоване вебпрограмне забезпечення, що постачається в межах комерційної

діяльності (системи керування вмістом, платформи е-комерції, браузери, менеджери паролів, WAF, бібліотеки), і невід'ємний від продукту хмарний бекенд (наприклад, сервер мобільного застосунку). «Чистий» SaaS регулюється NIS 2; некомерційне вільне ПЗ виведено з-під дії, для стюардів відкритого коду діє полегшений режим [48].

Суттєві вимоги додатка I стосуються властивостей продукту (відсутність відомих експлуатованих вразливостей, безпечна конфігурація за замовчуванням, керування доступом, мінімізація поверхні атаки, журналювання, безпечне оновлення) та оброблення вразливостей (SBOM, розділ **??**; безкоштовні оновлення безпеки; тестування; координоване розкриття) протягом періоду підтримки, як правило не менше п'яти років. Важливі продукти класів I і II та критичні оцінюються суворіше; їх описує регламент 2025/2392 [54]: до класу I належать браузери, менеджери паролів, системи керування ідентичністю, до класу II — міжмережеві екрани і системи виявлення вторгнень. CRA чинний з 10.12.2024; положення про органи оцінювання діють з 11.06.2026; повідомлення про активно експлуатовані вразливості й серйозні інциденти — з 11.09.2026 (раннє попередження за 24 год, повідомлення за 72 год, остаточний звіт до 14 днів після виправлення); решта вимог і маркування CE — з 11.12.2027 (рис. 2.2).

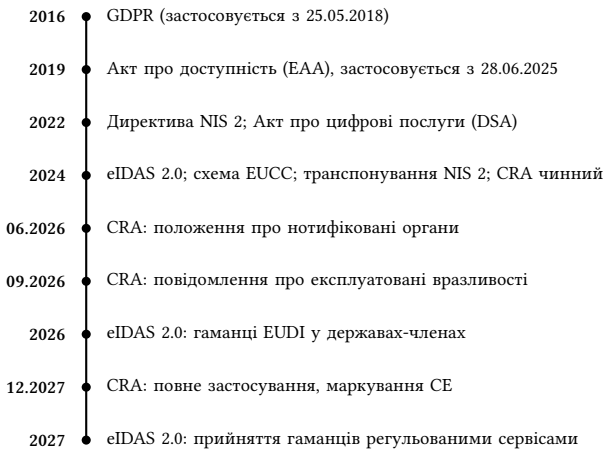


Рис. 2.2 — Хронологія актів ЄС, що визначають вимоги до безпеки вебресурсів

2.3.3 Загальний регламент захисту даних

За ст. 3(2) GDPR [112] застосовується до контролера поза ЄС, що пропонує товари чи послуги особам в ЄС або відстежує їхню поведінку (а відстеження через cookie — типова функція вебресурсу); такий контролер призначає

представника в ЄС (ст. 27). Для безпеки визначальні ст. 25 (**захист даних за задумом і за замовчуванням**: мінімізація, псевдонімізація, приватні налаштування), ст. 32 (заходи з урахуванням сучасного рівня техніки: шифрування, конфіденційність, цілісність, доступність, стійкість, відновлення, регулярне тестування) і ст. 33 (повідомлення наглядового органу протягом 72 год), доповнена ст. 34 щодо повідомлення суб'єктів. Вимірювання банерів згоди виявили масову реєстрацію згоди до її надання [93]: відповідність слід перевіряти технічно, а не за документацією.

2.3.4 eIDAS 2.0, DSA та EAA

Регламент 2024/1183 (eIDAS 2.0) [114] запроваджує гаманець цифрової ідентичності (EUDI Wallet), який регульовані й великі онлайнові сервіси зі строгою автентифікацією мають приймати, — новий механізм автентифікації з вибірковим розкриттям атрибутів (розділ **??**); ст. 45 вимагає від браузерів визнавати кваліфіковані сертифікати вебсайтів (QWAC) (розділ **??**). Акт про цифрові послуги (DSA) [113] з 17.02.2024 регулює посередницькі послуги і платформи: повідомлення про незаконний вміст, прозорість, простежуваність продавців. Акт про доступність (EAA) [63] з 28.06.2025 охоплює, зокрема, е-комерцію; він не безпековий, але вимагає доступності механізмів захисту (CAPTCHA, багатофакторна автентифікація, тайм-аути сеансу) для людей з інвалідністю (розділ **??**).

2.3.5 Санкції та строки повідомлення

Акти ЄС задають граничний штраф як більшу з двох величин — фіксованої суми і частки світового річного обороту T:

$$F_{\max} = \max\bigl(F_{\text{фікс}},\ \alpha\, T\bigr), \tag{2.2}$$

де для GDPR (ст. 83(5)) $F_{\text{фікс}} = 20$ млн євро, $\alpha = 4\,\%$; для суттєвих суб'єктів NIS 2 — 10 млн євро і 2 %, для важливих — 7 млн євро і 1,4 %; для CRA (суттєві вимоги) — 15 млн євро і 2,5 %. Поріг $T^{*} = F_{\text{фікс}}/\alpha$, нижче від якого визначальна фіксована сума, становить 500 млн євро для GDPR і NIS 2 та 600 млн євро для CRA. Для $T = 2$ млрд євро граничний штраф за GDPR — $\max(20;\,80) = 80$ млн євро, за CRA — $\max(15;\,50) = 50$ млн євро; для $T = 40$ млн євро граничні суми (20 і 15 млн) перевищують половину обороту, тобто для малого бізнесу санкції непропорційно суворі.

Один інцидент (компрометація через вразливість власного продукту з витоком персональних даних) може запустити кілька паралельних процедур. Якщо t_0 — момент обізнаності, $d_{k,j}$ — строк j-го повідомлення в режимі k, то

$$t_{k,j} - t_0 \le d_{k,j} \quad \forall k, j; \qquad d^{*} = \min_{k,j} d_{k,j}, \tag{2.3}$$

де для NIS 2 і CRA перше повідомлення — 24 год, друге — 72 год, для GDPR — 72 год. Строк $d^* = 24$ год визначає вимогу до виявлення і класифікації (розділ ??): якщо на узгодження рішення відводиться 6 год, середній час виявлення й класифікації має бути меншим за 18 год із запасом на варіабельність. Порівняння актів — у табл. 2.2.

Таблиця 2.2 — Акти ЄС, що впливають на безпеку вебресурсів

Акт	Адресат	Ключові вимоги	Санкції
NIS 2	суттєві й важливі суб'єкти; цифрова інфраструктура, майданчики	ст. 21 заходи; ст. 23 повідомлення 24/72 год	10 млн/2 %; 7 млн/1,4 %
CRA	виробники продуктів із цифровими елементами	додаток I; SBOM; повідомлення з 11.09.2026	15 млн/2,5 %
GDPR	контролери й обробники, зокрема поза ЄС	ст. 25, 32; ст. 33 — 72 год	20 млн/4 %
eIDAS 2.0	держави-члени, довірчі сторони	гаманець EUDI; QWAC	національні
DSA	посередницькі послуги, платформи	повідомлення й дії; простежуваність	до 6 %
EAA	постачальники продуктів і послуг	доступність, у т.ч. механізмів захисту	національні

2.4 Міжнародні стандарти

2.4.1 ISO/IEC 27001 і 27002

ISO/IEC 27001:2022 і 27002:2022 (ДСТУ EN ISO/IEC 27001:2023 [7] і 27002:2023 [8]) задають вимоги до системи управління інформаційною безпекою (СУІБ) і 93 заходи за темами: організаційні (37), людські (8), фізичні (14), технологічні (34) [11]. Для вебресурсів ключові заходи безпечного розроблення: 8.25 «Безпечний життєвий цикл розроблення», 8.26 «Вимоги до безпеки застосунків», 8.27 «Архітектура захищених систем і принципи інженерії», 8.28 «Безпечне кодування» (новий), 8.29 «Тестування безпеки під час розроблення та приймання»; суміжний новий захід — 8.23 «Вебфільтрація» (контроль доступу персоналу до зовнішніх сайтів). ISO/IEC 27001 сертифікує *систему управління*, а не захищеність застосунку: сертифікована організація може експлуатувати вразливий ресурс, якщо ризик формально прийнято.

2.4.2 ISO/IEC 27034 і ISO/IEC 15408

ISO/IEC 27034 [84] переносить логіку СУІБ на рівень застосунку: **організаційна нормативна база** (ONF) містить політики і заходи; **заходи безпе-**

ки застосунку (ASC) мають опис цілі, реалізації й верифікації; **цільовий рівень довіри** задає набір ASC для конкретного застосунку. Рівні довіри близькі до L1–L3 ASVS, тому ASVS часто використовують як готовий каталог ASC. Загальні критерії (ISO/IEC 15408) [82] оцінюють продукти на відповідність профілю захисту з рівнями гарантій EAL1–EAL7; для вебзастосунків це дорого, але релевантно для WAF і, через схему EUCC [53], для продуктів, критичних за CRA.

2.4.3 PCI DSS 4.0.1

PCI DSS [110] — договірна вимога для всіх, хто зберігає, обробляє чи передає дані карток. З 31.03.2025 обов'язкові вимоги, що прямо стосуються вебресурсів. Вимога 6.4.1 зобов'язує захищати загальнодоступні вебзастосунки від відомих атак, 6.4.2 — застосовувати автоматизоване рішення, що виявляє і блокує вебатаки (фактично WAF, розділ **??**). Вимога 6.4.3: кожен скрипт платіжної сторінки, що виконується в браузері, має бути авторизований, мати гарантовану цілісність і обґрунтування в переліку. Вимога 11.6.1: механізм виявлення несанкціонованих змін заголовків HTTP і вмісту платіжних сторінок у вигляді, отриманому браузером, щонайменше щотижня або з періодичністю за цільовим аналізом ризиків. Це відповідь на скимери Magecart; засоби реалізації розглянуто в розділі **??**. У 2025 р. PCI SSC вилучила 6.4.3 і 11.6.1 з анкети SAQ A (вбудована форма чи перенаправлення), але додала критерій прийнятності: торговець підтверджує, що його сайт не вразливий до атак скриптами [80]. Відповідальність не зникла, а перейшла в декларацію.

2.4.4 NIST CSF 2.0 і SSDF

NIST CSF 2.0 [100] організує результати за шістьма функціями — «Керувати» (нова), «Ідентифікувати», «Захищати», «Виявляти», «Реагувати», «Відновлювати» — у 22 категоріях і 106 підкатегоріях; поточний і цільовий профілі візуалізують розрив. Інструмент багатостандартної оцінки кіберзрілості з CSF 2.0 як базовою шкалою і відображенням на ISO/IEC 27001:2022, COBIT 2019 і CIS Controls v8 запропоновано в [33]. SSDF (NIST SP 800-218) [125] групує практики безпечного розроблення в чотири групи: підготовка організації (PO), захист ПЗ (PS), створення захищеного ПЗ (PW), реагування на вразливості (RV), — і значною мірою перекривається з вимогами CRA щодо оброблення вразливостей.

2.4.5 Відповідність між стандартами

Практичним інструментом є таблиця відповідності (crosswalk). Якщо $M \subseteq \mathcal{R}_A \times \mathcal{R}_B$ — відношення відповідності вимог документів A і B, то покриття

$$\operatorname{cov}(A \to B) = \frac{\left|\{\, b \in \mathcal{R}_B : \exists\, a \in \mathcal{R}_A,\ (a,b) \in M \,\}\right|}{|\mathcal{R}_B|}. \tag{2.4}$$

Покриття (2.4) несиметричне і завищує еквівалентність, бо M здебільшого фіксує тематичну, а не змістову відповідність: захід 8.28 «відповідає» десяткам вимог ASVS, але загальна політика кодування не гарантує виконання жодної з них. Тому слід розрізняти повну, часткову і тематичну відповідність (табл. 2.3).

Таблиця 2.3 — Відповідність вимог стандартів і рамок для вебресурсів

Тема	ISO/IEC 27002	PCI DSS	NIST	ASVS 5.0
Безпечний ЖЦ	8.25, 8.27	6.1, 6.2	SSDF PO, PW	V15
Вимоги до застосунку	8.26	6.2.4	SSDF PW.1	усі розділи
Безпечне кодування	8.28	6.2.4	SSDF PW.5	V1, V2, V5
Тестування	8.29	6.2.3, 11.3, 11.4	SSDF PW.7, PW.8	(метод — WSTG)
Вебатаки ззовні	8.20, 8.26	6.4.1, 6.4.2	CSF PR.PS, DE.CM	V4, V13
Скрипти в браузері	8.28	6.4.3, 11.6.1	CSF PR.DS	V3
Автентифікація	5.17, 8.5	8.3, 8.4	SP 800-63	V6, V7, V10
Журналювання	8.15, 8.16	10.2	CSF DE.CM	V16
Вразливості	8.8	6.3	SSDF RV	V15

2.5 Галузеві рамки OWASP

2.5.1 Стандарт верифікації ASVS 5.0

OWASP ASVS 5.0.0 [102] (травень 2025 р.) — найдетальніший відкритий каталог вимог до вебзастосунків: близько 350 вимог у 17 розділах: V1 — кодування і санітизація; V2 — валідація і бізнес-логіка; V3 — безпека клієнтської частини; V4 — API і вебсервіси; V5 — обробка файлів; V6 — автентифікація; V7 — сеанси; V8 — авторизація; V9 — самодостатні токени; V10 — OAuth і OIDC; V11 — криптографія; V12 — захищені комунікації; V13 — конфігурація; V14 — захист даних; V15 — безпечне кодування й архітектура; V16 — журналювання та обробка помилок; V17 — WebRTC. Вимоги сформульовано як перевірювані твердження про властивості застосунку. Рівні кумулятивні: L1 — мінімальний для всіх застосунків; L2 — для застосунків із чутливими даними чи транзакціями; L3 — для найкритичніших (крити-

чна інфраструктура, медицина, великі фінансові операції). ASVS дає змогу коректно сформулювати технічне завдання («ASVS 5.0 рівня L2, крім V17»).

2.5.2 WSTG, SAMM, Top 10 і API Security Top 10

WSTG [109] описує методику тестування за категоріями від збирання інформації до бізнес-логіки, клієнтської частини та API: ASVS відповідає на питання «*що* має бути істинним», WSTG — «*як* це перевірити» (розділ ??). SAMM [105] оцінює організацію: п'ять бізнес-функцій (управління, проєктування, реалізація, верифікація, операції) по три практики і три рівні зрілості (розділ ??). OWASP Top 10:2025 [108] — документ обізнаності, а не стандарт: категорії навмисно широкі, тож «відповідність Top 10» у технічному завданні не має перевірюваного змісту. API Security Top 10:2023 [101] виконує ту саму роль для API (розділ ??).

Співвідношення документів подано на рис. 2.3: на рівні організації ISO/IEC 27001 і CSF 2.0 задають цілі та управління ризиками, SAMM і SSDF — процеси розроблення; на рівні застосунку ISO/IEC 27034 задає рівень довіри, ASVS — вимоги, WSTG — методику верифікації; Top 10 слугує для пріоритизації й навчання. Нормативні акти і PCI DSS посилаються на результати, а не на документи OWASP, проте настанови до вимоги 6.2.4 PCI DSS серед прикладів галузевих джерел наводять і OWASP.

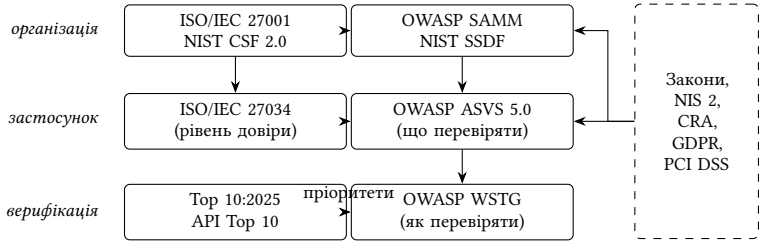


Рис. 2.3 — Співвідношення стандартів управління і рамок OWASP

2.6 Оцінювання відповідності та сертифікація

2.6.1 Національна система та міжнародна сертифікація

Для державних систем основним механізмом стала авторизація з безпеки [6]: власник категоризує систему, обирає базовий і галузевий профілі, впроваджує й оцінює заходи та подає документи до Держспецзв'язку, яка ухвалює рішення протягом 10 днів [38]; доповнює її аудит стану кіберзахисту [20]. Для вебресурсу з частими релізами це вимагає безперервного моніторингу й автоматизованих перевірок у конвеєрі CI/CD.

Сертифікацію СУІБ за ISO/IEC 27001 проводять за трирічним циклом із щорічними наглядовими аудитами; перевіряючи постачальника, слід з'ясувати, чи входить потрібний вебсервіс до області сертифікації. Стандарти аудиту ISO 19011 і ISO/IEC 27007 порівняно з погляду автоматизації в [32]. Оцінювання за PCI DSS залежить від рівня торговця: найбільші подають звіт про відповідність (ROC) кваліфікованого оцінювача (QSA), інші — анкету самооцінювання: SAQ A (вбудована форма чи перенаправлення), SAQ A-EP (сторінка торговця впливає на формування платіжної форми), SAQ D (інші випадки); зовнішні ресурси щокварталу сканує затверджений постачальник (ASV). Для продуктів схема EUCC [53] може підтверджувати відповідність CRA; для класу I можливе самооцінювання за гармонізованими стандартами, для класу II обов'язкове оцінювання третьою стороною [115].

2.6.2 Кількісне оцінювання рівня відповідності

Нехай $\mathcal{R} = \{r_1, \dots, r_N\}$ — застосовні вимоги (2.1), $w_i > 0$ — вага (3 — обов'язкова вимога закону чи профілю, 2 — договору чи стандарту, 1 — рекомендація), $c_i \in \{0;\ 0{,}5;\ 1\}$ — ступінь виконання. **Зважений індекс розриву відповідності**:

$$G = 1 - \frac{\sum_{i=1}^{N} w_i\, c_i}{\sum_{i=1}^{N} w_i}, \qquad G \in [0; 1]. \tag{2.5}$$

Індекс (2.5) компенсаторний: виконання багатьох другорядних вимог маскує невиконання критичної. Тому для обов'язкових вимог $\mathcal{R}_{\text{обов}}$ вводять блокувальну умову, а пріоритет решти визначають за питомим зменшенням індексу на одиницю витрат C_i:

$$\min_{i:\, r_i \in \mathcal{R}_{\text{обов}}} c_i = 1, \tag{2.6}$$

$$\pi_i = \frac{\Delta G_i}{C_i} = \frac{w_i\,(1 - c_i)}{C_i \sum_{j=1}^{N} w_j}. \tag{2.7}$$

Доки (2.6) не виконано, обов'язкові вимоги мають абсолютний пріоритет незалежно від π_i.

Числовий приклад. Реєстр містить 50 вимог: 15 обов'язкових ($w = 3$), 25 стандартних ($w = 2$), 10 рекомендацій ($w = 1$); $\sum w_i = 105$. Обов'язкові: 13 — повністю, 2 — частково; стандартні: 18 — повністю, 5 — частково, 2 — не виконано; рекомендації: 4 — повністю, 2 — частково, 4 — не виконано. Зважена сума $3(13 + 1) + 2(18 + 2{,}5) + 1(4 + 1) = 88$, звідки $G = 1 - 88/105 \approx 0{,}162$; умова (2.6) не виконана. Доведення двох обов'язкових вимог зменшує G на $3/105 \approx 0{,}029$, до $0{,}133$. Далі порівняймо дві невиконані стандартні вимоги: моніторинг платіжних сторінок (11.6.1, $C = 40$ людино-год) і усунення

вади заголовків ($C = 4$ людино-год). За однакового $\Delta G = 2/105$ значення π відрізняються вдесятеро ($4{,}8 \cdot 10^{-4}$ проти $4{,}8 \cdot 10^{-3}$), тож друга виконується першою. Модель (2.7) не враховує залежностей між вимогами і їхньої ризикової цінності (11.6.1 знижує ризик реального скимінгу), тому її доповнюють аналізом ризиків (розділ 4).

2.7 Порівняльний аналіз вимог України та ЄС

Реформа 2025 р. наблизила національну модель до європейської: обидві ґрунтуються на ризик-орієнтованому підході, відповідальності суб'єкта і безперервному підтриманні заходів (табл. 2.4).

Таблиця 2.4 — Порівняння підходів України та ЄС до регулювання безпеки вебресурсів

Аспект	Україна	ЄС
Рамкові акти	ЗУ № 2163-VIII, № 80/94-ВР зі змінами ЗУ № 4336-IX	NIS 2, CRA, GDPR
Сфера дії	державні ресурси, КІ, об'єкти кіберзахисту	суттєві й важливі суб'єкти, у т.ч. приватні цифрові
Підтвердження захищеності	авторизація з безпеки за профілями; раніше атестат КСЗІ	самооцінювання, аудит, сертифікація; нагляд
Регулювання продуктів	немає горизонтального акта	CRA (з 11.12.2027), EUCC
Повідомлення про інциденти	CERT-UA; національна система реагування	24/72 год, 1 міс. (NIS 2); 72 год (GDPR)
Персональні дані	ЗУ № 2297-VI; без строкового повідомлення	GDPR: ст. 25, 32–34; до 4 % обороту
Відповідальність керівництва	посадові особи, ст. 363 ККУ	ст. 20 NIS 2: персональна
Електронна ідентичність	КЕП, Дія.Підпис	eIDAS 2.0, гаманець EUDI

Напрями гармонізації: поширення вимог на приватних цифрових, хмарних, DNS- і CDN-провайдерів за NIS 2; вимоги до безпеки програмних продуктів за зразком CRA, які для українських розробників, що працюють на ринок ЄС, однаково стають фактичним стандартом; строкове повідомлення про порушення безпеки персональних даних; узгодження профілів безпеки з ASVS і ISO/IEC 27002, щоб одна міра закривала кілька режимів.

2.8 Кейс: визначення застосовних вимог

2.8.1 Державний вебпортал електронних послуг

Портал приймає заяви громадян: автентифікація через КЕП, доступ до кількох реєстрів через API, розміщення в хмарі постачальника з реєстру. За моделлю (2.1) застосовні закони про кібербезпеку й захист інформації [27, 24] зі змінами [20] (авторизація з безпеки за базовим і галузевим профіля-

ми [6], посадові особи з кібербезпеки, взаємодія з CERT-UA); у разі категоризації як об'єкта критичної інформаційної інфраструктури — постанова № 518 [9]; закони про персональні дані [25], довірчі [21] і хмарні послуги [29]; вимоги до сайтів органів влади [23]. Технічне наповнення профілю доцільно задати через ASVS: L2 для всіх розділів і L3 для V6–V10 (автентифікація, сеанси, авторизація, токени, федерація), бо вади доступу до реєстрових даних зачіпають мільйони громадян; інтеграції з реєстрами оцінюються за API Security Top 10, процеси розробника — за SSDF і SAMM.

2.8.2 Український інтернет-магазин із продажем у ЄС

Магазин (оборот 12 млн євро, 80 працівників) продає власні товари в Україні та ЄС, приймає картки й має мобільний застосунок. Застосовні закони про персональні дані й е-комерцію [25, 22]; GDPR через ст. 3(2) [112] (представник у ЄС, ст. 25, 32, процедура ст. 33); PCI DSS через договір з еквайрером [110]; EAA [63] як суміжна вимога. NIS 2 і DSA не застосовні, доки магазин не стане майданчиком для сторонніх продавців. Сайт не є продуктом за CRA, але мобільний застосунок, що розповсюджується в ЄС у межах комерційної діяльності, разом із бекендом може кваліфікуватися як продукт із цифровими елементами, тож до 11.12.2027 магазин має підготуватися до обов'язків виробника [115]. Ключове рішення — спосіб прийому карток: власна форма означає SAQ A-EP або D з вимогами 6.4.3 і 11.6.1; вбудована форма провайдера — SAQ A з обґрунтованим підтвердженням стійкості до атак скриптами [80], що на практиці потребує тих самих механізмів (сувора політика безпеки вмісту, моніторинг сторінки). Оскільки $T = 12$ млн євро $< T^*$, граничний штраф за GDPR (2.2) — 20 млн євро, більше за річний оборот.

Для обох ресурсів далі формують єдиний реєстр вимог, оцінюють стан за (2.5) з перевіркою (2.6) і планують усунення розривів за (2.7). Технології обох ресурсів майже однакові, а вимоги різні: їх визначають статус власника, ринок і бізнес-модель.

Висновки до розділу

Нормативне забезпечення безпеки вебресурсів багаторівневе: закони встановлюють обов'язки й санкції, підзаконні акти і профілі — процедури, міжнародні стандарти — мову управління, а рамки OWASP і PCI DSS — найдетальніші перевірювані вимоги, які через договори і тлумачення «сучасного рівня техніки» фактично стають обов'язковими. В Україні Закон № 4336-IX і постанова КМУ № 712 замінили модель атестата КСЗІ ризик-орієнтованою авторизацією з безпеки за профілями, наблизивши національну систему до NIS 2, але без регулювання приватного цифрового сектору і продуктів. У ЄС NIS 2, GDPR і CRA (повідомлення з 11.09.2026, повне застосування з

11.12.2027) створюють для українських розробників і ресурсів, що працюють на ринок ЄС, вимоги зі строками повідомлення 24/72 год і штрафами (2.2), що для малого бізнесу перевищують річний оборот. Для практики корисні модель застосовності (2.1), блокувальні вимоги плюс індекс (2.5) і пріоритизація (2.7).

Питання для самоперевірки

1. Назвіть шість рівнів нормативного забезпечення (рис. 2.1) і поясніть, як галузеві рамки набувають обов'язковості.
2. Які п'ять категорій суб'єктів зобов'язань виділяють для вебресурсів? Наведіть приклад організації, що належить до трьох категорій.
3. Поясніть зміст предикатів φ_k і ψ_r у моделі (2.1) на прикладі PCI DSS.
4. Які зміни запровадив Закон № 4336-IX? Чим авторизація з безпеки відрізняється від атестата КСЗІ?
5. Які статті Кримінального кодексу застосовні до дефейсу, DDoS-атаки і продажу викраденої бази? Яке значення має ст. 363 для власника ресурсу?
6. За яких умов вебресурс підпадає під NIS 2? Чому інтернет-магазин власних товарів не є її суб'єктом?
7. Яке вебпрограмне забезпечення охоплює CRA і чим він відрізняється за сферою дії від NIS 2? Назвіть ключові дати.
8. Обчисліть за (2.2) граничні штрафи за GDPR і CRA для оборотів 100 млн і 1 млрд євро. Що означає поріг T^*?
9. За (2.3) визначте допустимий середній час виявлення інциденту, якщо на узгодження рішення відводиться 8 год, а коефіцієнт запасу дорівнює 1,5.
10. Які заходи ISO/IEC 27002:2022 стосуються безпечного розроблення? Чому сертифікат ISO/IEC 27001 не гарантує захищеності вебзастосунку?
11. Сформулюйте вимоги 6.4.3 і 11.6.1 PCI DSS і поясніть, як зміна SAQ A 2025 р. вплинула на відповідальність торговця.
12. Поясніть за рис. 2.3 і табл. 2.3 співвідношення ASVS, WSTG, SAMM і Top 10. Чому «відповідність Top 10» — некоректна вимога?
13. Обчисліть (2.5) для прикладу з підрозділу 2.6 після виконання всіх обов'язкових і двох невиконаних стандартних вимог. Чи виконується (2.6)?
14. Дослідницьке: запропонуйте некомпенсаторну модель агрегування відповідності, що враховує залежності між вимогами і їхню ризикову цінність, та порівняйте її з (2.5) і (2.7).

15. Дослідницьке: розробіть методику автоматизованого відображення вимог базового профілю безпеки на ASVS 5.0 і ISO/IEC 27002 з оцінкою покриття (2.4) і розрізненням повної, часткової та тематичної відповідності.

РОЗДІЛ 3

Математичні та кількісні основи оцінювання захищеності вебресурсів

Розділ 1 увів модель порушника (1.3), оцінку кількості спроб (1.5), модель гонки між експлуатацією і виправленням (1.6) та композицію ланцюгів атак (1.8), а нормативні вимоги (розділ 2) здебільшого сформульовано якісно: «достатня стійкість», «обмеження частоти», «своєчасне усунення». Розділ систематизує апарат, що перетворює такі вимоги на числа: теорію вгадування, моделі підбору облікових даних, теорію статистичного виявлення, теорію масового обслуговування, марковські й байєсові моделі атак та оцінки CVSS, EPSS, KEV і SSVC, і завершується розгорнутим числовим прикладом. Самі механізми захисту розглянуто в розділах ??, ??, ?? і ??.

3.1 Постановка задачі кількісного оцінювання захищеності

3.1.1 Вебресурс як об'єкт кількісного оцінювання

Розглянемо вебресурс як систему $\mathcal{W} = \langle \mathcal{E}, \mathcal{S}, \mathcal{C}, \mathcal{M}, \mathcal{V} \rangle$, де $\mathcal{E}$ — вхідні точки (сторінки, кінцеві точки API, форми входу); $\mathcal{S}$ — секрети й ідентифікатори (паролі, токени сеансу, ключі API, ідентифікатори об'єктів); $\mathcal{C}$ — обчислювальні ресурси (робочі процеси, з'єднання, пам'ять); $\mathcal{M}$ — механізми захисту (гешування паролів, обмеження частоти, MFA, WAF, журналювання); $\mathcal{V}$ — відомі вразливості компонентів. З моделі порушника (1.3) для кількісних оцінок найважливіші ресурси: кількість адрес ботнету, швидкість запитів, обчислювальна потужність і бюджет. Захищеність характеризується вектором показників

$$\mathbf{q} = \big(H_\infty,\ P_{\text{онл}}(T),\ C_{\text{офл}},\ \text{PPV},\ \lambda_a^*,\ P_{\text{ціль}},\ \text{Cov}\big),$$

кожна компонента якого відповідає окремій властивості й моделі (табл. 3.1). Задача *оцінювання* — обчислити $\mathbf{q}$ для заданих $\mathcal{W}$ і порушника, задача *синтезу* — обрати параметри (довжину токена, вартість гешування, ліміт спроб, поріг тривоги, порядок виправлень), що забезпечують цільові значення. Майже всі показники визначаються *економікою порушника*: вартістю запиту, спроби вгадування чи години роботи графічного процесора.

Таблиця 3.1 — Показники кількісного оцінювання захищеності вебресурсу

Властивість	Показник	Модель і вихідні дані	Підр.
Стійкість секретів	H_∞, $\tilde{\lambda}_\beta$, імовірність колізії	Розподіл секретів, кількість ідентифікаторів	3.2
Автентифікація (онлайн)	$P_{\text{онл}}(T)$, кількість зламаних записів	Крива вгадування, ліміт спроб, повторне використання паролів	3.3
Автентифікація (офлайн)	$C_{\text{офл}}$, GPU-год, долари	Функція гешування, параметри, обладнання	3.3
Виявлення	P_D, P_{FA}, PPV	Розподіли ознак, базова частота	3.4
Доступність	ρ, W, λ_a^*	Інтенсивності, час обслуговування, кількість процесів	3.5
Ланцюги атак	$P_{\text{ціль}}$, кількість кроків	Атаковий граф, імовірності переходів	3.6
Вразливості	Покриття, ефективність	CVSS, EPSS, KEV, бюджет	3.7

3.1.2 Вимоги до моделей

Модель, придатна для обґрунтування рішень, має бути *явною* щодо припущень (незалежність спроб, пуассонівський потік, стаціонарність розподілу паролів), *спостережуваною* (параметри оцінюються з журналів або відкритих даних), *консервативною* (за невизначеності обирають значення, вигідні порушникові), супроводжуватися *аналізом чутливості* і давати результати в *порівнюваних* одиницях (імовірність, години, долари). Такі моделі є джерелом оцінок імовірності для управління ризиками (розділ 4).

3.2 Ентропія та стійкість секретів

3.2.1 Ентропія Шеннона, мін-ентропія і ентропія вгадування

Нехай секрет X набуває значень $x_1, \dots, x_N$ з імовірностями $p_1 \geq p_2 \geq \cdots \geq p_N$. Три класичні міри невизначеності:

$$H(X) = -\sum_{i=1}^{N} p_i \log_2 p_i, \qquad H_\infty(X) = -\log_2 p_1, \qquad G(X) = \sum_{i=1}^{N} i\, p_i, \tag{3.1}$$

де H — ентропія Шеннона; H_∞ — мін-ентропія, що визначає успіх першої найкращої спроби; G — ентропія вгадування, тобто середня кількість спроб порушника, який перебирає значення в порядку спадання ймовірності. Для рівномірного розподілу $H = H_\infty = \log_2 N$, $G = (N+1)/2$; для секретів, обраних людиною, ці міри розходяться на порядки. Мессі [92] показав, що для $H(X) \geq 2$ біт

$$G(X) \;\geq\; 2^{H(X)-2} + 1, \tag{3.2}$$

але оцінки зверху не існує: розподіл з довгим «хвостом» може мати високу H і дуже малу H_∞. Тому ентропія Шеннона *не є мірою стійкості* паролів проти вгадування.

Боно [46] запропонував часткові міри: *β-успішність* λ_β — частку записів, що зламуються за β найкращих спроб на кожен, і *α-роботу* — середню кількість спроб для зламу частки α записів. У бітах

$$\lambda_\beta = \sum_{i=1}^{\beta} p_i, \qquad \tilde{\lambda}_\beta = \log_2 \frac{\beta}{\lambda_\beta}, \tag{3.3}$$

де $\tilde{\lambda}_\beta$ — довжина *випадкового* секрету, еквівалентного розподілу для порушника з β спробами; $\tilde{\lambda}_1 = H_\infty$. Метрика λ_β описує онлайнову атаку з лімітом спроб, α-робота — офлайнову.

3.2.2 Емпіричні дані про паролі та закон Ципфа

Боно проаналізував анонімізовані гістограми паролів $69\,301\,337$ користувачів Yahoo! і отримав $H_\infty = 6{,}5$ біт (найпоширеніший пароль обрали 1,08 % користувачів), $\tilde{\lambda}_{10} = 9{,}1$ біт, тобто $\lambda_{10} \approx 1{,}8\,\%$, а α-робота для $\alpha = 0{,}25$ і $0{,}5$ становила 17,6 і 21,6 біт [46]. Отже, проти онлайнової атаки паролі еквівалентні випадковим секретам менше 10 біт, проти офлайнової — близько 20. Ван і співавтори на кількох великих корпусах витоків показали, що розподіл паролів добре описується законом Ципфа [131]:

$$p_i = \frac{i^{-s}}{\sum_{j=1}^{N} j^{-s}}, \qquad 0 < s < 1, \tag{3.4}$$

де i — ранг пароля за частотою, s — показник, N — кількість різних паролів. Для ілюстрації візьмемо $s = 0{,}8$, $N = 10^7$. Розрахунок дає $H \approx 20{,}5$ біт, $H_\infty \approx 6{,}9$ біт, $G \approx 1{,}7 \cdot 10^6$ (узгоджено з (3.2): $2^{18{,}5} + 1 \approx 3{,}6 \cdot 10^5$), а $\lambda_{10} = 2{,}9\,\%$, $\lambda_{100} = 6{,}7\,\%$, $\lambda_{1000} = 12{,}8\,\%$, $\lambda_{10^6} = 61{,}7\,\%$, що близько до емпіричних даних. Правила складу пароля майже не змінюють верхівку розподілу, тоді як *заборона найпоширеніших паролів* безпосередньо зменшує λ_β; тому NIST SP 800-63B-4 вимагає перевірки за списками скомпрометованих і поширених паролів замість правил складу [127], а українські дослідники пов'язують рівні вимог до ентропії (від 40–64 біт для відкритих даних до 112–128 біт для критичної інфраструктури) з використанням менеджерів паролів [34].

3.2.3 Токени сеансу та парадокс днів народження

Серверні секрети можуть бути рівномірними. OWASP вимагає для ідентифікатора сеансу не менше 64 біт ентропії від криптографічно стійкого генератора [103]. Нехай порушник надсилає r спроб за секунду, активні S се-

ансів, ідентифікатор має b випадкових біт. Імовірність угадати хоча б один чинний ідентифікатор за час T і очікуваний час до успіху

$$P_{\text{сеанс}}(T) = 1 - \Big(1 - \frac{S}{2^b}\Big)^{rT} \approx 1 - \exp\Big(-\frac{rTS}{2^b}\Big), \qquad \bar{T} = \frac{2^b}{rS}. \tag{3.5}$$

Для $b = 64$, $S = 10^5$, $r = 10^4$ с$^{-1}$ маємо $\bar{T} \approx 585$ років і ймовірність успіху за рік $\approx 0{,}17\,\%$; для $b = 32$ — секунди, для $b = 128$ — близько 10^{-22} за рік. Тому 64 біти — мінімум із запасом на зростання S і r; від викрадення токена через XSS чи журнали ентропія не захищає (розділи ??, ??).

Друга вимога — *унікальність*. Для n випадкових b-бітових ідентифікаторів імовірність колізії (парадокс днів народження)

$$P_{\text{кол}}(n) \approx 1 - \exp\Big(-\frac{n^2}{2^{\,b+1}}\Big), \qquad n_{0,5} \approx 1{,}18 \cdot 2^{b/2}, \tag{3.6}$$

де $n_{0,5}$ — кількість, за якої колізія рівноймовірна. Для 32-бітових ідентифікаторів за $n = 10^5$ маємо $P_{\text{кол}} \approx 0{,}69$, для 64-бітових за $n = 10^9$ — $2{,}7\,\%$, для UUID версії 4 (122 випадкові біти) за $n = 10^{12}$ — близько 10^{-13}. Довжину обирають за жорсткішою з умов (3.5) і (3.6).

Для ідентифікаторів об'єктів (номер замовлення, документа) непередбачуваність має інше значення. За послідовних ідентифікаторів порушник майже кожним запитом влучає в чужий об'єкт, за випадкових 64-бітових і $n = 10^6$ об'єктів — з імовірністю $n/2^{64} \approx 5 \cdot 10^{-14}$. Проте це *не є* контролем доступу: ідентифікатори витікають через журнали, Referer і спільні посилання, а першопричиною IDOR залишається відсутня перевірка авторизації (A01:2025) [108]. Випадкові ідентифікатори зменшують лише масштаб масового перебору (розділ ??).

3.3 Моделі підбору облікових даних

3.3.1 Онлайновий підбір з обмеженням частоти

Нехай вебресурс дозволяє не більше r спроб на обліковий запис за одиницю часу і блокує автентифікатор після L послідовних невдач. Тоді кількість спроб щодо одного запису за час T, імовірність зламу цільового запису й очікувана кількість зламаних записів за розпилення паролів (password spraying) по k найпоширеніших паролів на кожен з A записів

$$n(T) = \min\big(\lfloor rT \rfloor,\ L\big), \qquad P_{\text{онл}}(T) = \lambda_{n(T)}, \qquad \mathbb{E}[X_{\text{розп}}] = A\,\lambda_k, \quad k < L, \tag{3.7}$$

де λ_β визначено в (3.3). Ліміт L обмежує ризик *окремого* запису значенням λ_L незалежно від тривалості атаки, але не ризик *сукупності* записів: розпилення залишається нижче порога блокування. NIST SP 800-63B-4 обмежує кількість послідовних невдалих спроб значенням не більше 100 [127].

За моделлю Ципфа ($s = 0{,}8$) $\lambda_{100} = 6{,}7\,\%$, а розпилення п'яти паролів по $A = 2 \cdot 10^5$ записах дає $A\lambda_5 \approx 4\,300$ зламаних записів. Якщо заборонено 10^4 найпоширеніших паролів і користувачі, що обрали б їх, розподіляються пропорційно за рештою розподілу, ці показники падають до 0,07 % і приблизно семи записів; припущення оптимістичне, але порядок ефекту зберігається. Ліміт за IP-адресою проти ботнету слабкий (розділ **??**).

3.3.2 Заповнення облікових даних

Заповнення облікових даних (credential stuffing) використовує пари «логін–пароль» з витоків інших сервісів, тож успіх визначає поведінка користувачів: за оцінкою Даса й співавторів, 43–51 % користувачів повторно використовують пароль на різних сайтах, а багато інших застосовують передбачувані перетворення [60]. Очікувана кількість захоплених записів

$$\mathbb{E}[X_{\text{зап}}] = A\,\rho_L\,\rho_R\,(1-\rho_M)\,(1-d), \tag{3.8}$$

де ρ_L — частка записів, для яких у порушника є пара з витоків; ρ_R — частка повторного використання; ρ_M — частка записів зі стійкою до цієї атаки MFA; d — імовірність блокування спроби засобом протидії ботам. Для $A = 2 \cdot 10^5$, $\rho_L = 0{,}3$, $\rho_R = 0{,}45$ без MFA і протидії ботам маємо 27 000 записів — на порядок більше, ніж за розпилення. Модель мультиплікативна, тож найсильніші заходи обнуляють множник: обов'язкова фішингостійка MFA, ключі доступу (passkeys), що усувають пароль, і перевірка паролів за базами витоків (розділ **??**). Протидія ботам лише зменшує масштаб, а ліміт L не діє: на запис витрачається одна-дві спроби.

3.3.3 Вартість офлайнового підбору

Після викрадення бази гешів сервер не контролює частоту спроб, і захищає лише вартість функції гешування. Вартість перевірки N_g кандидатів і обмеження швидкості для Argon2

$$C_{\text{офл}} = \frac{N_g}{3600\,R}\,c_h, \qquad R_{\text{Argon2}} \lesssim \frac{B_{\text{пам}}}{3\,t\,m}, \tag{3.9}$$

де R — швидкість перевірки на одному GPU (спроб/с); c_h — вартість GPU-години; $B_{\text{пам}}$ — пропускна здатність пам'яті (байт/с); t — кількість проходів по пам'яті обсягом m байт (кожен блок — два читання й один запис). Через сіль $N_g = A\beta$ для β спроб на запис.

Візьмемо вимірювання hashcat 6.2.6 на RTX 4090 [58]: MD5 — $1{,}64 \cdot 10^{11}$ спроб/с, SHA-256 — $2{,}2 \cdot 10^{10}$, PBKDF2-HMAC-SHA256 (999 ітерацій) — $8{,}87 \cdot 10^6$, bcrypt з вартістю 5 — $1{,}84 \cdot 10^5$, scrypt з $N = 2^{14}$ — 7126. Для параметрів, рекомендованих OWASP [103], швидкості перераховано пропорційно кількості ітерацій, для Argon2id оцінено за (3.9) з $B_{\text{пам}} \approx 10^{12}$ байт/с; $c_h = 0{,}5$ дол. (табл. 3.2).

Таблиця 3.2 — Оцінка вартості офлайнового підбору на одному GPU класу RTX 4090

Функція і параметри	R, спроб/с	Простір $36^8 \approx 2{,}8{\cdot}10^{12}$: час; вартість	$2{\cdot}10^5$ записів $\times\, 10^3$ спроб: GPU-год; вартість
MD5	$1{,}6{\cdot}10^{11}$	17 с; $<$0,01 дол.	$<0{,}01$; ≈ 0
SHA-256	$2{,}2{\cdot}10^{10}$	2 хв; 0,02 дол.	$<0{,}01$; ≈ 0
PBKDF2-SHA256, 600 000	$1{,}5{\cdot}10^{4}$	6 GPU-років; $2{,}7{\cdot}10^{4}$ дол.	3,8; 1,9 дол.
bcrypt, вартість 10	$5{,}8{\cdot}10^{3}$	16 GPU-років; $6{,}8{\cdot}10^{4}$ дол.	9,7; 4,8 дол.
bcrypt, вартість 12	$1{,}4{\cdot}10^{3}$	62 GPU-роки; $2{,}7{\cdot}10^{5}$ дол.	39; 19 дол.
scrypt, $N = 2^{17}$, $r = 8$	$\approx 9{\cdot}10^{2}$	100 GPU-років; $4{,}4{\cdot}10^{5}$ дол.	62; 31 дол.
Argon2id, 19 МіБ, $t = 2$	$\lesssim 8{\cdot}10^{3}$	$\gtrsim$11 GPU-років; $\gtrsim 4{,}6{\cdot}10^{4}$ дол.	$\gtrsim$6,6; $\gtrsim$3,3 дол.

Отже, швидкі геш-функції непридатні: восьмисимвольний пароль з малих літер і цифр перебирається за хвилини [34]. Повільні функції захищають *випадкові* паролі, але не обрані людиною: перевірка 10^3 найпоширеніших кандидатів для кожного з $2 \cdot 10^5$ записів з bcrypt (вартість 12) коштує близько 19 дол. і за $\lambda_{1000} = 12{,}8\,\%$ розкриває близько $25\,500$ паролів. Мінімальні параметри Argon2id за вартістю на GPU порівнянні з bcrypt з вартістю 10, тому RFC 9106 рекомендує значно більші параметри ($m = 2$ ГіБ, $t = 1$ або $m = 64$ МіБ, $t = 3$) [44]. Повільне гешування без заборони поширених паролів і MFA недостатнє (розділ ??).

3.4 Теорія статистичного виявлення

3.4.1 Критерій Неймана–Пірсона і ROC-крива

WAF, система виявлення вторгнень чи модуль протидії ботам перевіряють гіпотези: $\mathcal{H}_0$ — запит легітимний, $\mathcal{H}_1$ — атака. Якщо відомі щільності ознак запиту $f_0(x)$ і $f_1(x)$, то за лемою Неймана–Пірсона найпотужніше правило за заданої ймовірності хибної тривоги α

$$\Lambda(x) = \frac{f_1(x)}{f_0(x)} \underset{\mathcal{H}_0}{\overset{\mathcal{H}_1}{\gtrless}} \eta, \qquad P_{FA} = \Pr\{\Lambda > \eta \mid \mathcal{H}_0\} = \alpha, \qquad P_D = Q\big(Q^{-1}(P_{FA}) - d'\big), \tag{3.10}$$

де η — поріг; P_D — імовірність виявлення; остання рівність справджується для гауссівської моделі з однаковою дисперсією, d' — відстань між середніми в одиницях стандартного відхилення, $Q(\cdot)$ — доповнювальна функція стандартного нормального розподілу. Залежність $P_D(P_{FA})$ за зміни порога — ROC-крива. Приклад: за $d' = 3$ і $P_{FA} = 10^{-3}$ маємо $P_D = Q(3{,}09 - 3) \approx$

0,46, а за $P_{FA} = 10^{-5}$ — лише 0,10; для $d' = 5$ — 0,97 і 0,77. Отже, дуже мала P_{FA} досяжна лише за рахунок якості ознак, а не налаштування порога.

3.4.2 Проблема базової частоти

Аксельссон показав, що для систем виявлення вторгнень вирішальною є P_{FA}, бо частка атак у потоці подій мізерна [41]. Нехай π — апріорна частка шкідливих запитів. За формулою Байєса частка істинних тривог серед усіх тривог (positive predictive value)

$$\mathrm{PPV} = \frac{P_D\,\pi}{P_D\,\pi + P_{FA}\,(1-\pi)}, \qquad P_{FA} \;\le\; \frac{P_D\,\pi\,(1-\mathrm{PPV}^*)}{\mathrm{PPV}^*\,(1-\pi)}, \tag{3.11}$$

де друга нерівність — вимога до детектора для цільового значення PPV^*.

Числовий приклад. Вебресурс обробляє 10^7 HTTP-запитів на добу, з них атакувальних $\pi = 10^{-5}$ (100 запитів), $P_D = 0{,}99$. За $P_{FA} = 10^{-3}$ маємо 99 істинних і близько 10 000 хибних тривог, PPV $\approx 1\,\%$; якщо первинний аналіз тривоги триває 5 хв, потрібно 842 людино-години на добу — понад сто аналітиків. За $P_{FA} = 10^{-4}$ — 1099 тривог, PPV $\approx 9\,\%$, 92 людино-години; лише за $P_{FA} \approx 10^{-5}$ PPV сягає 50 % (199 тривог, 17 людино-годин), а для $\mathrm{PPV}^* = 0{,}9$ потрібна $P_{FA} \le 1{,}1 \cdot 10^{-6}$. Криві (3.11) наведено на рис. 3.1.

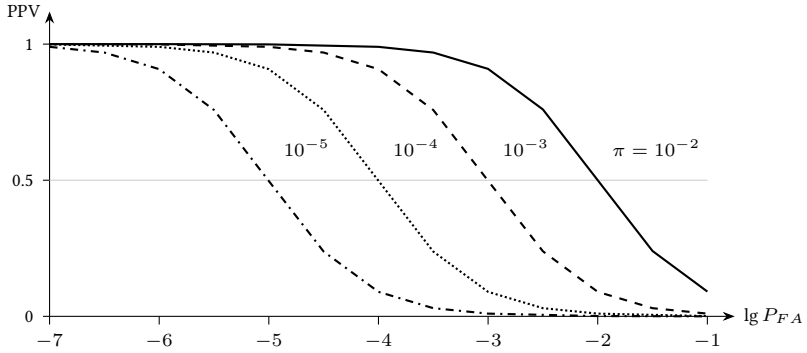


Рис. 3.1 — Частка істинних тривог залежно від імовірності хибної тривоги для різних базових частот ($P_D = 0{,}99$), розраховано за (3.11)

Зменшення базової частоти на порядок вимагає на порядок меншої P_{FA}. Звідси наслідки для WAF і моніторингу (розділи **??**, **??**): блокувальні правила мають працювати з мінімальною P_{FA}, решта — в режимі журналювання; кореляція кількох умовно незалежних ознак (сигнатура, аномальна відповідь, подальша поведінка клієнта) зменшує ефективну P_{FA} приблизно до добутку окремих значень; оцінки детекторів на збалансованих наборах даних без перерахунку на реальну π вводять в оману. Добове навантаження

$N_{\text{зап}}\big(P_D\pi + P_{FA}(1-\pi)\big)\tau$, де τ — час аналізу тривоги, робить поріг ще й *організаційним* параметром: перевантажені аналітики пропускають тривоги, що фактично зменшує P_D.

3.5 Моделі масового обслуговування для оцінювання стійкості до відмови в обслуговуванні

3.5.1 Модель M/M/1 і закон Літтла

Вебсервер з одним робочим процесом, пуассонівським потоком запитів інтенсивністю λ і експоненційним часом обслуговування із середнім $1/\mu$ описується моделлю M/M/1 [88]:

$$\rho = \frac{\lambda}{\mu}, \qquad L = \frac{\rho}{1-\rho}, \qquad W = \frac{1}{\mu - \lambda}, \qquad L = \lambda W \quad (\rho < 1), \tag{3.12}$$

де ρ — завантаження, L — середня кількість запитів у системі, W — середній час перебування; остання рівність — закон Літтла, справедливий для будь-якої стаціонарної системи, що дозволяє перевіряти вимірювання за журналами. Для $\mu = 100$ с$^{-1}$ за $\lambda = 50$ маємо $W = 20$ мс, за $\lambda = 90$ — 100 мс, за $\lambda = 99$ — 1 с: порушникові достатньо підняти завантаження до 0,95–0,99.

3.5.2 Багатоканальна модель M/M/c і формула Ерланга C

Для сервера з c робочими процесами, навантаженням $a = \lambda/\mu$ і $\rho = a/c < 1$ імовірність очікування в черзі дає формула Ерланга C [88]:

$$C(c,a) = \frac{\dfrac{a^c}{c!}\,\dfrac{c}{c-a}}{\displaystyle\sum_{k=0}^{c-1}\frac{a^k}{k!} + \frac{a^c}{c!}\,\frac{c}{c-a}}, \qquad W_q = \frac{C(c,a)}{c\mu - \lambda}, \qquad W = W_q + \frac{1}{\mu}. \tag{3.13}$$

Приклад: $c = 16$, час обслуговування 20 мс ($\mu = 50$ с$^{-1}$), пропускна здатність 800 запитів/с. За $\lambda = 400$ ($\rho = 0{,}5$) $C = 0{,}009$, $W_q \approx 0{,}02$ мс; за $\lambda = 760$ ($\rho = 0{,}95$) $C = 0{,}78$, $W_q = 19{,}5$ мс, $W = 39{,}5$ мс і за законом Літтла $L \approx 30$; за $\lambda = 790$ $W \approx 114$ мс. Багатоканальна система довше зберігає малу затримку, але різкіше деградує поблизу насичення (рис. 3.2).

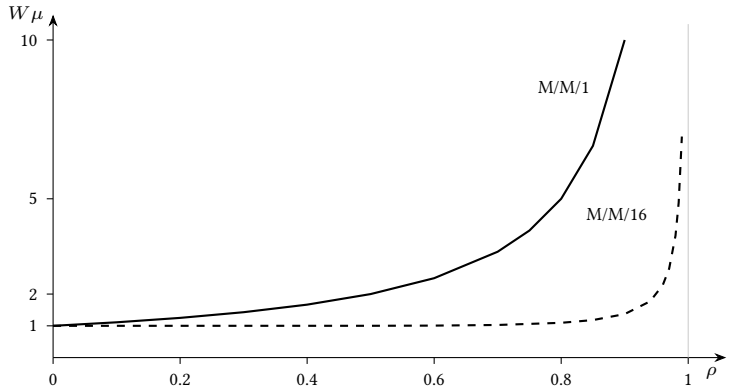


Рис. 3.2 — Нормований час перебування $W\mu$ залежно від завантаження для моделей M/M/1 і M/M/16, розраховано за (3.12) і (3.13)

3.5.3 Неоднорідні запити і вплив варіативності

У вебзастосунку більшість запитів обробляються за мілісекунди, а пошук, звіти чи експорт — за секунди. Для системи M/G/c з коефіцієнтом варіації часу обслуговування c_s застосовують наближення Аллена–Канніна

$$W_q^{\mathrm{M/G/c}} \;\approx\; W_q^{\mathrm{M/M/c}} \cdot \frac{1 + c_s^2}{2}, \qquad c_s^2 = \frac{\operatorname{Var} S}{(\mathbb{E}S)^2}, \tag{3.14}$$

тобто черга зростає пропорційно c_s^2. Додамо до легітимних запитів попереднього прикладу ($\lambda_l = 400$ с$^{-1}$ по 20 мс) $\lambda_a = 3$ с$^{-1}$ «дорогих» запитів по 2 с: $\mathbb{E}S = 34{,}7$ мс, $\rho = 0{,}875$, $c_s^2 \approx 49$, і очікування зростає з 8,8 мс (M/M/c) до близько 220 мс, а за $\lambda_a = 3{,}5$ с$^{-1}$ — до 0,7 с. Крайній випадок — алгоритмічна складність: Кросбі і Воллах показали, що підібрані ключі, які спричиняють колізії в геш-таблицях, перетворюють операції зі складністю $O(1)$ на $O(n)$ і дозволяють малим потоком вивести сервер з ладу [59]; сучасні аналоги — ReDoS і вкладені запити GraphQL (розділ ??).

3.5.4 Коефіцієнт підсилення атаки

Стійкість до прикладної відмови в обслуговуванні характеризує мінімальна інтенсивність атакувальних запитів λ_a^*, що доводить сервер до насичення. З умови $\rho = (\lambda_l s_l + \lambda_a s_a)/c < 1$, де s_l, s_a — середній час обслуговування легітимного й атакувального запиту,

$$\lambda_a^* = \frac{c - \lambda_l s_l}{s_a}, \qquad \kappa = \frac{s_a}{s_l}, \qquad A_{\text{ек}} = \frac{\text{витрати сервера на запит}}{\text{витрати порушника на запит}}, \tag{3.15}$$

де κ — асиметрія вартості запиту; $A_{\text{ек}}$ — економічний коефіцієнт підсилення. У прикладі $\lambda_a^* = (16 - 400 \cdot 0{,}02)/2 = 4$ запити/с; за розміру запиту 2 КБ це близько 64 кбіт/с — потік одного домашнього комп'ютера, непомітний для мережевого захисту від DDoS, тоді як звичайними запитами ($\kappa = 1$) знадобилося б 400 запитів/с. Для атак відбиттям аналогом κ є відношення розміру відповіді до розміру запиту (розділ **??**). Напрями захисту: зменшення s_a (кешування, індекси, ліміт вибірки), окремий пул процесів для дорогих кінцевих точок, обмеження частоти саме дорогих операцій і перенесення вартості на клієнта. Ці моделі доповнюють українські дослідження низькошвидкісних HTTP-атак, що виснажують з'єднання сервера малим потоком [18].

3.6 Атакові графи та марковські моделі

3.6.1 Атакові графи

Атаковий граф узагальнює формулу (1.8): вершини — стани порушника або умови (вразливість, доступ), дуги — дії (XSS, заповнення облікових даних, IDOR, SSRF). Шейнер і співавтори запропонували автоматичне генерування атакових графів методом перевірки моделей і пошук мінімальних наборів заходів, що розривають усі шляхи до цілі [120]. Якісну побудову графів розглянуто в розділі 4, тут — їхні ймовірнісні інтерпретації.

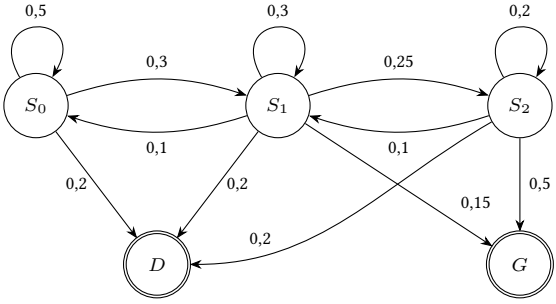
3.6.2 Поглинальний марковський ланцюг

Якщо порушник на кожному кроці просувається, залишається на місці, відступає або його виявляють, процес описує поглинальний марковський ланцюг з перехідною матрицею в канонічній формі

$$\mathbf{P} = \begin{pmatrix} \mathbf{Q} & \mathbf{R} \\ \mathbf{0} & \mathbf{I} \end{pmatrix}, \qquad \mathbf{N} = (\mathbf{I} - \mathbf{Q})^{-1}, \qquad \mathbf{B} = \mathbf{N}\mathbf{R}, \qquad \mathbf{t} = \mathbf{N}\mathbf{1}, \tag{3.16}$$

де $\mathbf{Q}$ — переходи між транзитивними станами; $\mathbf{R}$ — переходи в поглинальні стани («ціль досягнуто» G, «порушника виявлено» D); елемент n_{ij} фундаментальної матриці $\mathbf{N}$ — середня кількість відвідувань стану j зі стану i; b_{ik} — імовірність поглинання станом k; t_i — середня кількість кроків до поглинання.

Приклад наведено на рис. 3.3: з розвідки S_0 порушник за крок з імовірністю 0,3 отримує сеанс користувача S_1 (заповнення облікових даних, XSS), з імовірністю 0,2 його зупиняють; із сеансу з імовірністю 0,25 отримує функції адміністратора S_2, з імовірністю 0,15 одразу отримує дані через IDOR, з імовірністю 0,2 його виявляють; з S_2 з імовірністю 0,5 вивантажує дані.



S_0 — розвідка; S_1 — сеанс користувача; S_2 — функції адміністратора; G — дані вивантажено; D — порушника зупинено

Рис. 3.3 — Поглинальний марковський ланцюг атаки на вебзастосунок

Обчислення за (3.16) дає $b_{0G} \approx 0{,}30$, $b_{1G} \approx 0{,}50$, $b_{2G} \approx 0{,}69$ і $t_0 \approx 3{,}5$ кроку. Обов'язкова MFA, що зменшує ймовірність $S_0 \to S_1$ до 0,1 (решта — у D), знижує b_{0G} до 0,09; виправлення IDOR (перехід $S_1 \to G$ замінюється на виявлення) — до 0,15; обидва заходи — до 0,05. Модель враховує повторні спроби й повернення, але припускає відсутність пам'яті порушника, а ймовірності переходів доводиться оцінювати експертно або за даними тестувань на проникнення (розділ ??).

3.6.3 Байєсові атакові графи

У байєсовому атаковому графі [111] кожна вершина v — бінарна випадкова величина «умову досягнуто», а таблиці умовних імовірностей задаються типом вершини. Для вершин «І» (потрібні всі передумови) і «АБО» (достатньо однієї) за припущення незалежності

$$P_{\text{І}}(v) = p_v \prod_{u \in \mathrm{pa}(v)} P(u), \qquad P_{\text{АБО}}(v) = 1 - \prod_{u \in \mathrm{pa}(v)} \bigl(1 - p_{uv} P(u)\bigr), \tag{3.17}$$

де $\mathrm{pa}(v)$ — батьківські вершини; p_v, p_{uv} — імовірності успіху експлуатації за наявності передумов. Приклад: сеанс досягається через збережений XSS ($p = 0{,}3$) АБО заповнення облікових даних ($p = 0{,}2$): $P(S_1) = 1 - 0{,}7 \cdot 0{,}8 = 0{,}44$; доступ адміністратора вимагає сеансу І IDOR в API адміністратора ($p = 0{,}6$): $P(S_2) = 0{,}264$; ціль досягається через S_2 АБО незалежну SSRF ($p = 0{,}1$): $P(G) \approx 0{,}34$. Виправлення IDOR ($p = 0{,}05$) знижує $P(G)$ до 0,12, а CSP, що зменшує успішність XSS до 0,05, — лише до 0,23. Головна перевага підходу — оновлення апостеріорних імовірностей за спостереженнями моніторингу, що дає змогу динамічно пріоритизувати реагування [111]; обмеження — зростання таблиць для вершин з багатьма батьками і суб'єктивність p_v.

3.7 Оцінки вразливостей і ймовірнісна пріоритизація

3.7.1 CVSS 4.0

CVSS версії 4.0 (FIRST, листопад 2023 р.) оцінює *технічну тяжкість* вразливості за шкалою 0–10 [72]. Базові метрики охоплюють експлуатованість (вектор атаки AV, складність AC, нова метрика вимог до атаки AT, привілеї PR, взаємодія з користувачем UI — «немає», «пасивна», «активна») і вплив окремо на вразливу (VC, VI, VA) і подальші системи (SC, SI, SA), що замінило неоднозначну метрику Scope версії 3.1. Група загрози містить зрілість експлойта (E), група середовища — вимоги до властивостей безпеки, додаткові метрики на оцінку не впливають; позначення CVSS-B, CVSS-BT, CVSS-BE, CVSS-BTE вказують використані групи, рівень «високий» відповідає 7,0–8,9, «критичний» — 9,0–10,0. CVSS є мірою тяжкості, а не ризику: за даними Денисюка (понад 300 тис. записів NVD) лише близько 0,45 % CVE потрапляють до каталогу експлуатованих вразливостей [3], тож пріоритизація лише за CVSS змушує виправляти безліч вразливостей, які ніколи не будуть атаковані.

3.7.2 EPSS, каталог KEV і SSVC

EPSS оцінює ймовірність того, що для вразливості буде зафіксовано експлуатаційну активність упродовж наступних 30 днів [86]. Модель навчається на даних сенсорів про спроби експлуатації та ознаках CVE і щоденно оновлює оцінки; третю версію описано в [87], четверту випущено в березні 2025 р. Каталог KEV агентства CISA містить вразливості з *підтвердженою* експлуатацією і чіткими заходами усунення; для федеральних органів США він пов'язаний з обов'язковими строками виправлення, на кінець 2025 р. налічував близько 1 500 записів [50]. SSVC замінює числову оцінку деревом рішень: за станом експлуатації, технічним впливом, автоматизованістю, значущістю для місії і впливом на суспільний добробут вразливість відносять до дії Track, Track*, Attend або Act [51]. Порівняння — у табл. 3.3.

Таблиця 3.3 — Порівняння систем оцінювання вразливостей

Система	Що оцінює	Результат	Обмеження
CVSS 4.0	Технічну тяжкість за умови експлуатації	Оцінка 0–10, вектор	Не є ймовірністю; група середовища рідко заповнюється
EPSS	Імовірність експлуатації за 30 днів	$p \in [0,1]$, процентиль	Глобальна, без урахування середовища; залежить від сенсорів
KEV	Факт підтвердженої експлуатації	Так / ні	Запізнюється; лише підтверджене
SSVC	Рішення для зацікавленої сторони	Track, Track*, Attend, Act	Якісна; потребує знання місії й активів

3.7.3 Пріоритизація як задача оптимізації

Джейкобс і співавтори формалізували вибір стратегії виправлень через метрики інформаційного пошуку [85]. Нехай V — вразливості в інвентарі, p_i — імовірність експлуатації, c_i — вартість усунення, $x_i \in \{0,1\}$ — рішення про виправлення, B — бюджет циклу. Тоді

$$\mathrm{Cov} = \frac{TP}{TP+FN}, \quad \mathrm{Eff} = \frac{TP}{TP+FP}, \quad \max_{\mathbf{x}} \sum_{i \in V} x_i p_i \ \text{ за } \sum_{i \in V} x_i c_i \le B, \tag{3.18}$$

де TP — виправлені вразливості, що згодом експлуатувалися; FN — невиправлені експлуатовані; FP — виправлені неексплуатовані. Покриття показує частку закритих реальних загроз, ефективність — частку не марно витрачених зусиль. Задача є задачею про рюкзак; жадібний розв'язок (сортування за p_i/c_i) близький до оптимального, коли $c_i \ll B$. Для вебресурсів у p_i доцільно враховувати й досяжність компонента з Інтернету.

В умовному прикладі табл. 3.4 стратегія за CVSS $\ge 7{,}0$ потребує 900 виправлень за ефективності 3,3 %, що ненабагато краще за випадковий вибір, а «KEV або EPSS $\ge 0{,}1$» з 140 виправленнями дає більше покриття. Числа умовні, але співвідношення відповідає емпіричним висновкам [85, 87]. Згідно з моделлю гонки (1.6) вразливості з KEV і високим EPSS слід виправляти за години чи дні, решту — у плановому циклі.

Таблиця 3.4 — Порівняння стратегій виправлення (умовний приклад: 2000 вразливостей, 45 експлуатуються)

Стратегія	Зусилля	TP	Покриття	Ефективність
Виправляти все	2000	45	100 %	2,3 %
CVSS $\geq$ 9,0	250	12	26,7 %	4,8 %
CVSS $\geq$ 7,0	900	30	66,7 %	3,3 %
EPSS $\geq$ 0,1	120	27	60,0 %	22,5 %
KEV або EPSS $\geq$ 0,1	140	33	73,3 %	23,6 %
Те саме або CVSS $\geq$ 9,0 на зовнішніх ресурсах	300	38	84,4 %	12,7 %

3.8 Розгорнутий приклад комплексного розрахунку

Розглянемо вебпортал електронних послуг: $A = 2 \cdot 10^5$ облікових записів, 10^7 запитів на добу, пікове легітимне навантаження 400 запитів/с, 16 робочих процесів (типовий запит 20 мс, пошук за реєстром 2 с). Вихідна конфігурація: паролі без перевірки за списками, bcrypt з вартістю 12, ліміт 100 невдалих спроб, MFA у 60 % користувачів, протидія ботам блокує половину спроб, токени сеансу 128 біт, WAF з $P_{FA} = 10^{-4}$, $P_D = 0{,}99$. Порушник має пари з витоків для $\rho_L = 30\,\%$ користувачів, $\rho_R = 0{,}45$ [60], ботнет і оренду GPU за 0,5 дол./год; паролі розподілені за Ципфом ($s = 0{,}8$).

Результати розрахунку зведено в табл. 3.5. Розпилення паролів оцінено з урахуванням MFA ($4\,300 \cdot 0{,}4$), заповнення облікових даних — як $2 \cdot 10^5 \cdot 0{,}3 \cdot 0{,}45 \cdot 0{,}4 \cdot 0{,}5 = 5\,400$ записів; заходи — список з 10^4 заборонених паролів, обов'язкова фішингостійка MFA для 95 % записів, кореляція двох умовно незалежних ознак WAF з $P_{FA} \approx 10^{-2{,}5}$ кожна, кешування й індексування пошуку ($s_a = 0{,}2$ с) з окремим пулом процесів, виправлення IDOR і перехід до пріоритизації за KEV і EPSS.

Таблиця 3.5 — Зведення результатів розрахунку для вебпорталу електронних послуг

Показник	Формула	Вихідна конфігурація	Після заходів
Угадування сеансу за рік	(3.5)	$<10^{-20}$	без змін
Цільовий онлайновий підбір	(3.7)	6,7 %	0,07 % (список заборонених)
Розпилення паролів, записів	(3.7)	$\approx$1 700	одиниці
Заповнення облікових даних	(3.8)	5 400	675 (MFA 95 %)
Офлайн, 10^3 спроб на запис	(3.9)	19 дол.; $\approx$25 500 паролів	$\approx$1 300 паролів
PPV тривог WAF	(3.11)	9 %; 92 люд.-год/добу	50 %; 17 люд.-год/добу
Поріг прикладного DoS λ_a^*	(3.15)	4 запити/с	40 запитів/с, окремий пул
Досягнення цілі	(3.16)	0,30	0,05 (MFA, IDOR)
Виправлень для покриття $\geq$67 %	(3.18)	900 (CVSS)	140 (KEV, EPSS)

Найбільший ефект дають заходи, що усувають цілі класи атак, а не ті, що лише здорожчують окрему спробу. Результати чутливі до ρ_L, s і ймовірностей переходів, тож на практиці їх подають інтервалами, отриманими методом Монте-Карло (розділ 4).

Висновки до розділу

Майже всі показники захищеності вебресурсу визначаються економікою порушника. Ентропія Шеннона не характеризує стійкість паролів: їхня мінентропія близько 6,5 біт, а проти офлайнової атаки вони еквівалентні випадковим секретам близько 20 біт, тож найефективнішим заходом є заборона найпоширеніших паролів. Серверні секрети мають містити щонайменше 64 випадкові біти, але непередбачуваність ідентифікатора не замінює контролю доступу. Ліміт спроб обмежує ризик окремого запису, але не сукупності записів; заповнення облікових даних описується мультиплікативною моделлю з вирішальною роллю MFA; повільне гешування не захищає популярних паролів. Проблема базової частоти вимагає P_{FA} порядку 10^{-5}–10^{-6} і кореляції ознак. Прикладну відмову в обслуговуванні визначають асиметрія вартості запитів і варіативність часу обслуговування. Атакові графи дозволяють порівнювати заходи за ймовірністю досягнення цілі, а поєднання EPSS і KEV з CVSS дає краще покриття експлуатованих вразливостей за на порядок менших зусиль. Цінність моделі визначають явні припущення й аналіз чутливості.

Питання для самоперевірки

1. Які показники захищеності вебресурсу наведено в табл. 3.1? Чому майже всі вони визначаються економікою порушника?
2. Обчисліть H, H_∞ і G за (3.1) для розподілу $(0{,}5;\ 0{,}25;\ 0{,}125;\ 0{,}125)$. Чому оцінка (3.2) тут не застосовна?
3. Поясніть метрики λ_β і $\tilde{\lambda}_\beta$ (3.3). Яку ймовірність зламу за 10 спроб означає $\tilde{\lambda}_{10} = 9{,}1$ біт?
4. Чому правила складу пароля менш ефективні, ніж список заборонених паролів? Обґрунтуйте за законом Ципфа (3.4).
5. За (3.5) визначте мінімальну довжину токена сеансу, за якої ймовірність угадування за рік не перевищує 10^{-6} для $S = 10^6$ і $r = 10^5$ с$^{-1}$.
6. За (3.6) оцініть кількість 48-бітових випадкових ідентифікаторів, за якої ймовірність колізії досягає 1 %. Чому випадкові ідентифікатори не усувають IDOR?
7. Порівняйте за (3.7) цільовий підбір і розпилення паролів. Чому ліміт невдалих спроб не захищає від розпилення?
8. Які множники моделі (3.8) найефективніше зменшувати і якими заходами?
9. За табл. 3.2 оцініть вартість перевірки 10^4 кандидатів для кожного з 10^6 записів з bcrypt (вартість 12). Яку частку паролів буде розкрито за $\lambda_{10^4} \approx 22\,\%$?
10. Як зміниться P_D за (3.10) для $d' = 4$ при переході від $P_{FA} = 10^{-3}$ до 10^{-5}?
11. За (3.11) визначте P_{FA} для PPV $= 0{,}8$ за $\pi = 10^{-6}$ і $P_D = 0{,}95$. Як це ілюструє рис. 3.1?
12. За (3.13) і законом Літтла обчисліть W і L для $c = 8$, $\mu = 25$ с$^{-1}$, $\lambda = 180$ с$^{-1}$. Чому багатоканальна система різкіше деградує поблизу насичення (рис. 3.2)?
13. Поясніть роль κ і c_s^2 у формулах (3.14) і (3.15). Які архітектурні заходи зменшують кожну з цих величин?
14. Обчисліть за (3.16) імовірність досягнення цілі для ланцюга рис. 3.3, якщо ймовірність виявлення в кожному стані зросте до 0,3 за рахунок імовірності залишитися в стані.
15. Дослідницьке: розробіть методику оцінювання параметрів ρ_L і ρ_R моделі (3.8) для державного вебпорталу за журналами автентифікації без порушення приватності користувачів і обґрунтуйте вимоги до обсягу вибірки.

16. Дослідницьке: запропонуйте модель пріоритизації виправлень для вебресурсів, що поєднує EPSS, KEV, досяжність вразливого коду і модель гонки (1.6), сформулюйте її як задачу (3.18) і запропонуйте метрики для експериментальної перевірки.

РОЗДІЛ 4

Моделювання загроз і управління ризиками вебзастосунків

Розділи 1–3 описали вебресурс як об'єкт захисту і модель порушника, нормативні вимоги та кількісні моделі окремих властивостей — стійкості секретів, виявлення, відмови в обслуговуванні, атакових графів, оцінок CVSS, EPSS і KEV. Управлінського змісту ці результати набувають у системі рішень: які активи захищати, від яких сценаріїв, якими заходами, за яку ціну і який залишковий ризик прийнятний. Розділ розглядає процес управління ризиками, методології моделювання загроз (STRIDE, PASTA, LINDDUN), бази знань CAPEC, CWE і ATT&CK, дерева атак, кількісні моделі ризику (ALE, FAIR, ROSI, модель Гордона–Лоба), безпеку за проєктом і подання невизначеності та завершується моделлю загроз і реєстром ризиків порталу державних послуг.

4.1 Процес управління ризиками

4.1.1 Стандарти та загальна схема

Ризик за ISO 31000 [81] — це вплив невизначеності на цілі; ризик інформаційної безпеки подають поєднанням імовірності (частоти) події та її наслідків. ISO/IEC 27005:2022 [83] конкретизує процес ISO 31000: встановлення контексту, оцінювання ризиків (ідентифікація, аналіз, оцінка), оброблення, прийняття залишкового ризику, а також наскрізні комунікація і моніторинг (рис. 4.1). Редакція 2022 р. розрізняє два підходи до ідентифікації: *подієвий* (event-based), що виходить зі стратегічних сценаріїв — джерело ризику, мотивація, шлях до мети, — і *активо-орієнтований* (asset-based), що перебирає активи, загрози і вразливості. Для вебзастосунку перший зручний на рівні керівництва («масове захоплення облікових записів громадян»), другий — на рівні архітектури, де він поєднується з моделюванням загроз (підрозділ 4.2).

NIST SP 800-30 [98] описує оцінювання ланцюгом «джерело загрози → подія → вразливість (за наявних заходів) → несприятливий вплив» на трьох рівнях: організації, бізнес-процесу та інформаційної системи. CSF 2.0 [100] додав функцію **управління** (GOVERN, GV): категорія GV.RM вимагає визначити стратегію управління ризиками, апетит до ризику і толерантність, GV.SC — ризики ланцюга постачання. Отже, керівництво встановлює критерії прийняття, а команди розробки й експлуатації надають оцінки і варіанти оброблення.

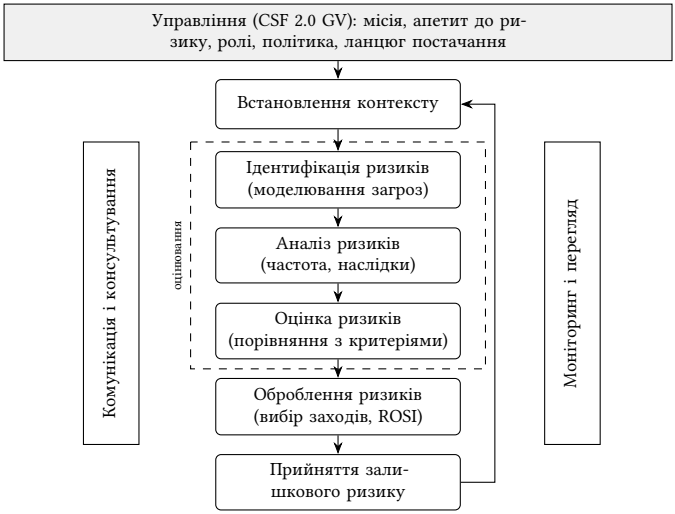


Рис. 4.1 — Процес управління ризиками вебзастосунку (за [83, 81, 100])

Для державних інформаційних ресурсів після змін, внесених Законом № 4336-IX [20], базовим механізмом стали профілі безпеки та авторизація з безпеки [6], які за природою ризик-орієнтовані: вибір заходів профілю обґрунтовують результатами оцінювання ризиків.

4.1.2 Встановлення контексту для вебресурсу

На цьому етапі визначають межі системи, зацікавлені сторони, критерії впливу та прийняття ризику. Межі вебзастосунку майже ніколи не збігаються з межами організації: частину функцій виконують CDN, хмарний провайдер, постачальник ідентичності, платіжний шлюз, сторонні скрипти, а частину — браузер користувача (розділ 1, домени довіри). Тому межі визначають *функціонально* — через потоки даних і межі довіри.

Активами вебресурсу є: *дані* (персональні, платіжні, витяги з реєстрів, ключі API і підпису токенів); *сеанси й токени*, компрометація яких рівнозначна захопленню облікового запису; *облікові записи*, насамперед привілейовані й сервісні; *бізнес-процеси* (оформлення послуги, переказ), цілісність яких не зводиться до цілісності даних; *доступність* у пікові періоди; *репутація і довіра*. Зацікавлені сторони — власник і керівництво (апетит до ризику), користувачі як суб'єкти даних (GDPR [112], Закон «Про захист персональних даних» [25]), команди розробки й експлуатації, постачальники, регулятори та CERT-UA [47]. Критерії впливу задають за кількома вимірами (фінанси, кількість постраждалих, недоступність, регуляторні строки (2.3)) і агрегують за найгіршим виміром, а не сумою балів.

4.2 Моделювання загроз вебзастосунку

4.2.1 Діаграми потоків даних і межі довіри

Моделювання загроз (threat modeling) — структурований аналіз системи з метою виявити, що може піти не так, і вирішити, що з цим робити. Маніфест моделювання загроз [128] (2020) зводить процес до чотирьох запитань: *над чим ми працюємо? що може піти не так? що ми з цим зробимо? чи достатньо добре ми це зробили?* — і наголошує, що «найкращої» методології не існує, а цінність має регулярна практика. Емпіричних порівнянь ефективності методологій бракує [133].

Відповідь на перше запитання дає **діаграма потоків даних** (data flow diagram, DFD) з елементами чотирьох типів: зовнішні сутності, процеси, сховища даних і потоки [122]. До них додають **межі довіри** (trust boundaries), на яких змінюється рівень довіри або власник. Саме на перетинах меж зосереджена більшість загроз: дані з менш довіреного домену мають бути автентифіковані, авторизовані й перевірені.

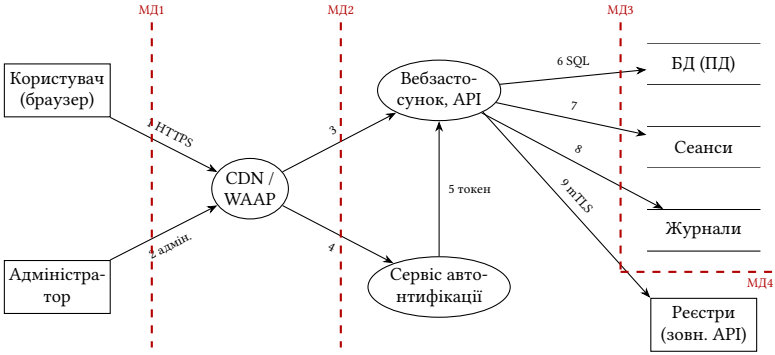


Рис. 4.2 — DFD типового вебзастосунку з межами довіри МД1–МД4 (прямокутник — зовнішня сутність, еліпс — процес, дві лінії — сховище)

На рис. 4.2 МД1 відділяє інтернет від периметра (CDN, вебекран прикладного рівня, протидія ботам), МД2 — периметр від застосунку, МД3 — застосунок від сховищ, МД4 — організацію від зовнішніх реєстрів. Потоки 1 і 2 на МД1 — основне місце підміни й ін'єкцій, підробка токена в потоці 5 означає підміну будь-якого користувача, а спільний шлях адміністративного і користувацького доступу — рішення, яке модель загроз має поставити під сумнів.

4.2.2 STRIDE і STRIDE-per-element

Методологія STRIDE [122] класифікує загрози за порушеною властивістю (табл. 4.1). Це не таксономія атак, а *мнемоніка повноти*: для кожного елемента DFD аналітик ставить шість запитань і фіксує відповіді.

Таблиця 4.1 — Категорії STRIDE у вебзастосунках

Категорія	Властивість	Типові веб-прояви	Заходи (розділ)
Spoofing (підміна)	автентичність	заповнення облікових даних; фішинг з проксі (AiTM); підроблений JWT; викрадений cookie	фішингостійка MFA, ключі доступу; перевірка підпису й аудиторії токена (??, ??)
Tampering (модифікація)	цілісність	SQL- і командні ін'єкції; зміна параметрів ціни; збережений XSS; підміна стороннього скрипту	параметризація; серверна перевірка; CSP, SRI (??, ??, ??)
Repudiation (відмова від авторства)	неспростовність	заперечення транзакції; відсутні або змінювані журнали адміністративних дій	журнали з контролем цілісності; КЕП для юридично значущих дій (??)
Information disclosure (розкриття)	конфіденційність	IDOR; надмірні відповіді API; трасування стека в помилках; SSRF до метаданих хмари	авторизація на рівні об'єктів; мінімізація відповідей; обробка винятків (??, ??)
Denial of service (відмова)	доступність	HTTP-флуд; Rapid Reset; дорогі запити пошуку; ReDoS; блокування облікових записів	CDN, обмеження частоти, квоти, тайм-аути (3, ??)
Elevation of privilege (підвищення)	авторизація	BFLA; масове присвоєння ролі; обхід перевірки в UI; вебшел	централізована авторизація; заборона за замовчуванням (??)

Варіант **STRIDE-per-element** обмежує перебір: для кожного типу елемента DFD застосовні лише певні категорії (табл. 4.2). Сховище журналів додатково є об'єктом загроз неспростовності. Варіант *STRIDE-per-interaction* аналізує пари «джерело–приймач» на межі довіри [122].

Таблиця 4.2 — STRIDE-per-element для DFD рис. 4.2

Елемент	S	T	R	I	D	E	Приклад
Зовнішня сутність	+		+				U: вхід з викраденим паролем
Процес	+	+	+	+	+	+	W: SSTI, IDOR, ReDoS
Потік даних		+		+	+		5: підміна токена
Сховище		+	(+)	+	+		L: видалення записів

Кількість кандидатних загроз для DFD з n_e зовнішніх сутностей, n_p процесів, n_f потоків і n_s сховищ становить $2n_e + 6n_p + 3n_f + 4n_s$; для рис. 4.2 ($n_e = 3$, $n_p = 3$, $n_f = 9$, $n_s = 3$) це $6 + 18 + 27 + 12 = 63$ пари «елемент–категорія». Цінність мають пари з відповіддю «не знаємо» або «залежить від постачальника»: вони формують перелік ризиків для кількісного аналізу.

4.2.3 PASTA: ризик-орієнтоване моделювання

Методологія PASTA (Process for Attack Simulation and Threat Analysis) [129] будує модель «згори вниз» у сім етапів: (1) бізнес-цілі й вимоги відповідності; (2) технічний обсяг; (3) декомпозиція застосунку (DFD, межі довіри, ролі, точки входу); (4) аналіз загроз за даними розвідки та інцидентів; (5) аналіз вразливостей і слабкостей (CWE, результати тестування); (6) моделювання атак (дерева атак, симуляція); (7) аналіз ризиків і впливу із залишковим ризиком. PASTA відповідає не на запитання «що може піти не так з елементом», а «які атаки реальних порушників проти бізнес-функції найімовірніші і скільки вони коштуватимуть». Етапи 4–7 спираються на підрозділи 4.3–4.5; PASTA доцільна для критичних застосунків, а для рядової функціональності достатньо STRIDE-per-element.

4.2.4 LINDDUN: загрози приватності

Система може бути захищеною за STRIDE і водночас надмірно збирати й пов'язувати дані. Методологія LINDDUN [62] використовує ту саму DFD і сім категорій: зв'язуваність (Linkability), ідентифіковуваність (Identifiability), неспростовність (Non-repudiation) як загроза приватності, виявлюваність (Detectability), розкриття інформації (Disclosure), необізнаність суб'єкта (Unawareness) і невідповідність вимогам (Non-compliance). Для вебзастосунків типові зв'язування сеансів через сторонні cookie і відбиток браузера, виявлюваність наявності облікового запису через різні повідомлення форм входу та необізнаність про передачу даних стороннім скриптам. Категорія невідповідності відображає вимоги GDPR [112], а результати LINDDUN є основою оцінки впливу на захист даних (DPIA).

4.3 Бази знань про атаки та слабкості

4.3.1 CAPEC, CWE і ATT&CK

CWE [56] — ієрархічний словник *слабкостей* проєктування й реалізації (CWE-89 — SQL-ін'єкція, CWE-862 — відсутня авторизація), ранжований щорічно в CWE Top 25 [36]. CAPEC [55] — каталог *шаблонів атак* з передумовами, навичками, ресурсами і зв'язками з CWE. MITRE ATT&CK [96] описує *поведінку* реальних порушників: тактики і техніки зі звітів про інциденти. Для вебресурсів ключовою є тактика початкового доступу (Initial Access) з технікою T1190 «Exploit Public-Facing Application»; інші типові техніки наведено в табл. 4.3, а для закріплення — T1505.003 «Web Shell». CWE відповідає на запитання «що неправильно в коді чи проєкті», CAPEC — «як цим скористатися», ATT&CK — «що робить порушник до і після». Ланцюг «CWE → CAPEC → ATT&CK» пов'язує результати статичного аналізу (розділ ??) з правилами виявлення в SIEM (розділ ??).

4.3.2 OWASP Top 10:2025 як каталог ризиків

OWASP Top 10:2025 [108] — каталог *категорій ризику*, кожна з яких агрегує десятки CWE (розділ 1). Він придатний як контрольний список повноти моделі і мова комунікації з керівництвом, але не як одиниця аналізу: A01 охоплює і IDOR у кабінеті громадянина, і SSRF з різними частотами й наслідками. Зв'язки між базами наведено в табл. 4.3; оцінки CVSS 4.0 і EPSS (підрозділ 3.7) слугують вхідними даними для частоти подій у моделі ризику.

Таблиця 4.3 — Зв'язок сценаріїв атак із базами знань

Сценарій	CAPEC	CWE	ATT&CK	Top 10
SQL-ін'єкція в пошуку	66	89	T1190	A05
Збережений XSS у кабінеті	592, 63	79	T1189, T1539	A05
IDOR в API довідок	1	639, 862	T1190	A01
Заповнення облікових даних	600	307, 287	T1110.004, T1078	A07
SSRF до метаданих хмари	664	918	T1190, T1552.005	A01
Шкідлива версія залежності	538	1357	T1195.001	A03
Прикладна відмова в обслуговуванні	125	770, 400	T1499	API4

Відображення між базами не взаємно однозначні: один шаблон CAPEC експлуатує кілька CWE, а T1190 охоплює майже всі серверні вразливості, тобто для веб-рівня ATT&CK надто грубий і потребує доповнення CAPEC. Прикладна відмова в обслуговуванні не має окремої категорії в Top 10:2025 і описується в API Security Top 10 [101]

(API4:2023 «Unrestricted Resource Consumption»). Автоматичне зіставлення CVE → CWE → CAPEC → ATT&CK через різну гранулярність потребує експертної перевірки.

4.4 Дерева атак

4.4.1 Структура та обчислення атрибутів

Дерево атак [119] — ієрархічна модель, корінь якої відповідає меті порушника, внутрішні вузли — підцілям, листя — елементарним діям; вузол «АБО» досягається, якщо досягнуто хоча б одного нащадка, «І» — якщо всіх. Формальна семантика [94] трактує дерево як множину сценаріїв і показує, що атрибут коректно обчислюється знизу вгору, якщо операції для «АБО» і «І» утворюють напівкільце, наприклад $(\min, +)$ для вартості. На відміну від атакових графів (підрозділ 3.6), дерева описують цілі, а не стани системи.

Імовірності за незалежності листків поширюють, як у байєсовому атаковому графі (3.17): $p_{\text{І}} = \prod_k p_k$, $p_{\text{АБО}} = 1 - \prod_k (1 - p_k)$. Для вартості і вигоди раціонального порушника

$$\begin{gathered} c_{\text{І}} = \sum_k c_k, \qquad c_{\text{АБО}} = \min_k c_k, \\ U^* = \max_{\sigma \in \Sigma} \bigl(p_\sigma B - c_\sigma \bigr), \end{gathered} \tag{4.1}$$

де c_k — вартість листка; Σ — множина сценаріїв (мінімальних наборів листків, що досягають кореня); p_σ, c_σ — імовірність успіху і вартість сценарію; B — вигода порушника. Захист *економічно стримує* раціонального порушника, якщо $U^* < 0$. Незалежне поширення p і c некоректне для рішень: мінімальна вартість і максимальна ймовірність можуть досягатися на різних сценаріях, тому використовують U^* або фронт Парето за (p, c). Дерева атак і захисту [89] додають вузли контрзаходів, що дає змогу оцінювати ефект захисту в тій самій моделі.

4.4.2 Приклад: заволодіння обліковим записом адміністратора

Мета G — заволодіння обліковим записом адміністратора вебпорталу (рис. 4.3). Шлях A1 (І): фішинг пароля і обхід MFA через «втому від push-сповіщень»; A2 (АБО): викрадення сеансу через збережений XSS у панелі модерації або шкідливе ПЗ на робочій станції адміністратора; A3 (АБО): вада логіки — обхід відновлення пароля або виклик функцій адміністрування через API без перевірки ролі (BFLA).

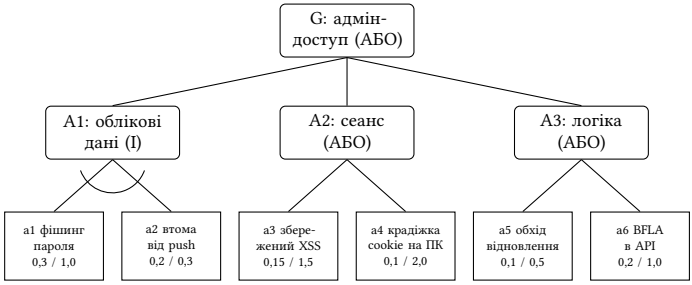


Рис. 4.3 — Дерево атак «заволодіння обліковим записом адміністратора» (у листі: імовірність успіху за рік / вартість в умовних одиницях; дуга — вузол «I»)

Маємо $p_{A1} = 0{,}3 \cdot 0{,}2 = 0{,}06$, $p_{A2} = 1 - 0{,}85 \cdot 0{,}9 = 0{,}235$, $p_{A3} = 1 - 0{,}9 \cdot 0{,}8 = 0{,}28$, $p_G = 1 - 0{,}94 \cdot 0{,}765 \cdot 0{,}72 \approx 0{,}482$; мінімальні вартості $c_{A1} = 1{,}3$, $c_{A2} = 1{,}5$, $c_{A3} = c_G = 0{,}5$. За $B = 10$ корисності сценаріїв: $U(a6) = 0{,}2 \cdot 10 - 1{,}0 = 1{,}0$, $U(a5) = 0{,}5$, $U(a3) = 0$, $U(A1) = -0{,}7$, $U(a4) = -1{,}0$ — раціональний порушник обере BFLA в API, а не фішинг, що зазвичай першим спадає на думку.

Заходи: ключі FIDO2 для адміністраторів (розділ **??**) знижують $p(a2)$ до 0,01; CSP з Trusted Types (розділ **??**) — $p(a3)$ до 0,03; виправлення відновлення і централізована перевірка ролей (розділ **??**) — $p(a5)$ до 0,01, $p(a6)$ до 0,02. Тоді $p_{A1} = 0{,}003$, $p_{A2} = 0{,}127$, $p_{A3} = 0{,}030$, $p_G \approx 0{,}156$ — утричі менше, і всі $U < 0$. Проте залишкову ймовірність тепер визначає a4: викрадений з робочої станції cookie обходить і MFA, і серверні перевірки. Прив'язка сеансу до пристрою (DBSC, розділ **??**) і привілейовані робочі станції ($p(a4) = 0{,}02$) дають $p_G \approx 0{,}080$. Типовий висновок: після закриття очевидних шляхів пріоритет зміщується на контроль сеансу і кінцевого пристрою.

4.5 Кількісне оцінювання ризику

4.5.1 ALE і FAIR

Класична модель визначає втрати від однієї події SLE $=$ AV $\cdot$ EF (вартість активу на частку втрати) і річні очікувані втрати як добуток на річну частоту ARO. Методологія FAIR (Factor Analysis of Information Risk) [73] розкладає частоту подій втрат (LEF) на частоту подій загрози (TEF) і вразливість (Vuln), а величину втрат (LM) — на первинні (реагування, відновлення, простій) і вторинні, спричинені реакцією сторонніх (штрафи, позови, відтік клієнтів):

$$\begin{aligned} \mathrm{ALE} &= \mathrm{SLE} \cdot \mathrm{ARO}, \qquad & \mathrm{LEF} &= \mathrm{TEF} \cdot \mathrm{Vuln}, \\ \mathrm{Vuln} &= \Pr\{\mathrm{TCap} > \mathrm{RS}\}, \qquad & \mathrm{LM} &= L_{\text{перв}} + p_{\text{втор}}\, L_{\text{втор}}, \end{aligned} \tag{4.2}$$

де TCap — спроможність загрози, RS — стійкість захисту на спільній шкалі, $p_{\text{втор}}$ — імовірність вторинних наслідків. Очікувані річні втрати дорівнюють LEF · E[LM], але кожен множник FAIR вимагає подавати розподілом (підрозділ 4.7).

Приклад. Вебпортал фіксує TEF $= 12$ кампаній заповнення облікових даних на рік; за наявних обмеження частоти й часткової MFA Vuln $= 0{,}25$, тож LEF $= 3$. Первинні втрати події — 200 тис. грн; з імовірністю 0,3 подія набуває розголосу з вторинними втратами 1 500 тис. грн. Тоді LM $= 650$ тис. грн і ALE $= 1\,950$ тис. грн. Орієнтиром порядку величин є галузеві дані (середня світова вартість витоку даних у 2025 р. — 4,44 млн дол. США [79]), що погано переносяться на конкретну організацію. Методику оцінювання комплексних (прямих, непрямих, репутаційних) збитків запропоновано в [30], а кількісну методологію для випадку відсутності фінансових даних про втрати — у [1].

4.5.2 ROSI та економічне обґрунтування заходів

Доцільність заходу j оцінюють рентабельністю інвестицій у безпеку [124]. Щоб урахувати взаємодію заходів, ефект визначають відносно вже впровадженої множини X за мультиплікативною моделлю ефективності:

$$\begin{gathered}\mathrm{ROSI}_j = \frac{\Delta\mathrm{ALE}_j - C_j}{C_j}, \qquad \Delta\mathrm{ALE}_j = \mathrm{ALE}(X) - \mathrm{ALE}(X \cup \{j\}), \\ \mathrm{ALE}(X) = \sum_i \mathrm{ALE}_i^0 \prod_{m \in X} \bigl(1 - e_{im}\bigr),\end{gathered} \tag{4.3}$$

де C_j — річна вартість заходу (амортизація, ліцензії, праця, вплив на швидкість розробки); $e_{im} \in [0;1]$ — частка зниження ризику сценарію i заходом m. У прикладі вище захід вартістю 400 тис. грн (перевірка паролів за списками зламаних, обов'язкова MFA, протидія ботам), що знижує LEF на 70 %, дає $\Delta\mathrm{ALE} = 1\,365$ і ROSI $\approx 2{,}41$. Заходи ранжують жадібно з перерахунком після кожного кроку; для однотипних заходів модель (4.3) завищує ефект, і їх об'єднують.

4.5.3 Модель Гордона–Лоба

Гордон і Лоб [74] розглянули інформаційний набір з потенційними втратами L і ймовірністю порушення без інвестицій v, яку інвестиції z знижують до $S(z, v)$:

$$\begin{gathered}z^{*} = \arg\max_{z \ge 0} \Bigl\{ \bigl[v - S(z,v)\bigr] L - z \Bigr\}, \qquad S(z,v) = \frac{v}{(\alpha z + 1)^{\beta}}, \\ z^{*} < vL/e \approx 0{,}37\, vL,\end{gathered} \tag{4.4}$$

де $\alpha, \beta > 0$ — параметри продуктивності інвестицій; межу vL/e доведено для двох широких класів функцій S. Для S з (4.4) $z^* = \left[(\alpha\beta vL)^{1/(\beta+1)} - 1\right]/\alpha$. За $v = 0{,}6$, $L = 5\,000$ тис. грн, $\alpha = 0{,}002$ (тис. грн)$^{-1}$, $\beta = 1$ маємо $z^* = (\sqrt{6} - 1)/0{,}002 \approx 725$ тис. грн, $S(z^*) \approx 0{,}245$, чисту вигоду $(0{,}6 - 0{,}245) \cdot 5\,000 - 725 \approx 1\,050$ тис. грн; межа $vL/e \approx 1\,104$ не перевищена. Оскільки α і β на практиці невідомі, цінність моделі — у висновках: інвестувати «до нуля ризику» нераціонально, бюджет понад третину очікуваних втрат потребує обґрунтування, а оптимальні інвестиції не обов'язково зростають з v — захист найвразливіших наборів може бути настільки дорогим, що раціональніше захищати набори із середньою вразливістю.

ROSI — інструмент ранжування, а не остаточного рішення: обов'язкові заходи (розділ 2) впроваджують незалежно від нього, цінність детективних заходів погано виражається через ΔALE, а для державних послуг L має включати втрати громадян.

4.6 Безпека за проєктом

4.6.1 Небезпечний дизайн і сценарії зловживання

Категорія A06:2025 «Insecure Design» [108] відокремлює вади *проєкту* від вад *реалізації*: досконала реалізація небезпечного проєкту залишається небезпечною, бо потрібний механізм не передбачено. Приклади: відновлення доступу через «секретні запитання»; відсутність обмеження кількості цінних операцій (масове бронювання талонів, перебір промокодів); довіра до ціни чи ролі від клієнта; багатокрокові процеси без серверної перевірки порядку кроків (CWE-841); відсутність розділення орендарів. Такі вади не виявляють сканери, бо кожен запит синтаксично коректний.

Загрози на рівні вимог описують **сценаріями зловживання** (abuse cases) [95] або **сценаріями неправомірного використання** (misuse cases) [123], які зображують на одній діаграмі з use-сценаріями з відношеннями «загрожує» і «пом'якшує». Наприклад, сценарій «громадянин замовляє витяг» доповнюють сценарієм «бот масово замовляє витяги щодо інших осіб, перебираючи ідентифікатори», що пом'якшується авторизацією на рівні об'єкта і квотами. Сценарії перетворюють на перевірювані вимоги ASVS 5.0 [102]: розділу V2 (валідація та бізнес-логіка), V8 (авторизація), V15 (безпечне кодування й архітектура). Рівень ASVS обирають за ризиком: для державного порталу чи інтернет-банкінгу обґрунтований L2 для всього застосунку і L3 для функцій з найвищим впливом.

4.6.2 Шаблони безпечного проєктування

Шаблони безпечного проєктування усувають цілі класи вад [40, 103]: *повна опосередкованість* — кожен доступ проходить через єдиний серверний

механізм авторизації; *заборона за замовчуванням* для нових кінцевих точок API; *безпечні за замовчуванням API* — шаблонізатори з контекстним кодуванням, ORM з параметризацією; *розділення привілеїв* — адміністративний інтерфейс як окремий застосунок за окремою межею довіри; *мінімізація даних*; *ідемпотентність і транзакційність* бізнес-операцій проти станів гонитви (подвійне нарахування паралельними запитами). Ці шаблони переносять безпеку з дисципліни розробника на властивість платформи (розділ **??**).

4.6.3 Моделювання загроз в Agile і DevSecOps

Разовий семінар перед випуском погано узгоджується з ітеративною розробкою. NIST SSDF [125] (PW.1) і OWASP SAMM [105] (Threat Assessment) розглядають моделювання загроз як безперервну діяльність на трьох рівнях: запитання STRIDE для історії користувача, що перетинає межу довіри; модель застосунку, що оновлюється при архітектурних змінах; глибокий аналіз (PASTA, дерева атак) для критичних функцій. **Моделювання загроз як код** (threat modeling as code) описує DFD текстом у репозиторії поруч із кодом, рецензує його як код і генерує діаграми та переліки кандидатних загроз; прикладами є OWASP pytm [104] і OWASP Threat Dragon [106]. Згенерований перелік — лише контрольний список: специфічних вад бізнес-логіки він не виявляє.

4.7 Невизначеність оцінок

4.7.1 Інтервальні оцінки та PERT

Точкові оцінки створюють ілюзію точності: «3 інциденти на рік» насправді означає інтервал. Практика кількісного оцінювання [78, 73] вимагає 90-відсоткових довірчих інтервалів або трійок «мінімум–найімовірніше–максимум». Для трійки (a, m, b) використовують бета-PERT-розподіл, а для величин, що охоплюють порядки (втрати), — логнормальний з параметрами за 90-відсотковим інтервалом $[a; b]$:

$$\mu_{\text{PERT}} = \frac{a + 4m + b}{6}, \qquad \sigma_{\text{PERT}} \approx \frac{b - a}{6};$$
$$\ln X \sim \mathcal{N}(\mu, \sigma^2), \quad \mu = \frac{\ln a + \ln b}{2}, \quad \sigma = \frac{\ln b - \ln a}{2 \cdot 1{,}645}, \quad \mathrm{E}[X] = e^{\mu + \sigma^2/2}. \tag{4.5}$$

Для частоти $(a, m, b) = (1;\ 3;\ 12)$ на рік $\mu_{\text{PERT}} \approx 4{,}17$, $\sigma_{\text{PERT}} \approx 1{,}83$: асиметрія зсуває середнє вправо від моди. Для втрат від серйозного витоку з інтервалом $[200;\ 5\,000]$ тис. грн медіана $\sqrt{200 \cdot 5\,000} = 1\,000$, $\sigma \approx 0{,}978$, $\mathrm{E}[X] \approx 1\,614$ тис. грн — на 60 % більше за медіану через важкий хвіст. «Ти-

пове» значення замість середнього систематично занижує ризик найруйнівніших сценаріїв.

4.7.2 Метод Монте-Карло і криві перевищення втрат

Річні втрати моделюють складеним пуассонівським процесом: кількість подій $N \sim \mathrm{Poisson}(\lambda)$, втрати X_k незалежні й однаково розподілені. Результат — **крива перевищення втрат** (loss exceedance curve, LEC):

$$L_\Sigma = \sum_{k=1}^{N} X_k, \qquad \mathrm{E}[L_\Sigma] = \lambda\,\mathrm{E}[X],$$
$$\bar{F}(\ell) = \Pr\{L_\Sigma > \ell\} \approx \frac{1}{M}\sum_{r=1}^{M} \mathbf{1}\{L_\Sigma^{(r)} > \ell\}, \tag{4.6}$$

де M — кількість ітерацій. Для $\lambda = 0{,}5$ і логнормальних втрат з інтервалом $[200;\,5\,000]$ моделювання з $M = 2\cdot 10^5$ дає $\mathrm{E}[L_\Sigma] \approx 807$ тис. грн (аналітично $0{,}5 \cdot 1\,614$), імовірність хоча б однієї події $1 - e^{-0{,}5} \approx 0{,}39$, $\bar{F}(1\,000) \approx 0{,}23$, $\bar{F}(5\,000) \approx 0{,}033$, 95-й і 99-й процентилі — близько 4 000 і 8 400 тис. грн. Якщо керівництво задало *криву толерантності* «втрати понад 5 млн грн на рік — з імовірністю не більше 2 %», ризик неприйнятний, хоча середні втрати (0,8 млн) помірні. На відміну від порядкових матриць «імовірність × вплив», де добуток рангів не має кількісного змісту, LEC адитивна за сценаріями й інтерпретована [78].

4.7.3 Калібрування експертів і байєсове оновлення

Експерт *калібрований*, якщо близько 90 % його 90-відсоткових інтервалів містять істинне значення. Непідготовлені експерти надмірно впевнені, а коротке тренування із зворотним зв'язком суттєво покращує калібрування [78]. Якість бінарних прогнозів вимірюють оцінкою Браєра $\mathrm{BS} = \frac{1}{n}\sum_i (f_i - o_i)^2$, де f_i — прогнозована ймовірність, $o_i \in \{0,1\}$ — результат.

Оцінки оновлюють за даними моніторингу (розділ **??**). Якщо апріорну частоту λ описано гамма-розподілом (α_0, β_0), а за час t зареєстровано k подій, то завдяки спряженості з пуассонівською правдоподібністю

$$\lambda \mid k \sim \mathrm{Gamma}(\alpha_0 + k,\ \beta_0 + t), \qquad \mathrm{E}[\lambda \mid k] = \frac{\alpha_0 + k}{\beta_0 + t}. \tag{4.7}$$

Апріорна оцінка 2 серйозні інциденти на рік з $(\alpha_0, \beta_0) = (2;\,1)$ і 1 інцидент за 3 роки дають апостеріорне середнє $(2+1)/(1+3) = 0{,}75$ на рік. Відсутність інцидентів теж є даними, якщо система виявлення здатна їх помітити (підрозділ 3.4).

4.8 Кейс: модель загроз і реєстр ризиків порталу державних послуг

4.8.1 Модель загроз і реєстр ризиків

Портал державних електронних послуг має архітектуру рис. 4.2: $2 \cdot 10^5$ облікових записів громадян (пароль з необов'язковою MFA або КЕП), кабінет посадовців, API довідок і витягів, інтеграції з реєстрами, CDN без розвиненої протидії ботам, сторонні бібліотеки з публічних репозиторіїв. Портал підлягає авторизації з безпеки за профілем безпеки [6], тож реєстр ризиків обґрунтовує вибір заходів. Аналіз STRIDE-per-element дав 63 кандидатні пари, з яких після відкидання закритих типовими заходами лишилося шість сценаріїв, оцінених експертно за (4.2) (табл. 4.4; тис. грн, ARO — подій на рік; для R4 і R5 включено суспільні втрати від недоступності послуг).

Таблиця 4.4 — Реєстр ризиків порталу державних послуг (фрагмент)

ID	Сценарій (STRIDE; база знань)	ARO	SLE	ALE_0	Залиш.
R1	Заповнення облікових даних (S; CAPEC-600)	6	120	720	108
R2	IDOR в API витягів (I; CWE-639)	1,5	600	900	180
R3	Збережений XSS у кабінеті посадовця (S, E; CWE-79)	0,5	800	400	100
R4	Прикладний DDoS у піковий період (D; T1499)	4	150	600	600
R5	Шкідлива залежність у збиранні (T; T1195.001)	0,2	4 000	800	320
R6	Зловживання логікою черги (T, E; CWE-841)	2	100	200	120
	Разом			3 620	1 428

Стовпець «Залиш.» — залишковий ризик після заходів M1, M2, M3, M5 (див. нижче). Власники ризиків: R1, R3 — керівник напряму ідентифікації; R2, R6 — власник продукту; R4 — служба експлуатації; R5 — керівник розробки.

4.8.2 Вибір заходів за ROSI

Розглянуто п'ять заходів: M1 — фішингостійка MFA і ключі доступу, перевірка паролів за списками зламаних, обмеження частоти ($C = 500$; R1: $e = 0{,}85$); M2 — централізована авторизація на рівні об'єктів і функцій з тестами авторизації в CI ($C = 350$; R2: $0{,}8$; R6: $0{,}4$); M3 — CSP з Trusted Types і контекстне кодування ($C = 150$; R3: $0{,}75$); M4 — WAAP з протидією ботам і захистом від DDoS прикладного рівня ($C = 700$; R4: $0{,}7$; R1: $0{,}3$; R6: $0{,}3$); M5 — SBOM, аналіз складу ПЗ, фіксація версій і перевірка цілісності залежностей ($C = 300$; R5: $0{,}6$). Результати жадібного вибору за (4.3) наведено в табл. 4.5.

Таблиця 4.5 — Послідовне обґрунтування заходів (тис. грн на рік)

Крок	C_j	ΔALE_j	ROSI	ALE після	Рішення
M2	350	800	1,29	2 820	впровадити
M3	150	300	1,00	2 520	впровадити
M5	300	480	0,60	2 040	впровадити
M1	500	612	0,22	1 428	впровадити
M4	700	488	−0,30	940	див. текст

Перші чотири заходи мають додатний ROSI; їхня сумарна вартість 1 300 тис. грн узгоджується з орієнтиром Гордона–Лоба $3\,620/e \approx 1\,332$, а сумарна вартість ризику (втрати плюс витрати) зменшується з 3 620 до $1\,428 + 1\,300 = 2\,728$. Захід M4 має від'ємний ROSI навіть першим кроком ($\Delta\text{ALE} = 696$, $\text{ROSI} \approx -0{,}01$), а після M1 і M2 його внесок у зниження R1 і R6 частково дублюється. Проте після чотирьох заходів найбільший залишковий ризик — R4 (600 з 1 428), а досвід DDoS-атак на державні ресурси (розділ 1) свідчить, що $\text{ARO} = 4$ може бути заниженим. Раціонально переглянути M4: базовий захист від DDoS у межах CDN і окремий пул для дорогих запитів (розділ **??**) з перевіркою чутливості методом Монте-Карло.

4.8.3 Залишковий ризик і прийняття

Після M1, M2, M3, M5 залишкові очікувані втрати становлять 1 428 тис. грн на рік (39 % початкових). R2 і R3 (вади застосунку) знижено в 4–5 разів, а домінують R4 і R5, що залежать від зовнішніх сторін. Їх приймає керівництво відповідно до апетиту до ризику з щоквартальним переглядом: частоти R1 і R4 оновлюють за даними моніторингу за (4.7), а R5 — за повідомленнями про компрометацію пакетів (розділ **??**). Залишковий ризик — явне управлінське рішення, а не побічний продукт заходів.

Висновки до розділу

Управління ризиками вебзастосунку ґрунтується на ISO/IEC 27005, ISO 31000, NIST SP 800-30 і функції управління CSF 2.0, але потребує функціонального визначення меж через потоки даних і межі довіри та врахування сеансів, бізнес-процесів, доступності й довіри як активів. STRIDE-per-element забезпечує повноту за властивостями безпеки, PASTA пов'язує сценарії з бізнес-цілями, LINDDUN охоплює приватність, а CWE, CAPEC і ATT&CK дають спільну мову проєктування, тестування і моніторингу. Дерево атак показало, що раціональний порушник обирає не найочевидніший шлях, а найдешевшу ваду логіки, і що після закриття очевидних шляхів пріоритет зміщується на захист сеансу й кінцевого пристрою. ROSI ранжує заходи з урахуванням уже впроваджених, модель Гордона–Лоба обмежує раціональний бюджет третиною очікуваних втрат,

а невизначеність подають розподілами і кривими перевищення втрат з байєсовим оновленням; порядкові матриці придатні лише для комунікації. У кейсі порталу державних послуг очікувані втрати знижено з 3,62 до 1,43 млн грн на рік за витрат 1,3 млн грн, а залишковий ризик змістився до доступності та ланцюга постачання (розділи **??** і **??**).

Питання для самоперевірки

1. Опишіть етапи процесу управління ризиками за ISO/IEC 27005:2022 (рис. 4.1). Чим подієвий підхід до ідентифікації ризиків відрізняється від активо-орієнтованого?
2. Яку роль відіграє функція GOVERN у CSF 2.0? Хто встановлює критерії прийняття ризику?
3. Чому межі вебзастосунку визначають функціонально? Які його активи відсутні в переліку «дані–системи»?
4. Побудуйте DFD для інтернет-магазину з платіжним шлюзом і позначте межі довіри. Які потоки перетинають найбільше меж?
5. Для кожної категорії STRIDE (табл. 4.1) наведіть по одному прояву в API мобільного банкінгу і відповідний захід.
6. Обчисліть кількість кандидатних пар STRIDE-per-element (табл. 4.2) для DFD з 2 зовнішніми сутностями, 5 процесами, 12 потоками і 4 сховищами. Як скоротити перебір без втрати повноти?
7. Порівняйте STRIDE і PASTA за вхідними даними, результатом і трудомісткістю. Для яких застосунків виправдана PASTA?
8. Проаналізуйте за LINDDUN форму відновлення пароля, що повідомляє «користувача з такою адресою не знайдено».
9. За табл. 4.3 поясніть, чому техніка T1190 надто груба для моделювання загроз вебзастосунку і як це компенсує CAPEC.
10. Для дерева рис. 4.3 обчисліть p_G і c_G, якщо впроваджено лише FIDO2 для адміністраторів. Який сценарій максимізує U^* за (4.1) при $B = 5$?
11. За (4.2) обчисліть ALE для TEF $= 20$, Vuln $= 0{,}1$, первинних втрат 300 і вторинних 2 000 тис. грн з імовірністю 0,2. Яким має бути ефект заходу вартістю 250, щоб ROSI ≥ 1?
12. Поясніть результат Гордона–Лоба (4.4). Чому оптимальні інвестиції не обов'язково зростають з вразливістю набору?
13. Наведіть три вади категорії A06:2025, які не виявляє сканер вразливостей, і для кожної сформулюйте сценарій зловживання та вимогу ASVS.

14. Чому крива перевищення втрат (4.6) інформативніша за матрицю «імовірність × вплив»? Обчисліть $\mathrm{E}[L_\Sigma]$ для $\lambda = 1$ і інтервалу втрат $[100;\ 10\,000]$.
15. Дослідницьке: розробіть метод автоматичного оновлення моделі загроз у конвеєрі CI/CD (threat modeling as code), що виявляє зміни DFD, які перетинають межі довіри, і оцініть його повноту на відкритому вебзастосунку.
16. Дослідницьке: для кейсу підрозділу 4.8 замініть точкові ARO і SLE інтервалами, побудуйте криві перевищення втрат до і після заходів методом Монте-Карло та дослідіть чутливість рішення щодо M4 до невизначеності частоти DDoS-атак.

Список використаних джерел

[1] Байдур О. Кількісна методологія оцінки ризиків кібербезпеки при відсутності фінансових даних про втрати. *Кібербезпека: освіта, наука, техніка.* 2024. Т. 2, № 26. С. 95–114. DOI: 10.28925/2663-4023.2024.26.659.

[2] Балацька В., Ткачук Р., Маслова Н. Еволюція КСЗІ та інтеграція блокчейн-технологій у кіберзахисті державних інформаційних систем України. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 2, № 30. С. 316–332. DOI: 10.28925/2663-4023.2025.30.975.

[3] Денисюк В. Прогнозування експлуатації CVE на основі відкритих даних NVD та KEV для ризико-орієнтованої пріоритизації. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 2, № 30. С. 428–444. DOI: 10.28925/2663-4023.2025.30.906.

[4] Державна служба спеціального зв'язку та захисту інформації України: офіційний вебсайт. URL: https://cip.gov.ua/.

[5] Держспецзв'язку: Від 15 лютого Україна зазнала понад 3 000 DDoS-атак. *Урядовий портал.* 16.03.2022. URL: https://www.kmu.gov.ua/news/derzhspeczvyazku-vid-15-lyutogo-ukrayina-zaznala-ponad-3-000-ddos-atak.

[6] Деякі питання захисту інформаційних, електронних комунікаційних, інформаційно-комунікаційних, технологічних систем: постанова Кабінету Міністрів України від 18.06.2025 № 712. URL: https://www.kmu.gov.ua/npas/deiaki-pytannia-zakhystu-informatsiinykh-elektronnykh-komunikatsiinykh-informatsiino-s712180625.

[7] ДСТУ EN ISO/IEC 27001:2023. Інформаційна безпека, кібербезпека та захист приватності. Системи керування інформаційною безпекою. Вимоги (EN ISO/IEC 27001:2022, IDT). Київ: ДП «УкрНДНЦ», 2023.

[8] ДСТУ EN ISO/IEC 27002:2023. Інформаційна безпека, кібербезпека та захист приватності. Заходи інформаційної безпеки (EN ISO/IEC 27002:2022, IDT). Київ: ДП «УкрНДНЦ», 2023.

[9] Загальні вимоги до кіберзахисту об'єктів критичної інфраструктури: затв. постановою Кабінету Міністрів України від 19.06.2019 № 518. URL: https://zakon.rada.gov.ua/laws/show/518-2019-п.

[10] Кримінальний кодекс України від 05.04.2001 № 2341-III. Розділ XVI. Кримінальні правопорушення у сфері використання електронно-обчислювальних машин (комп'ютерів), систем та комп'ютерних мереж і мереж електрозв'язку. URL: https://zakon.rada.gov.ua/laws/show/2341-14.

[11] Курій Є., Опірський І. ISO 27001: аналіз змін та особливості відповідності новій версії стандарту. *Кібербезпека: освіта, наука, техніка.* 2023. Т. 3, № 19. С. 46–55. DOI: 10.28925/2663-4023.2023.19.4655.

[12] НД ТЗІ 1.1-002-99. Загальні положення щодо захисту інформації в комп'ютерних системах від несанкціонованого доступу. Київ: ДСТСЗІ СБ України, 1999. URL: https://cip.gov.ua/ua/news/normativni-dokumenti-z-pitan-tzi.

[13] НД ТЗІ 2.5-004-99. Критерії оцінки захищеності інформації в комп'ютерних системах від несанкціонованого доступу. Київ: ДСТСЗІ СБ України, 1999.

[14] НД ТЗІ 3.7-003-05. Порядок проведення робіт із створення комплексної системи захисту інформації в інформаційно-телекомунікаційній системі. Київ: ДСТСЗІ СБ України, 2005.

[15] Новини 14 січня: російські хакери атакували 70 державних сайтів, українські активи падають. *Економічна правда.* 14.01.2022. URL: https://epravda.com.ua/news/2022/01/14/681463/.

[16] Огляд національної системи кібербезпеки України 2025: аналітичне дослідження. Київ: Національний координаційний центр кібербезпеки при РНБО України, 2026. URL: https://rnbo.gov.ua/files/2026/NATIONAL_CYBER_SCC/kiber_2025.pdf.

[17] Петрів П., Опірський І. Аналіз проблематики використання існуючих стандартів з веб-вразливостей. *Кібербезпека: освіта, наука, техніка.* 2023. Т. 2, № 22. С. 96–112. DOI: 10.28925/2663-4023.2023.22.96112. URL: https://csecurity.kubg.edu.ua/index.php/journal/article/view/512.

[18] Поночовний П. Модель упередження низькошвидкісних HTTP DDoS атак на кінцевого користувача. *Кібербезпека: освіта, наука, техніка.* 2024. Т. 2, № 26. С. 291–304. DOI: 10.28925/2663-4023.2024.26.695.

[19] Правила забезпечення захисту інформації в інформаційних, електронних комунікаційних та інформаційно-комунікаційних системах: затв. постановою Кабінету Міністрів України від 29.03.2006 № 373. URL: https://zakon.rada.gov.ua/laws/show/373-2006-п.

[20] Про внесення змін до деяких законів України щодо захисту інформації та кіберзахисту державних інформаційних ресурсів, об'єктів критичної інформаційної інфраструктури: Закон України від 27.03.2025 № 4336-IX. URL: https://zakon.rada.gov.ua/laws/show/4336-20.

[21] Про електронні довірчі послуги: Закон України від 05.10.2017 № 2155-VIII. URL: https://zakon.rada.gov.ua/laws/show/2155-19.

[22] Про електронну комерцію: Закон України від 03.09.2015 № 675-VIII. URL: https://zakon.rada.gov.ua/laws/show/675-19.

[23] Про затвердження Порядку інформаційного наповнення та технічного забезпечення Єдиного веб-порталу органів виконавчої влади та Порядку функціонування веб-сайтів органів виконавчої влади: наказ Держкомінформполітики, Держкомзв'язку від 25.11.2002 № 327/225. Зареєстровано в Мін'юсті 29.12.2002 за № 1021/7309. URL: https://zakon.rada.gov.ua/laws/show/z1021-02.

[24] Про захист інформації в інформаційно-комунікаційних системах: Закон України від 05.07.1994 № 80/94-ВР. URL: https://zakon.rada.gov.ua/laws/show/80/94-вр.

[25] Про захист персональних даних: Закон України від 01.06.2010 № 2297-VI. URL: https://zakon.rada.gov.ua/laws/show/2297-17.

[26] Про критичну інфраструктуру: Закон України від 16.11.2021 № 1882-IX. URL: https://zakon.rada.gov.ua/laws/show/1882-20.

[27] Про основні засади забезпечення кібербезпеки України: Закон України від 05.10.2017 № 2163-VIII (редакція від 19.10.2025). URL: https://zakon.rada.gov.ua/laws/show/2163-19.

[28] Про рішення Ради національної безпеки і оборони України від 14 травня 2021 року «Про Стратегію кібербезпеки України»: Указ Президента України від 26.08.2021 № 447/2021. URL: https://zakon.rada.gov.ua/laws/show/447/2021.

[29] Про хмарні послуги: Закон України від 17.02.2022 № 2075-IX. URL: https://zakon.rada.gov.ua/laws/show/2075-20.

[30] Соколов В., Складанний П. Методика оцінки комплексних збитків від інциденту інформаційної безпеки. *Кібербезпека: освіта, наука, техніка.* 2023. Т. 1, № 21. С. 99–120. DOI: 10.28925/2663-4023.2023.21.99120.

[31] У 2025 році кількість ворожих кібератак зросла на 37 %: кого атакують найчастіше (за даними CERT-UA). *dev.ua.* 08.01.2026. URL: https://dev.ua/news/u-2025-rotsi-kilkist-kiberatak-zrosla-na-37-1767858414.

[32] Чалий О., Толюпа С. Порівняння міжнародних стандартів аудиту інформаційної безпеки з перспективою автоматизації. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 3, № 31. С. 579–588. DOI: 10.28925/2663-4023.2025.31.1046.

[33] Шевченко С., Жданова Ю., Кія О. Напівавтоматизований інструмент багатостандартної оцінки кіберзрілості організації на основі NIST CSF 2.0, ISO/IEC 27001:2022, COBIT 2019 та CIS Controls v8. *Кібербезпека: освіта, наука, техніка.* 2025. Т. 3, № 31. С. 43–60. DOI: 10.28925/2663-4023.2025.31.1004.

[34] Штонда Р., Зозуля Р., Бокій О. Удосконалення парольної політики та використання сучасних менеджерів паролів для підвищення рівня кіберстійкості інформаційно-комунікаційних систем. *Кібербезпека: освіта, наука, техніка.* 2026. Т. 4, № 32. С. 431–447. DOI: 10.28925/2663-4023.2026.32.1114.

[35] 16 лютого — спільний брифінг Мінцифри, СБУ, Держспецзв'язку, Кіберполіції, РНБО та НБУ щодо хакерських атак 15 лютого. *Урядовий портал.* 16.02.2022. URL: https://www.kmu.gov.ua/events/16-lyutogo-spilnij-brifing-mincifri-sbu-derzhspeczvyazku-kiberpoliciyi-rnbo-ta-nbu-shchodo-hakerskih-atak-15-lyutogo.

[36] 2025 CWE Top 25 Most Dangerous Software Weaknesses. The MITRE Corporation, CISA, 2025. URL: https://cwe.mitre.org/top25/archive/2025/2025_cwe_top25.html.

[37] 2025 Imperva Bad Bot Report: How AI is Supercharging the Bot Threat. *Imperva Blog* (Thales Group). 15.04.2025. URL: https://www.imperva.com/blog/2025-imperva-bad-bot-report-how-ai-is-supercharging-the-bot-threat/.

[38] 485 інформаційних систем в Україні авторизовані у першому півріччі 2026 року. *Урядовий портал*. 27.07.2026. URL: https://www.kmu.gov.ua/news/485-informatsiinykh-system-v-ukraini-avtoryzovani-u-pershomu-pivrichchi-2026-roku.

[39] Akhawe D., Barth A., Lam P. E., Mitchell J., Song D. Towards a Formal Foundation of Web Security. *Proceedings of the 23rd IEEE Computer Security Foundations Symposium (CSF 2010)*. Edinburgh: IEEE, 2010. P. 290–304. DOI: 10.1109/CSF.2010.27.

[40] Anderson R. Security Engineering: A Guide to Building Dependable Distributed Systems. 3rd ed. Indianapolis: Wiley, 2020. 1232 p. URL: https://www.cl.cam.ac.uk/~rja14/book.html.

[41] Axelsson S. The Base-Rate Fallacy and the Difficulty of Intrusion Detection. *ACM Transactions on Information and System Security*. 2000. Vol. 3, No. 3. P. 186–205. DOI: 10.1145/357830.357849.

[42] Barth A. HTTP State Management Mechanism. RFC 6265. IETF, 2011. DOI: 10.17487/RFC6265. URL: https://www.rfc-editor.org/rfc/rfc6265.

[43] Barth A. The Web Origin Concept. RFC 6454. IETF, 2011. DOI: 10.17487/RFC6454. URL: https://www.rfc-editor.org/rfc/rfc6454.

[44] Biryukov A., Dinu D., Khovratovich D., Josefsson S. Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications. RFC 9106. IRTF, 2021. DOI: 10.17487/RFC9106.

[45] Bishop M. (Ed.). HTTP/3. RFC 9114. IETF, 2022. DOI: 10.17487/RFC9114. URL: https://www.rfc-editor.org/rfc/rfc9114.

[46] Bonneau J. The Science of Guessing: Analyzing an Anonymized Corpus of 70 Million Passwords. *2012 IEEE Symposium on Security and Privacy*. San Francisco: IEEE, 2012. P. 538–552. DOI: 10.1109/SP.2012.49.

[47] CERT-UA: Урядова команда реагування на комп'ютерні надзвичайні події України. URL: https://cert.gov.ua/.

[48] Chiara P. G. The Cyber Resilience Act: the EU Commission's proposal for a horizontal regulation on cybersecurity for products with digital elements. *International Cybersecurity Law Review*. 2022. Vol. 3, no. 2. P. 255–272. DOI: 10.1365/s43439-022-00067-6.

[49] CISA, FBI. Update: Destructive Malware Targeting Organizations in Ukraine. Cybersecurity Advisory AA22-057A. 26.02.2022 (rev. 28.04.2022). URL: https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-057a.

[50] CISA. Known Exploited Vulnerabilities Catalog. Cybersecurity and Infrastructure Security Agency, 2021–2026. URL: https://www.cisa.gov/known-exploited-vulnerabilities-catalog.

[51] CISA. Stakeholder-Specific Vulnerability Categorization Guide. Cybersecurity and Infrastructure Security Agency, 2022. URL: https://www.cisa.gov/stakeholder-specific-vulnerability-categorization-ssvc.

[52] Commission Implementing Regulation (EU) 2024/2690 of 17 October 2024 laying down rules for the application of Directive (EU) 2022/2555 as regards technical and methodological requirements of cybersecurity risk-management measures and further specification of the cases in which an incident is considered to be significant. *Official Journal of the EU*. L series, 18.10.2024. URL: https://eur-lex.europa.eu/eli/reg_impl/2024/2690/oj.

[53] Commission Implementing Regulation (EU) 2024/482 of 31 January 2024 laying down rules for the application of Regulation (EU) 2019/881 as regards the adoption of the European Common Criteria-based cybersecurity certification scheme (EUCC). *Official Journal of the EU*. L series, 07.02.2024. URL: https://eur-lex.europa.eu/eli/reg_impl/2024/482/oj.

[54] Commission Implementing Regulation (EU) 2025/2392 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847. *Official Journal of the EU*. L series, 01.12.2025. URL: https://eur-lex.europa.eu/eli/reg_impl/2025/2392/oj/eng.

[55] Common Attack Pattern Enumeration and Classification (CAPEC). The MITRE Corporation. URL: https://capec.mitre.org/.

[56] Common Weakness Enumeration (CWE). The MITRE Corporation. URL: https://cwe.mitre.org/.

[57] Content Security Policy Level 3. World Wide Web Consortium (W3C). URL: https://www.w3.org/TR/CSP3/.

[58] Croley S. (Chick3nman). Hashcat v6.2.6 Benchmark on the Nvidia RTX 4090. GitHub Gist, 2022. URL: https://gist.github.com/Chick3nman/32e662a5bb63bc4f51b847bb422222fd.

[59] Crosby S. A., Wallach D. S. Denial of Service via Algorithmic Complexity Attacks. *Proceedings of the 12th USENIX Security Symposium*. Washington, D.C.: USENIX, 2003. P. 29–44. URL: https://www.usenix.org/conference/12th-usenix-security-symposium/denial-service-algorithmic-complexity-attacks.

[60] Das A., Bonneau J., Caesar M., Borisov N., Wang X. The Tangled Web of Password Reuse. *Network and Distributed System Security Symposium (NDSS 2014)*. San Diego: Internet Society, 2014. DOI: 10.14722/ndss.2014.23357.

[61] DDoS-атака на мільйони доларів. Банки та урядові сайти зазнали наймасштабнішої атаки в історії України. *Forbes Україна*. 16.02.2022. URL: https://forbes.ua/news/ddos-ataka-na-milyoni-dolariv-banki-ta-uryadovi-sayti-zaznali-naymasshtabnishoi-ataki-v-istorii-ukraini-16022022-3706.

[62] Deng M., Wuyts K., Scandariato R., Preneel B., Joosen W. A Privacy Threat Analysis Framework: Supporting the Elicitation and Fulfillment of Privacy Requirements. *Requirements Engineering*. 2011. Vol. 16, No. 1. P. 3–32. DOI: 10.1007/s00766-010-0115-7.

[63] Directive (EU) 2019/882 of the European Parliament and of the Council of 17 April 2019 on the accessibility requirements for products and services (European

Accessibility Act). *Official Journal of the EU*. L 151. P. 70–115. URL: https://eur-lex.europa.eu/eli/dir/2019/882/oj.

[64] Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union (NIS 2 Directive). *Official Journal of the EU*. L 333. P. 80–152. URL: https://eur-lex.europa.eu/eli/dir/2022/2555/oj.

[65] Durumeric Z., Bailey M., Halderman J. A. An Internet-Wide View of Internet-Wide Scanning. *Proceedings of the 23rd USENIX Security Symposium*. San Diego: USENIX Association, 2014. P. 65–78. URL: https://www.usenix.org/conference/usenixsecurity14/technical-sessions/presentation/durumeric.

[66] Durumeric Z., Wustrow E., Halderman J. A. ZMap: Fast Internet-wide Scanning and Its Security Applications. *Proceedings of the 22nd USENIX Security Symposium*. Washington, D.C.: USENIX Association, 2013. P. 605–620. URL: https://www.usenix.org/conference/usenixsecurity13/technical-sessions/paper/durumeric.

[67] ENISA Threat Landscape 2025. Athens: European Union Agency for Cybersecurity, 2025. URL: https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025.

[68] Fahl S. Web & Mobile Security Knowledge Area. Version 1.0.1. *The Cyber Security Body of Knowledge (CyBOK)*. © Crown Copyright, The National Cyber Security Centre, 2021. URL: https://www.cybok.org/.

[69] Fetch Living Standard. WHATWG. URL: https://fetch.spec.whatwg.org/.

[70] Fielding R. T. Architectural Styles and the Design of Network-based Software Architectures: doctoral dissertation. Irvine: University of California, 2000. 162 p. URL: https://ics.uci.edu/~fielding/pubs/dissertation/top.htm.

[71] Fielding R., Nottingham M., Reschke J. (Ed.). HTTP Semantics. RFC 9110. IETF, 2022. DOI: 10.17487/RFC9110. URL: https://www.rfc-editor.org/rfc/rfc9110.

[72] FIRST. Common Vulnerability Scoring System Version 4.0: Specification Document. Forum of Incident Response and Security Teams, 2023. URL: https://www.first.org/cvss/v4-0/specification-document.

[73] Freund J., Jones J. Measuring and Managing Information Risk: A FAIR Approach. Oxford: Butterworth-Heinemann, 2014. 408 p.

[74] Gordon L. A., Loeb M. P. The Economics of Information Security Investment. *ACM Transactions on Information and System Security*. 2002. Vol. 5, No. 4. P. 438–457. DOI: 10.1145/581271.581274.

[75] Harbison M., Falcone R., Grunzweig J. Threat Brief: Ongoing Russia and Ukraine Cyber Activity. *Palo Alto Networks Unit 42*. 20.01.2022. URL: https://unit42.paloaltonetworks.com/ukraine-cyber-conflict-cve-2021-32648-whispergate/.

[76] Hoffman A. Web Application Security: Exploitation and Countermeasures for Modern Web Applications. 2nd ed. Sebastopol, CA: O'Reilly Media, 2024. 440 p.

[77] HTML Living Standard. WHATWG. URL: https://html.spec.whatwg.org/.

[78] Hubbard D. W., Seiersen R. How to Measure Anything in Cybersecurity Risk. 2nd ed. Hoboken: Wiley, 2023. 368 p. ISBN 978-1-119-89230-4.

[79] IBM Security, Ponemon Institute. Cost of a Data Breach Report 2025. Armonk: IBM, 2025. URL: https://www.ibm.com/reports/data-breach.

[80] Important Updates Announced for Merchants Validating to Self-Assessment Questionnaire A. *PCI Perspectives Blog*. PCI Security Standards Council, 2025. URL: https://blog.pcisecuritystandards.org/important-updates-announced-for-merchants-validating-to-self-assessment-questionnaire-a.

[81] ISO 31000:2018. Risk management — Guidelines. Geneva: ISO, 2018. URL: https://www.iso.org/standard/65694.html.

[82] ISO/IEC 15408-1:2022. Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 1: Introduction and general model. Geneva: ISO, 2022. URL: https://www.iso.org/standard/72891.html.

[83] ISO/IEC 27005:2022. Information security, cybersecurity and privacy protection — Guidance on managing information security risks. Geneva: ISO, 2022. URL: https://www.iso.org/standard/80585.html.

[84] ISO/IEC 27034-1:2011. Information technology — Security techniques — Application security — Part 1: Overview and concepts. Geneva: ISO, 2011. URL: https://www.iso.org/standard/44378.html.

[85] Jacobs J., Romanosky S., Adjerid I., Baker W. Improving Vulnerability Remediation through Better Exploit Prediction. *Journal of Cybersecurity*. 2020. Vol. 6, No. 1. Article tyaa015. DOI: 10.1093/cybsec/tyaa015.

[86] Jacobs J., Romanosky S., Edwards B., Adjerid I., Roytman M. Exploit Prediction Scoring System (EPSS). *Digital Threats: Research and Practice*. 2021. Vol. 2, No. 3. Article 20. DOI: 10.1145/3436242.

[87] Jacobs J., Romanosky S., Suciu O., Edwards B., Sarabi A. Enhancing Vulnerability Prioritization: Data-Driven Exploit Predictions with Community-Driven Insights. *2023 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW)*. Delft: IEEE, 2023. P. 194–206. DOI: 10.1109/EuroSPW59978.2023.00027.

[88] Kleinrock L. Queueing Systems. Vol. 1: Theory. New York: Wiley, 1975. 417 p.

[89] Kordy B., Piètre-Cambacédès L., Schweitzer P. DAG-based Attack and Defense Modeling: Don't Miss the Forest for the Attack Trees. *Computer Science Review*. 2014. Vol. 13–14. P. 1–38. DOI: 10.1016/j.cosrev.2014.07.001.

[90] Lauinger T., Chaabane A., Arshad S., Robertson W., Wilson C., Kirda E. Thou Shalt Not Depend on Me: Analysing the Use of Outdated JavaScript Libraries on the Web. *Proceedings of the Network and Distributed System Security Symposium (NDSS 2017)*. San Diego: Internet Society, 2017. DOI: 10.14722/ndss.2017.23414.

[91] Manadhata P. K., Wing J. M. An Attack Surface Metric. *IEEE Transactions on Software Engineering*. 2011. Vol. 37, No. 3. P. 371–386. DOI: 10.1109/TSE.2010.60.

[92] Massey J. L. Guessing and Entropy. *Proceedings of the 1994 IEEE International Symposium on Information Theory*. Trondheim: IEEE, 1994. P. 204. DOI: 10.1109/ISIT.1994.394764.

[93] Matte C., Bielova N., Santos C. Do Cookie Banners Respect my Choice? Measuring Legal Compliance of Banners from IAB Europe's Transparency and Consent Framework. *2020 IEEE Symposium on Security and Privacy (SP)*. San Francisco, CA: IEEE, 2020. P. 791–809. DOI: 10.1109/SP40000.2020.00076.

[94] Mauw S., Oostdijk M. Foundations of Attack Trees. *Information Security and Cryptology — ICISC 2005*. Lecture Notes in Computer Science, vol. 3935. Berlin, Heidelberg: Springer, 2006. P. 186–198. DOI: 10.1007/11734727_17.

[95] McDermott J., Fox C. Using Abuse Case Models for Security Requirements Analysis. *Proceedings 15th Annual Computer Security Applications Conference (ACSAC'99)*. Phoenix: IEEE, 1999. P. 55–64. DOI: 10.1109/CSAC.1999.816013.

[96] MITRE ATT&CK®: Adversarial Tactics, Techniques, and Common Knowledge (Enterprise matrix). The MITRE Corporation. URL: https://attack.mitre.org/.

[97] Nikiforakis N., Invernizzi L., Kapravelos A., Van Acker S., Joosen W., Kruegel C., Piessens F., Vigna G. You Are What You Include: Large-scale Evaluation of Remote JavaScript Inclusions. *Proceedings of the 2012 ACM Conference on Computer and Communications Security (CCS '12)*. New York: ACM, 2012. P. 736–747. DOI: 10.1145/2382196.2382274.

[98] NIST. Guide for Conducting Risk Assessments. NIST SP 800-30, Rev. 1. Gaithersburg, MD, 2012. DOI: 10.6028/NIST.SP.800-30r1. URL: https://csrc.nist.gov/pubs/sp/800/30/r1/final.

[99] NIST. Security and Privacy Controls for Information Systems and Organizations. NIST SP 800-53, Rev. 5. Gaithersburg, MD, 2020. DOI: 10.6028/NIST.SP.800-53r5. URL: https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final.

[100] NIST. The NIST Cybersecurity Framework (CSF) 2.0. NIST CSWP 29. Gaithersburg, MD, 2024. DOI: 10.6028/NIST.CSWP.29. URL: https://csrc.nist.gov/pubs/cswp/29/the-nist-cybersecurity-framework-20/final.

[101] OWASP API Security Top 10: 2023. OWASP Foundation, 2023. URL: https://owasp.org/API-Security/editions/2023/en/0x00-header/.

[102] OWASP Application Security Verification Standard (ASVS). Version 5.0.0. OWASP Foundation, 2025. URL: https://owasp.org/www-project-application-security-verification-standard/.

[103] OWASP Cheat Sheet Series. OWASP Foundation. URL: https://cheatsheetseries.owasp.org/.

[104] OWASP pytm: A Pythonic Framework for Threat Modeling. OWASP Foundation. URL: https://github.com/OWASP/pytm.

[105] OWASP Software Assurance Maturity Model (SAMM). Version 2.0. OWASP Foundation, 2020. URL: https://owaspsamm.org/model/.

[106] OWASP Threat Dragon. OWASP Foundation. URL: https://owasp.org/www-project-threat-dragon/.

[107] OWASP Top 10 for Large Language Model Applications: 2025. OWASP GenAI Security Project, 2024. URL: https://genai.owasp.org/llm-top-10/.

[108] OWASP Top 10:2025. The Ten Most Critical Web Application Security Risks. OWASP Foundation, 2025. URL: https://owasp.org/Top10/2025/.

[109] OWASP Web Security Testing Guide (WSTG). Version 4.2. OWASP Foundation, 2020. URL: https://owasp.org/www-project-web-security-testing-guide/.

[110] PCI Security Standards Council. Payment Card Industry Data Security Standard: Requirements and Testing Procedures. Version 4.0.1. Wakefield, MA: PCI SSC, 2024. URL: https://www.pcisecuritystandards.org/document_library/.

[111] Poolsappasit N., Dewri R., Ray I. Dynamic Security Risk Management Using Bayesian Attack Graphs. *IEEE Transactions on Dependable and Secure Computing*. 2012. Vol. 9, No. 1. P. 61–74. DOI: 10.1109/TDSC.2011.34.

[112] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data (General Data Protection Regulation). *Official Journal of the EU*. L 119. P. 1–88. URL: https://eur-lex.europa.eu/eli/reg/2016/679/oj.

[113] Regulation (EU) 2022/2065 of the European Parliament and of the Council of 19 October 2022 on a Single Market For Digital Services (Digital Services Act). *Official Journal of the EU*. L 277. P. 1–102. URL: https://eur-lex.europa.eu/eli/reg/2022/2065/oj.

[114] Regulation (EU) 2024/1183 of the European Parliament and of the Council of 11 April 2024 amending Regulation (EU) No 910/2014 as regards establishing the European Digital Identity Framework. *Official Journal of the EU*. L series, 30.04.2024. URL: https://eur-lex.europa.eu/eli/reg/2024/1183/oj.

[115] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act). *Official Journal of the EU*. L series, 20.11.2024. URL: https://eur-lex.europa.eu/eli/reg/2024/2847/oj.

[116] Rescorla E. The Transport Layer Security (TLS) Protocol Version 1.3. RFC 8446. IETF, 2018. DOI: 10.17487/RFC8446. URL: https://www.rfc-editor.org/rfc/rfc8446.

[117] Rose S., Borchert O., Mitchell S., Connelly S. Zero Trust Architecture. NIST Special Publication 800-207. Gaithersburg, MD, 2020. DOI: 10.6028/NIST.SP.800-207. URL: https://csrc.nist.gov/pubs/sp/800/207/final.

[118] Sakimura N., Bradley J., Jones M., de Medeiros B., Mortimore C. OpenID Connect Core 1.0 incorporating errata set 2. OpenID Foundation, 2023. URL: https://openid.net/specs/openid-connect-core-1_0.html.

[119] Schneier B. Attack Trees. *Dr. Dobb's Journal*. 1999. Vol. 24, No. 12. P. 21–29.

[120] Sheyner O., Haines J., Jha S., Lippmann R., Wing J. M. Automated Generation and Analysis of Attack Graphs. *Proceedings 2002 IEEE Symposium on Security and Privacy*. Berkeley: IEEE, 2002. DOI: 10.1109/SECPRI.2002.1004377.

[121] Shirey R. Internet Security Glossary, Version 2. RFC 4949. IETF, 2007. DOI: 10.17487/RFC4949. URL: https://www.rfc-editor.org/rfc/rfc4949.

[122] Shostack A. Threat Modeling: Designing for Security. Indianapolis: Wiley, 2014. 624 p.

[123] Sindre G., Opdahl A. L. Eliciting Security Requirements with Misuse Cases. *Requirements Engineering*. 2005. Vol. 10, No. 1. P. 34–44. DOI: 10.1007/s00766-004-0194-4.

[124] Sonnenreich W., Albanese J., Stout B. Return On Security Investment (ROSI) — A Practical Quantitative Model. *Journal of Research and Practice in Information Technology*. 2006. Vol. 38, No. 1. P. 45–56.

[125] Souppaya M., Scarfone K., Dodson D. Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities. NIST SP 800-218. Gaithersburg, MD, 2022. DOI: 10.6028/NIST.SP.800-218. URL: https://csrc.nist.gov/pubs/sp/800/218/final.

[126] Stuttard D., Pinto M. The Web Application Hacker's Handbook: Finding and Exploiting Security Flaws. 2nd ed. Indianapolis: Wiley, 2011. 912 p.

[127] Temoshok D., Fenton J. L., Choong Y.-Y., Lefkovitz N., Regenscheid A., Galluzzo R., Richer J. P. Digital Identity Guidelines. NIST SP 800-63-4. Gaithersburg, MD, 2025. DOI: 10.6028/NIST.SP.800-63-4. URL: https://csrc.nist.gov/pubs/sp/800/63/4/final.

[128] Threat Modeling Manifesto Working Group. Threat Modeling Manifesto. 2020. URL: https://www.threatmodelingmanifesto.org/.

[129] UcedaVélez T., Morana M. M. Risk Centric Threat Modeling: Process for Attack Simulation and Threat Analysis. Hoboken: Wiley, 2015. 696 p. ISBN 978-0-470-50096-5.

[130] Urban T., Vekaria Y., Shafiq Z., Böttger C. Third Parties. *The 2024 Web Almanac*. HTTP Archive, 2024. URL: https://almanac.httparchive.org/en/2024/third-parties.

[131] Wang D., Cheng H., Wang P., Huang X., Jian G. Zipf's Law in Passwords. *IEEE Transactions on Information Forensics and Security*. 2017. Vol. 12, No. 11. P. 2776–2791. DOI: 10.1109/TIFS.2017.2721359.

[132] Web Authentication: An API for accessing Public Key Credentials. Level 3. World Wide Web Consortium (W3C). URL: https://www.w3.org/TR/webauthn-3/.

[133] Xiong W., Lagerström R. Threat Modeling — A Systematic Literature Review. *Computers & Security*. 2019. Vol. 84. P. 53–69. DOI: 10.1016/j.cose.2019.03.010.

[134] Zalewski M. The Tangled Web: A Guide to Securing Modern Web Applications. San Francisco: No Starch Press, 2011. 320 p.

Додаток. Завдання для самостійної роботи

Завдання згруповано за тематичними блоками посібника. Для кожної теми зазначено зміст роботи та форму подання результату. Результати доцільно оформлювати як фрагменти дослідницької роботи магістранта: з постановкою задачі, обґрунтуванням методу, числовими результатами та висновками. Багато завдань спираються на дослідницькі питання самоперевірки відповідних розділів. Завдання, що передбачають практичне виконання атак, виконуються лише на власних навчальних стендах (наприклад, навмисно вразливих застосунках OWASP) або в межах письмово погодженого тестування.

Блок I. Засади

1. **Аналіз вебресурсу як об'єкта захисту** (розділ 1). Для обраного реального вебресурсу визначити архітектуру, домени довіри, сторонні компоненти, побудувати багаторівневу поверхню атаки та модель порушника. *Форма:* аналітична записка зі схемами.
2. **Визначення застосовних нормативних вимог** (розділ 2). Для державного вебпорталу або інтернет-магазину скласти реєстр обов'язкових і добровільних вимог (законодавство України, ЄС, PCI DSS, ASVS), обчислити індекс розриву відповідності. *Форма:* реєстр вимог і розрахунок.
3. **Кількісне оцінювання захищеності** (розділ 3). Для заданого вебзастосунку розрахувати стійкість секретів і токенів, ефективність обмеження частоти спроб, частку істинних тривог системи виявлення та запас стійкості до перевантаження. *Форма:* розрахунково-аналітична записка.
4. **Моделювання загроз і оцінювання ризиків** (розділ 4). Побудувати діаграму потоків даних, модель загроз (STRIDE, LINDDUN), дерево атак і кількісну оцінку ризику з обґрунтуванням заходів. *Форма:* модель загроз і реєстр ризиків.

Блок II. Механізми та технології захисту вебзастосунків

5. **Профіль захисту транспортного рівня** (розділ **??**). Проаналізувати конфігурацію TLS, сертифікатів, HSTS і DNS для групи вебресурсів (наприклад, державних доменів), сформулювати профіль конфігурації з урахуванням постквантового переходу. *Форма:* звіт з результатами вимірювань.

6. **Політика безпеки клієнтської частини** (розділ ??). Розробити й обґрунтувати політику CSP, заголовки ізоляції та атрибути cookie для вебзастосунку зі сторонніми скриптами; оцінити залишкові ризики XSS і CSRF. *Форма:* проєктне рішення.
7. **Захист від ін'єкцій** (розділ ??). На навчальному стенді дослідити класи ін'єкцій і SSRF, розробити заходи на рівні архітектури та коду, перевірити їхню ефективність. *Форма:* звіт з результатами експериментів.
8. **Схема автентифікації** (розділ ??). Спроєктувати схему автентифікації й керування сеансами з ключами доступу (passkeys) і процедурою відновлення облікового запису; визначити рівень AAL. *Форма:* проєктне рішення й аналіз загроз.
9. **Модель авторизації та федеративного входу** (розділ ??). Розробити модель контролю доступу (RBAC/ABAC/ReBAC) та профіль OAuth 2.0/OpenID Connect для багатокористувацького застосунку. *Форма:* модель і профіль конфігурації.
10. **Аудит безпеки API** (розділ ??). Для заданої специфікації OpenAPI або GraphQL-схеми виявити ризики за OWASP API Security Top 10, запропонувати політики шлюзу API. *Форма:* звіт аудиту.
11. **Стійкість до відмови в обслуговуванні** (розділ ??). Розробити багаторівневу схему захисту вебресурсу від DDoS і ботів, оцінити необхідну ємність і вартість. *Форма:* архітектура й розрахунок.

Блок III. Платформи, інфраструктура та нові класи загроз

12. **Захищене розгортання у хмарі** (розділ ??). Спроєктувати розгортання вебзастосунку в контейнерному середовищі з розмежуванням відповідальності, керуванням секретами й контролем конфігурацій. *Форма:* проєкт і перелік контрольних перевірок.
13. **Безпека ланцюга постачання** (розділ ??). Сформувати SBOM для реального проєкту, проаналізувати транзитивні залежності й вразливості, запропонувати рівень SLSA і заходи для конвеєра CI/CD. *Форма:* SBOM, аналіз і план заходів.
14. **Захист застосунку зі штучним інтелектом** (розділ ??). Побудувати модель загроз для вебзастосунку з великою мовною моделлю та агентами, запропонувати й експериментально перевірити захисні патерни проти ін'єкції підказок. *Форма:* модель загроз і звіт.

Блок IV. Операційна безпека та управління

15. **Програма тестування захищеності** (розділ ??). Розробити програму тестування вебзастосунку з поєднанням SAST, DAST, SCA і ручного

тестування; визначити метрики покриття й ефективності. *Форма:* програма й методика.

16. **Моніторинг і реагування** (розділ **??**). Спроєктувати схему журналювання, правила кореляції та сценарії реагування на інциденти вебресурсу; оцінити показники MTTD і MTTR. *Форма:* проєкт системи моніторингу і сценарії.
17. **Програма безпеки та наукове дослідження** (розділ **??**). Оцінити зрілість процесів безпечного розроблення організації за OWASP SAMM або виконати систематичний огляд за обраним перспективним напрямом як основу дисертаційного дослідження. *Форма:* оцінка зрілості з дорожньою картою або огляд із постановкою наукової задачі.